PARIS PANTHÉON-ASSAS UNIVERSITÉ

PROJET DE SÉCURITÉ RÉSEAU

MediConnect – Sécurisation de l'infrastructure réseau

Projet de sécurité réseau MediConnect

Auteurs	Enzo JUZYNA, Hugo JUZYNA
Promotion	2028
Année universitaire	2026-2027
Date	Octobre 2026

Table des matières

1 Introduction **2**
- 1.1 Contexte et objectifs . . . 2
- 1.2 Populations et besoins . . . 2
- 1.3 Démarche . . . 2
- 1.4 Environnement de laboratoire . . . 3

2 Architecture retenue **3**

3 Plan d'adressage **4**
- 3.1 Siège – FW_Siege . . . 5
- 3.2 Site secondaire – FW_SITE2 . . . 5
- 3.3 Clients VPN (attribution par RADIUS) . . . 5

4 Zones de sécurité et niveaux de confiance **6**

5 VPN utilisés **6**

6 Mécanismes d'authentification **9**

7 Politique de filtrage **11**
- 7.1 Matrice des flux autorisés (siège) . . . 11
- 7.2 Pare-feu locaux (défense en profondeur) . . . 12
- 7.3 Ressources des employés et du support . . . 14

8 Règles basées sur l'identité **15**

9 Contrôle applicatif **18**

10 Protection de la DMZ **19**

11 Sécurisation de l'administration **20**

12 Stratégie de journalisation **21**

13 Tests réalisés **22**

14 Limites et difficultés **24**
- 14.1 Limites de la solution . . . 24
- 14.2 Difficultés rencontrées . . . 24

15 Conclusion **24**

A Captures complémentaires **26**

B Script de test des accès **55**

Résumé

L'infrastructure de MediConnect repose sur deux pare-feu pfSense reliés par un tunnel IPsec, neuf zones internes filtrées au siège plus une zone VPN, un VPN d'accès distant avec MFA et des droits par profil, une DMZ dont les pages ne sont servies qu'en HTTPS (le port 80 ne fait que rediriger), une détection d'intrusion Suricata et une journalisation centralisée.

1. Introduction

1.1 Contexte et objectifs

MediConnect est une plateforme de prise de rendez-vous médicaux qui traite des données de santé. L'entreprise compte un siège, un site secondaire, des salariés en télétravail et des commerciaux itinérants. Le projet consiste à concevoir et déployer une architecture réseau qui protège ces données tout en donnant à chaque population l'accès dont elle a besoin, et seulement celui-là.

Les exigences du sujet :

- interconnexion chiffrée des deux sites ;
- VPN pour les employés en télétravail et les commerciaux ;
- portail patients accessible uniquement en HTTPS ;
- espace médecins distinct, avec authentification forte (MFA) et sans accès réseau direct ;
- DMZ et séparation entre la production et l'environnement de démonstration ;
- contrôle applicatif et règles fondées sur l'identité ;
- administration isolée : un utilisateur du réseau local ne doit pas pouvoir administrer ;
- journalisation centralisée.

1.2 Populations et besoins

Population	Où	Besoin	Réponse mise en place
Patients	Internet	prendre rendez-vous	portail public en HTTPS dans la DMZ (NAT 443)
Médecins	Internet	consulter leur agenda	espace médecins (8443) : certificat + mot de passe, aucun accès au réseau interne
Commerciaux	siège, site 2, itinérants	CRM, démonstration	zones COMMERCIAUX et COMMERCIAL, VPN_COMMERCIAUX
Comptabilité	siège, télétravail	serveur comptable	zone COMPTABILITE, VPN_COMPTA
Employés (direction, équipes administratives)	siège, site 2, télétravail	web, outils bureautiques	zones EMPLOYES et EMPLOYEE, VPN_EMPLOYE, SRV_BUREAU
Support	siège, site 2, télétravail	web, outils de support	zones SUPPORT (siège et site 2), VPN_SUPPORT, SRV_SUPPORT
Informatique	siège, télétravail	gérer l'authentification	zone IT, VPN_IT, SSH vers SRV_RADIUS
Administrateurs	siège, télétravail	administrer pare-feu et serveurs	zone ADMIN, VPN_ADMIN

1.3 Démarche

1. Conception : populations et flux nécessaires, une zone par profil, plan d'adressage et matrice des flux.

2. Déploiement et configuration de la maquette sous VMware : pare-feu, VPN, DMZ, Suricata, ufw et journalisation.
3. Validation et correction : tests par poste et par identité VPN, attaque simulée depuis Kali, lecture des journaux, puis correction des écarts trouvés.

1.4 Environnement de laboratoire

Élément	Choix
Virtualisation	VMware Workstation sur un hôte Windows ; un réseau virtuel (VMnet) par zone, VMnet8 (NAT) jouant le rôle d'Internet
Pare-feu	2 × pfSense 2.9.0 CE (FW_Siege, FW_SITE2), Suricata sur FW_Siege
Serveurs	9 × Ubuntu 26.04 : SRV_WEB (Apache), SRV_MEDECINS (nginx), SRV_CRM, SRV_COMPTA, SRV_BUREAU, SRV_SUPPORT, SRV_DEMO, SRV_RADIUS (FreeRADIUS), SRV_LOG (rsyslog)
Postes	Ubuntu 26.04 : un poste par zone au siège et au site 2, PC-TELETRAVAIL sur Internet ; clonés depuis un même modèle, ils portent presque tous le nom d'hôte pc-client, donc sur les captures chaque poste s'identifie par son adresse IP et par le nom de sa VM
Attaquant	Kali Linux sur Internet (VMnet8)
Outils de test	curl, ssh, dig, nmap, tcpdump et le script test_acces.sh

2. Architecture retenue

Un pare-feu pfSense par site, reliés par IPsec ; au siège, chaque profil d'utilisateurs et chaque famille de serveurs a sa propre zone, et pfSense est le seul point de passage entre elles.

Pourquoi pfSense. Open source et gratuit, il réunit dans une seule interface web tout ce que demande le sujet : filtrage par zone, NAT, IPsec, OpenVPN avec RADIUS, Suricata et envoi des journaux. La même distribution sert sur les deux sites, ce qui simplifie l'administration.

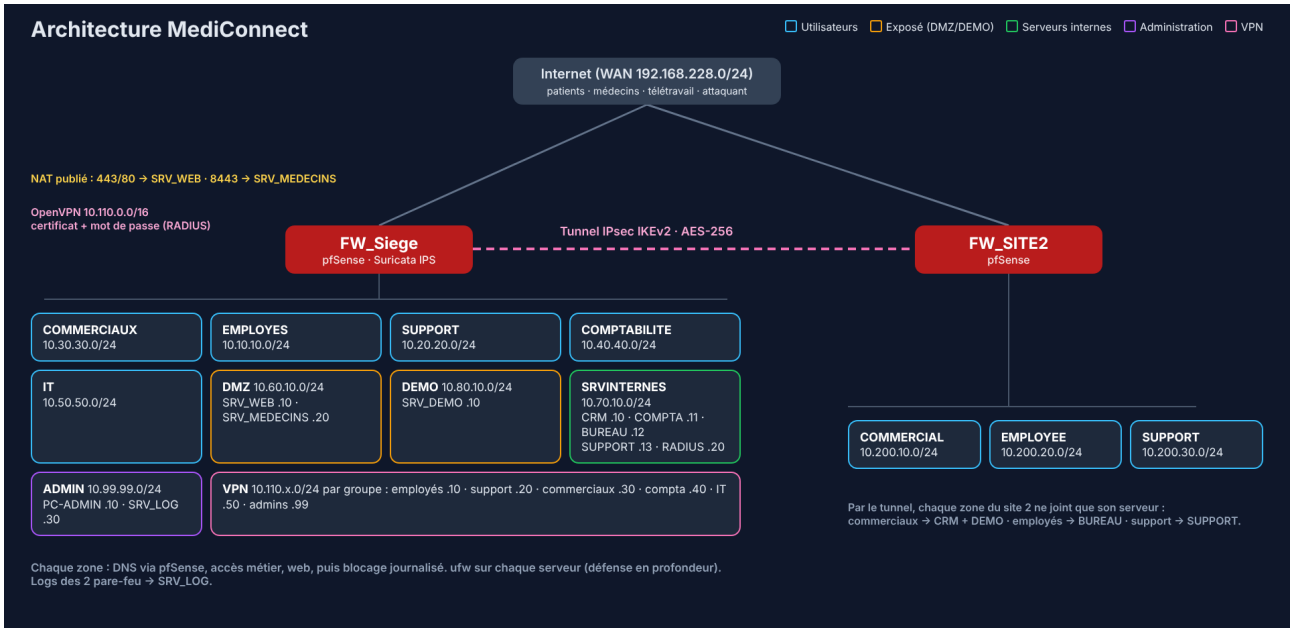


Figure 1 – Schéma de l'architecture : deux sites, neuf zones internes et une zone VPN au siège.

- **Siège (FW_Siege).** Dix interfaces : le WAN et neuf zones internes, plus l'interface VPN assignée pour les clients OpenVPN. pfSense porte le filtrage, le NAT de publication, les deux VPN, Suricata

et l'envoi des journaux.

- **Site secondaire (FW_SITE2).** Trois zones (commerciaux, employés, support), un accès Internet propre, et un tunnel IPsec vers le siège qui ne transporte que les flux autorisés : commerciaux vers le CRM, la DEMO et la zone d'administration, employés vers SRV_BUREAU, support vers SRV_SUPPORT.
- **Principe d'un profil = une zone.** Comme le propose le guide, un profil est matérialisé par un sous-réseau dédié, une interface dédiée et ses règles de filtrage.
- **Maquette.** VMware Workstation : un VMnet par zone, isolé de l'hôte ; VMnet8 (NAT) joue le rôle d'Internet pour les deux WAN, les postes nomades et l'attaquant (Kali).

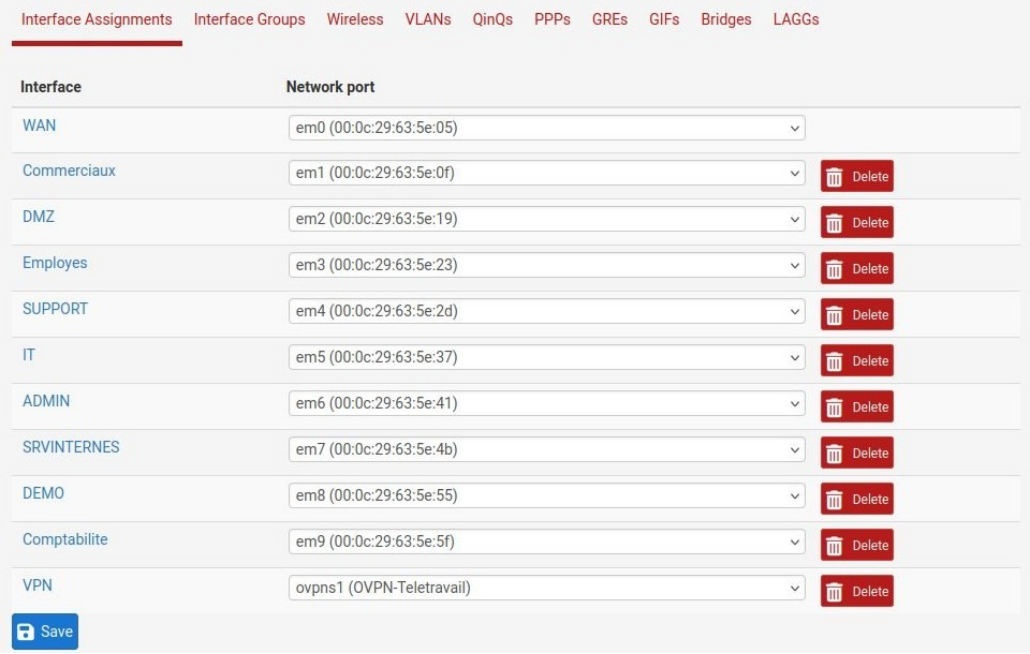


Figure 2 – FW_Siege : le WAN, neuf zones internes et l'interface VPN.

Captures complémentaires en annexe : figures A1 à A4.

3. Plan d'adressage

Chaque zone est un réseau /24 distinct, matérialisé par un VMnet dédié et une interface dédiée de pfSense ; la passerelle est toujours l'adresse .1 (pfSense), qui sert aussi de DNS. Les numéros de « VLAN » du guide sont repris dans le deuxième octet (10.10 = VLAN 10, etc.) ; les serveurs ont des IP fixes, regroupées par rôle (.10–.19 applications métier, .20–.29 infrastructure).

3.1 Siège – FW_Siege

Zone (interface)	« VLAN »	VMnet	Réseau	Passerelle	Machines
WAN (em0)	–	VMnet8 (NAT)	192.168.228.0/24	DHCP (.128)	accès Internet
COMMERCIAUX (em1)	30	VMnet2	10.30.30.0/24	10.30.30.1	PC_COMMERCIAL 10.30.30.100
DMZ (em2)	–	VMnet3	10.60.10.0/24	10.60.10.1	SRV_WEB 10.60.10.10, SRV_MEDECINS 10.60.10.20
EMPLOYES (em3)	10	VMnet6	10.10.10.0/24	10.10.10.1	PC_Employee 10.10.10.10
SUPPORT (em4)	20	VMnet7	10.20.20.0/24	10.20.20.1	PC-SUPPORT 10.20.20.10
IT (em5)	50	VMnet9	10.50.50.0/24	10.50.50.1	PC-IT 10.50.50.10
ADMIN (em6)	99	VMnet10	10.99.99.0/24	10.99.99.1	PC-ADMINISTRATEURS 10.99.99.10, SRV_LOG 10.99.99.30
SRVINTERNES (em7)	–	VMnet4	10.70.10.0/24	10.70.10.1	SRV_CRM 10.70.10.10, SRV_COMPTA 10.70.10.11, SRV_BUREAU 10.70.10.12, SRV_SUPPORT 10.70.10.13, SRV_RADIUS 10.70.10.20
DEMO (em8)	–	VMnet11	10.80.10.0/24	10.80.10.1	SRV_DEMO 10.80.10.10
COMPTABILITE (em9)	40	VMnet12	10.40.40.0/24	10.40.40.1	PC-COMPTA 10.40.40.10
VPN (ovpns1)	–	tunnel	10.110.0.0/16	10.110.0.1	clients OpenVPN

3.2 Site secondaire – FW_SITE2

Zone (interface)	VMnet	Réseau	Passerelle	Machines
WAN (em0)	VMnet8 (NAT)	192.168.228.0/24	DHCP (.129)	accès Internet indépendant
COMMERCIAL (em1)	VMnet5	10.200.10.0/24	10.200.10.1	PC_COMMERCIAL_Site2 10.200.10.10
EMPLOYEE (em2)	VMnet13	10.200.20.0/24	10.200.20.1	PC_Employee-Site2 10.200.20.10
SUPPORT (em3)	VMnet14	10.200.30.0/24	10.200.30.1	PC-SUPPORT-Site2 10.200.30.10

3.3 Clients VPN (attribution par RADIUS)

Groupe	Plage	Compte de test
Employés	10.110.10.0/24	employe01 → 10.110.10.10
Support	10.110.20.0/24	support01 → 10.110.20.10
Commerciaux	10.110.30.0/24	commercial01 → 10.110.30.10
Comptabilité	10.110.40.0/24	compta01 → 10.110.40.10
Informaticiens	10.110.50.0/24	it01 → 10.110.50.10
Administrateurs	10.110.99.0/24	admin01 → 10.110.99.10

Captures complémentaires en annexe : figures A5 à A11.

4. Zones de sécurité et niveaux de confiance

Plus une zone est exposée, plus son filtrage est strict ; la zone ADMIN, de confiance maximale, n'accepte de connexion entrante que du groupe VPN_ADMIN, authentifié par MFA. Tout passage d'une zone à l'autre traverse pfSense.

Zone	Confiance	Contenu	Ce qu'elle peut initier
Internet (WAN)	Nulle	patients, médecins, attaquants	seulement les services publiés : portail patients (443), espace médecins (8443), OpenVPN (1194)
DMZ	Très faible	portail patients, espace médecins	DNS et mises à jour vers Internet ; rien vers l'interne
DEMO	Faible	copie de démonstration, données fictives	DNS et mises à jour ; rien vers la production
VPN	Moyenne (identité vérifiée par MFA)	télétravailleurs, commerciaux itinérants, admins	selon le groupe de l'utilisateur
Site 2 (via IPsec)	Moyenne	employés, support, commerciaux du site secondaire	CRM et DEMO (443)
EMPLOYES, SUPPORT, COMMERCIAUX, COMPTABILITE, IT	Moyenne	postes de travail par profil	DNS, Internet (web) et les seuls serveurs de leur métier
SRVINTERNES	Élevée	CRM, Comptabilité, bureautique, support, RADIUS	DNS et mises à jour ; ils répondent mais n'initient rien vers les zones utilisateurs
ADMIN	Maximale	postes d'administration, serveur de logs	tout, journalisé

La DMZ et la DEMO portent en plus une règle explicite « vers RESEAUX_PRIVES : bloqué, journalisé », pour que toute tentative de rebond vers l'interne apparaisse nommément dans les logs.

5. VPN utilisés

Deux VPN aux rôles distincts : un tunnel IPsec permanent entre les deux sites, et un OpenVPN d'accès distant pour les utilisateurs nomades, qui aboutit au siège.

Pourquoi IPsec entre les sites. C'est le standard des tunnels site à site : interopérable entre équipements, il relie en permanence deux passerelles fixes, sans aucune action des utilisateurs.

Pourquoi OpenVPN pour les nomades. Il traverse les NAT et les box domestiques sur un seul port (UDP 1194), et identifie chaque personne par un certificat et un mot de passe RADIUS : c'est ce qui permet la MFA et des droits par groupe.

Pourquoi une clé pré-partagée. Pour deux passerelles fixes dans une maquette, une PSK longue est simple à déployer et suffisante ; en production, des certificats IKEv2 la remplaceraient (voir les limites).

	IPsec site à site	OpenVPN accès distant
Usage	relier le site 2 au siège	télétravailleurs, commerciaux itinérants, admins à distance
Extrémités	FW_Siege (192.168.228.128) ↔ FW_SITE2 (192.168.228.129)	client → WAN du siège, UDP 1194
Protocole	IKEv2	SSL/TLS, mode TUN, topologie subnet
Authentification	clé pré-partagée (Mutual PSK)	certificat utilisateur + mot de passe RADIUS (MFA)
Chiffrement	AES-256, SHA-256, DH groupe 14 (2048 bits)	AES-256-GCM, SHA-256, clé TLS (HMAC)
Réseaux transportés	10.200.10.0/24 ↔ 10.70.10.0/24 (serveurs), 10.80.10.0/24 (DEMO), 10.99.99.0/24 (admin) ; 10.200.20.0/24 ↔ 10.70.10.12 (bureautique) ; 10.200.30.0/24 ↔ 10.70.10.13 (support)	tunnel 10.110.0.0/16 ; tout le trafic du client (full tunnel)
Filtrage	onglet IPsec des deux pare-feu	interface VPN assignée (zone de terminaison VPN), règles par groupe

Les phases 2 IPsec ne portent que des réseaux de serveurs et d'administration, chacun associé à la seule zone du site 2 qui en a besoin : les employés du site 2 ne voient que SRV_BUREAU, le support que SRV_SUPPORT, et le site 2 n'a aucune route vers les postes du siège. L'OpenVPN fonctionne en full tunnel (Redirect IPv4 Gateway) : la navigation des postes nomades passe elle aussi par pfSense, où elle est filtrée, inspectée par Suricata et journalisée.

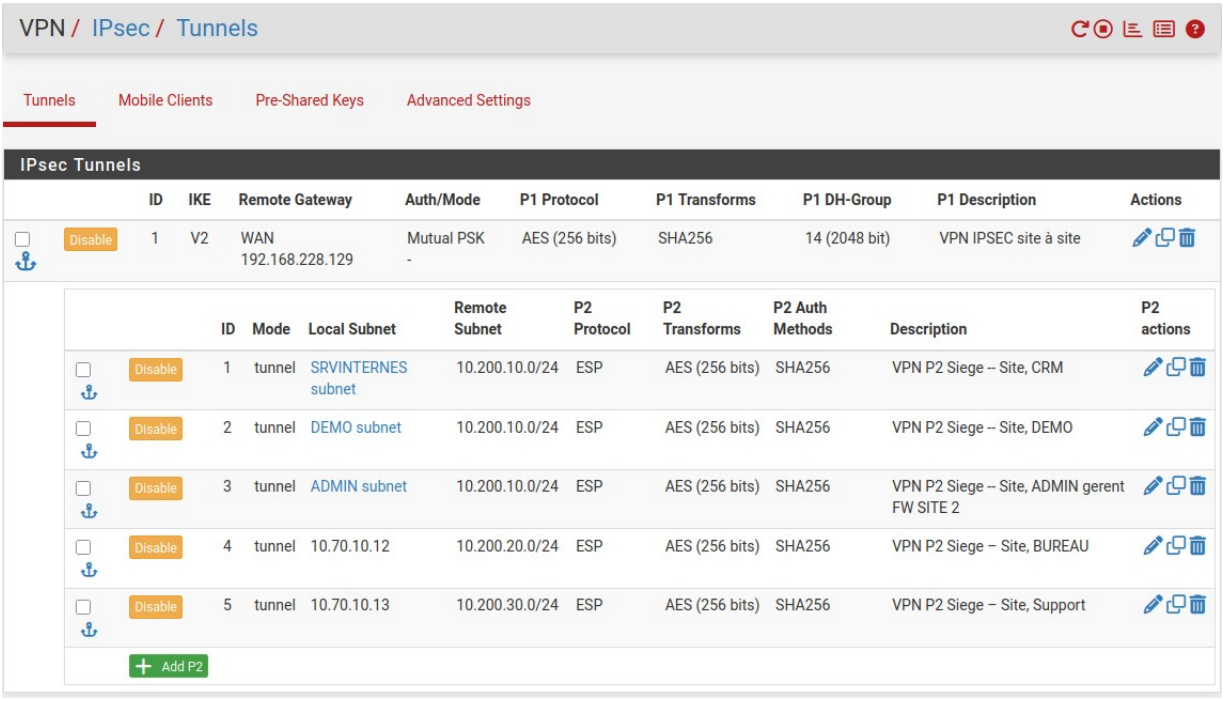


Figure 3 – IPsec côté siège : IKEv2, AES-256, SHA-256, DH 14 ; cinq phases 2 : SRVINTERNES, DEMO et ADMIN vers les commerciaux du site 2 (10.200.10.0/24), SRV_BUREAU (10.70.10.12) vers ses employés (10.200.20.0/24), SRV_SUPPORT (10.70.10.13) vers son support (10.200.30.0/24).

Le chiffrement a été vérifié sur le lien Internet lui-même, par une capture `tcpdump` sur le WAN de FW_Siege pendant un accès au CRM.

Captures complémentaires en annexe : figures A12 à A14.



Figure 4 – IPsec : entre 192.168.228.129 et 192.168.228.128, seuls des paquets ESP circulent ; ni l'adresse du CRM ni le contenu ne sont visibles.

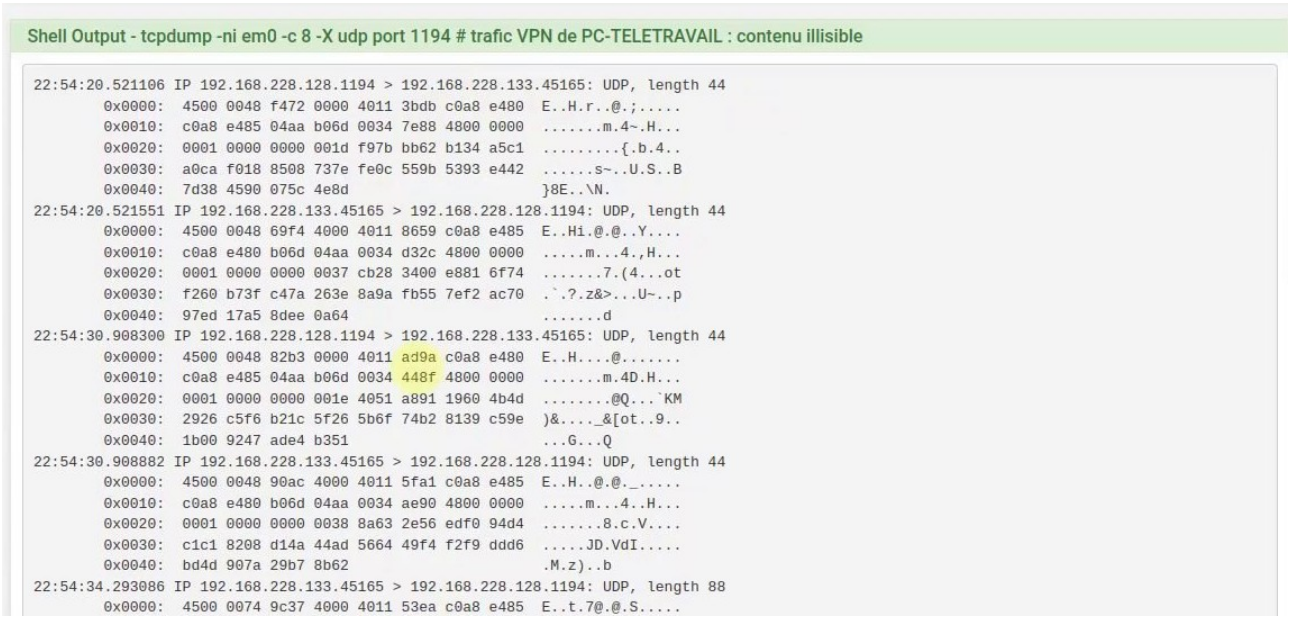


Figure 5 – OpenVPN : le trafic du télétravailleur sur UDP 1194 est illisible, alors qu'il consulte une page HTML du CRM.



Figure 6 – Full tunnel vérifié avec employe01 : les routes 0.0.0.0/1 et 128.0.0.0/1 passent par tun0, un DNS public (8.8.8.8) ne répond plus, et le web passe toujours, filtré par pfSense.

6. Mécanismes d'authentification

Chaque population s'authentifie avec un mécanisme proportionné à ses droits ; les médecins, les utilisateurs VPN et les administrateurs ont deux facteurs.

Population	Facteur 1 (posséder)	Facteur 2 (savoir)	Vérifié par
Patients	–	compte de l'application (hors périmètre)	application web
Médecins	certificat client X.509 signé par l'autorité « MediConnect CA Médecins »	identifiant + mot de passe	nginx sur SRV_MEDECINS (ssl_verify_client + auth_basic)
Utilisateurs VPN	certificat utilisateur signé par la CA « OVPN TELETRAVAIL »	mot de passe	pfSense (certificat) + FreeRADIUS (mot de passe)
Administrateurs à distance	certificat admin01	mot de passe RADIUS	idem VPN, groupe VPN_ADMIN
Administrateurs sur site	présence dans la zone ADMIN (isolée)	compte pfSense / SSH	pfSense, serveurs
Site 2	–	clé pré-partagée IPsec	les deux pare-feu

RADIUS centralisé. FreeRADIUS (SRV_RADIUS, 10.70.10.20) vérifie le mot de passe des comptes VPN et renvoie l'attribut Framed-IP-Address de leur groupe. Il n'accepte que les requêtes de pfSense (10.70.10.1, secret partagé) et se trouve dans la zone serveurs, hors d'atteinte des utilisateurs.

Strict User-CN Matching. Le nom d'utilisateur saisi doit être identique au nom du certificat : un certificat volé ne peut pas servir avec le mot de passe d'un autre compte (testé : AUTH_FAILED).

Certificats médecins. Sans certificat, nginx répond « 400 No required SSL certificate was sent » avant même d'afficher la page ; avec certificat mais mauvais mot de passe, « 401 ». Le journal nginx trace les deux facteurs sur une même ligne (utilisateur et sujet du certificat, verif=SUCCESS).

Captures complémentaires en annexe : figures A15 à A18.

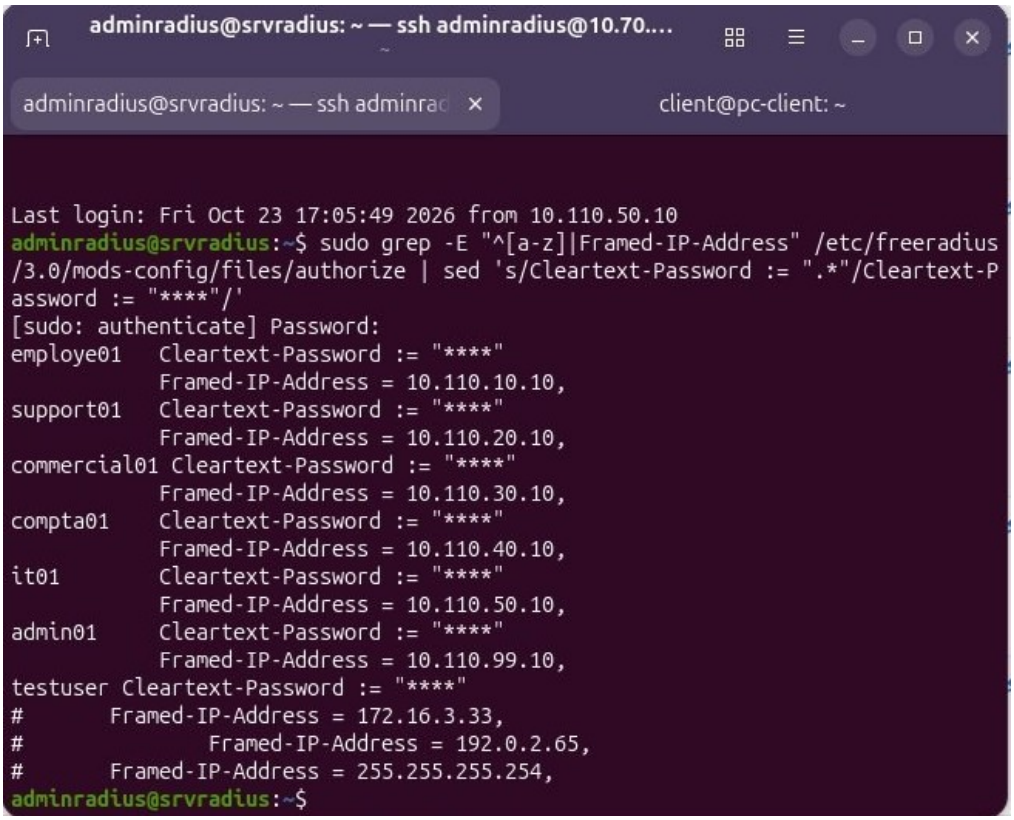


Figure 7 – Comptes RADIUS (mots de passe masqués) et adresse attribuée par groupe. La ligne testuser est le compte de test livré avec FreeRADIUS : il est désactivé, n'appartient à aucun groupe et n'a pas de certificat, il ne peut donc pas ouvrir de VPN.



Figure 8 – Certificat de compta01 + identifiants d'admin01 : AUTH_FAILED.

7. Politique de filtrage

La politique est « tout est interdit sauf ce qui est explicitement autorisé » : chaque interface se termine par un blocage journalisé, et aucune règle « any → any » n'existe hors de la zone ADMIN.

Toutes les interfaces suivent le même modèle :

1. DNS vers pfSense uniquement (pas de 8.8.8.8 : résolution journalisée, pas d'exfiltration par DNS) ;
2. les seuls accès métier du profil, par alias de serveur et port précis ;
3. Internet limité au web : destination ! RESEAUX_PRIVES (tout sauf 10/8, 172.16/12, 192.168/16), ports 80 et 443 ;
4. ping de la passerelle (diagnostic) ;
5. Block any, journalisé.

Le filtrage est à état : les réponses aux connexions autorisées repassent automatiquement, donc les serveurs n'ont besoin d'aucune règle sortante pour répondre.

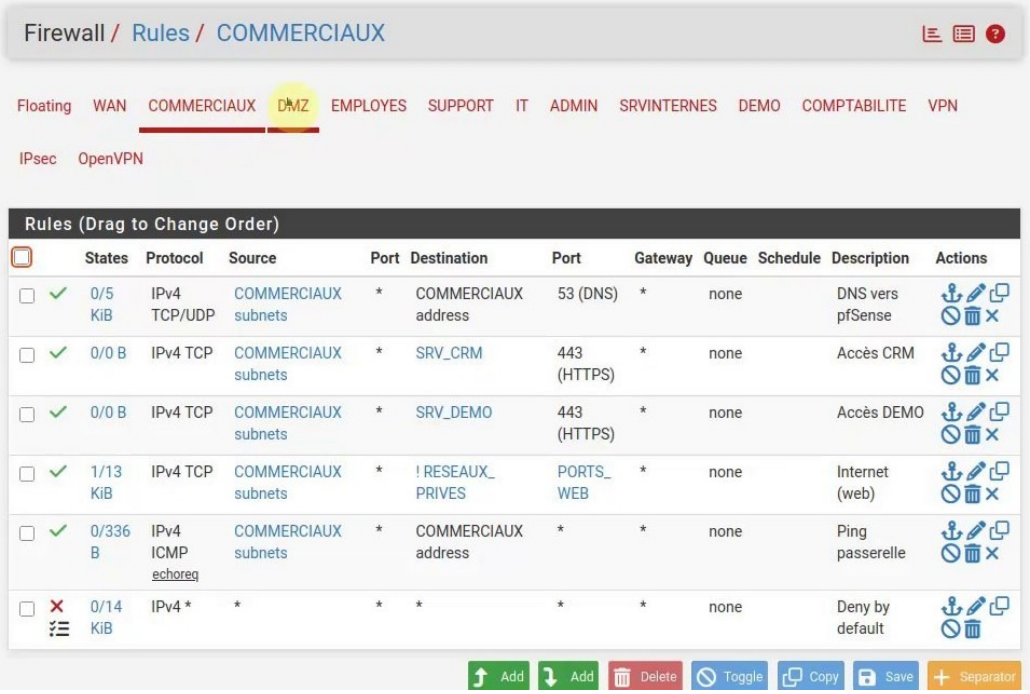


Figure 9 – Règles d'une zone utilisateurs (COMMERCIAUX) : DNS vers pfSense, CRM et DEMO en 443, web vers « ! RESEAUX_PRIVES », ping de la passerelle, puis refus par défaut journalisé.

7.1 Matrice des flux autorisés (siège)

Les colonnes CRM, Compta, Bureau, Support et DEMO désignent l'accès HTTPS (443) au serveur correspondant.

Source	CRM	Compta	Bureau	Support	DEMO	SSH serveurs (22)	pfSense 443/22	Internet 80/443
COMMERCIAUX	oui	non	non	non	oui	non	non	oui
EMPLOYES	non	non	oui	non	non	non	non	oui
SUPPORT	non	non	non	oui	non	non	non	oui
COMPTABILITE	non	oui	non	non	non	non	non	oui

Source	CRM	Compta	Bureau	Support	DEMO	SSH serveurs (22)	pfSense 443/22	Internet 80/443
IT	non	non	non	non	non	SRV_RADIUS seul (journalisé)	non	oui
ADMIN	non (ufw)	non (ufw)	non (ufw)	non (ufw)	non (ufw)	tous les serveurs	oui	oui (tout journalisé)
VPN_ COMMERCIAUX	oui	non	non	non	oui	non	non	oui
VPN_COMPTA	non	oui	non	non	non	non	non	oui
VPN_ EMPLOYE	non	non	oui	non	non	non	non	oui
VPN_ SUPPORT	non	non	non	oui	non	non	non	oui
VPN_IT	non	non	non	non	non	SRV_RADIUS seul	non	oui
VPN_ADMIN	non (ufw)	non (ufw)	non (ufw)	non (ufw)	non (ufw)	tous les serveurs (journalisé)	oui (journalisé)	oui
Site 2 commerciaux (IPsec)	oui	non	non	non	oui	non	non	Internet local du site
Site 2 employés (IPsec)	non	non	oui	non	non	non	non	Internet local du site
Site 2 support (IPsec)	non	non	non	oui	non	non	non	Internet local du site
DMZ	non	non	non	non	non	non	non	mises à jour
DEMO	non	non	non	non	non	non	non	mises à jour
SRVINTERNES	–	non (ufw)	non (ufw)	non (ufw)	non	–	non	mises à jour

Le site 2 reprend le modèle du siège : une zone par profil. Chaque zone n'emprunte le tunnel que vers son serveur métier : les commerciaux (10.200.10.0/24) vers le CRM et la DEMO, les employés (10.200.20.0/24) vers SRV_BUREAU, le support (10.200.30.0/24) vers SRV_SUPPORT. Chaque flux est filtré deux fois : à la sortie de la zone sur FW_SITE2, puis à l'arrivée sur l'onglet IPsec de FW_Siege. Aucune zone du site 2 ne joint les autres zones du site.

7.2 Pare-feu locaux (défense en profondeur)

Chaque serveur filtre aussi lui-même avec ufw : si une règle pfSense devenait trop large, le serveur refuserait encore. Les cinq serveurs de la zone SRVINTERNES (CRM, Comptabilité, bureautique, support, RADIUS) ne peuvent ainsi pas se joindre ; de même, SRV_WEB et SRV_MEDECINS, tous deux dans la DMZ, se refusent mutuellement.

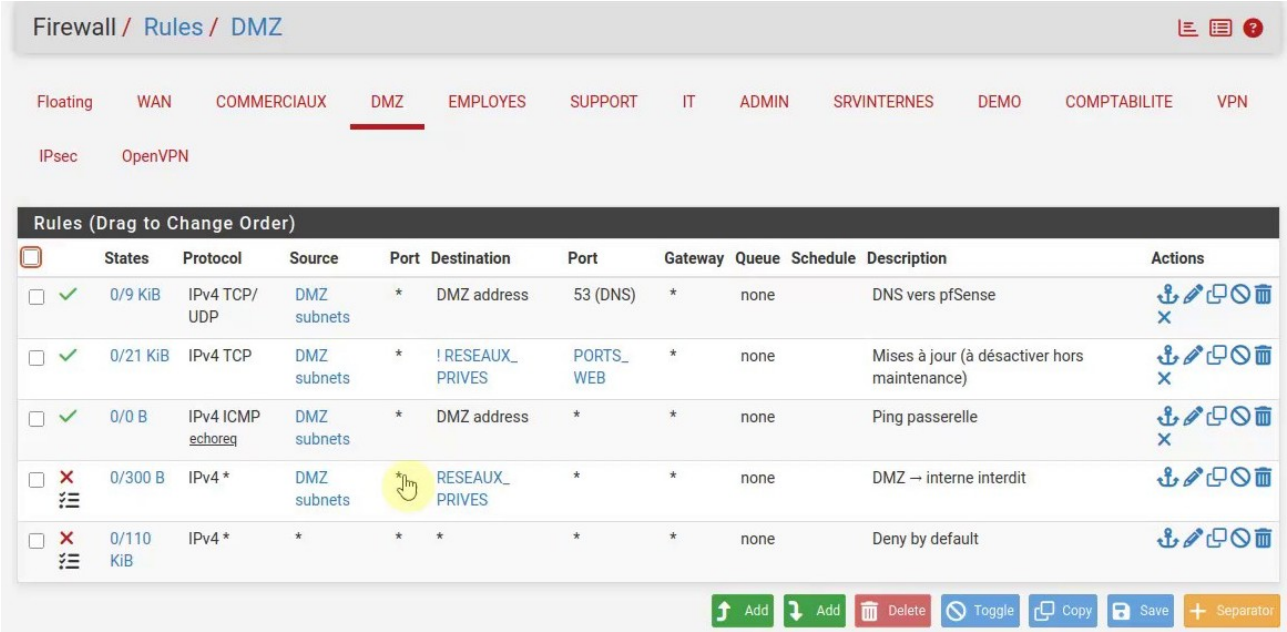


Figure 10 – Règles de la DMZ : DNS, mises à jour web, ping, blocage vers RESEAUX_PRIVES, puis refus par défaut journalisé.

Serveur	Accepte	SSH depuis
SRV_WEB	80, 443 depuis Internet (NAT)	ADMIN, VPN_ADMIN
SRV_MEDECINS	443 ouvert (portail public via le NAT 8443, protégé par certificat + mot de passe)	ADMIN, VPN_ADMIN
SRV_CRM	443 depuis COMMERCIAUX, VPN_COMMERCIAUX, site 2	ADMIN, VPN_ADMIN
SRV_COMPTA	443 depuis COMPTABILITE, VPN_COMPTA	ADMIN, VPN_ADMIN
SRV_BUREAU	443 depuis EMPLOYES, VPN_EMPLOYE, employés du site 2	ADMIN, VPN_ADMIN
SRV_SUPPORT	443 depuis SUPPORT, VPN_SUPPORT, support du site 2	ADMIN, VPN_ADMIN
SRV_DEMO	443 depuis COMMERCIAUX, VPN_COMMERCIAUX, site 2	ADMIN, VPN_ADMIN
SRV_RADIUS	UDP 1812-1813 depuis pfSense seul	ADMIN, VPN_ADMIN, IT, VPN_IT
SRV_LOG	UDP 514 depuis les deux pare-feu	ADMIN, VPN_ADMIN

« ADMIN » dans la colonne SSH couvre la zone d'administration (10.99.99.0/24) et les administrateurs connectés en VPN (10.110.99.0/24). Côté pfSense, l'onglet VPN autorise VPN_ADMIN vers RESEAUX_PRIVES sur le port 22 uniquement. Même la zone ADMIN n'atteint pas les applications métier (CRM, comptabilité, bureautique, support, DEMO en 443) : ufw la bloque, par moindre privilège.

```
admincompta@srv-compta:~$ sudo ufw status numbered                              # 443 autorisé seulement pour 10.40.40.0/24 (compta) et 10
.110.40.0/24 (VPN compta)
Status: active

     To                         Action      From
     --                         ------      ----
[ 1] 443/tcp                    ALLOW IN    10.40.40.0/24
[ 2] 443/tcp                    ALLOW IN    10.110.40.0/24
[ 3] 22/tcp                     ALLOW IN    10.99.99.0/24

admincompta@srv-compta:~$ sudo dmesg | grep "UFW BLOCK" | grep 10.99.99.10 | tail -2     # 10.99.99.10 = PC-ADMIN, refusé par le serveur lui-même
[ 2768.429523] [UFW BLOCK] IN=ens33 OUT= MAC=00:0c:29:82:9f:c4:00:0c:29:63:5e:4b:08:00 SRC=10.99.99.10 DST=10.70.10.11 LEN=60 TOS=0x00 PREC=0x00 TT
L=63 ID=4170 DF PROTO=TCP SPT=51732 DPT=80 WINDOW=64240 RES=0x00 SYN URGP=0
[ 2791.150274] [UFW BLOCK] IN=ens33 OUT= MAC=00:0c:29:82:9f:c4:00:0c:29:63:5e:4b:08:00 SRC=10.99.99.10 DST=10.70.10.11 LEN=60 TOS=0x00 PREC=0x00 TT
L=63 ID=29427 DF PROTO=TCP SPT=60170 DPT=443 WINDOW=64240 RES=0x00 SYN URGP=0
admincompta@srv-compta:~$
```

Figure 11 – Défense en profondeur : pfSense laisse passer PC-ADMINISTRATEURS, mais SRV_COMPTA le refuse sur le port 443 (ligne « UFW BLOCK »).

7.3 Ressources des employés et du support

Deux serveurs donnent aux employés et au support leurs outils de travail : SRV_BUREAU (10.70.10.12), l'espace bureautique des employés (documents partagés, notes de service), et SRV_SUPPORT (10.70.10.13), l'outil de tickets du support. FW_Siege n'ayant plus de carte réseau libre, ils rejoignent la zone SRVINTERNES ; ufw les isole des autres serveurs de la zone.

Ces deux serveurs ont été ajoutés après une première campagne de tests, qui montrait que les employés et le support n'avaient accès qu'au web. Les règles et les tests de ce rapport sont ceux de la version finale ; quelques captures d'annexe (état du tunnel IPsec, tour SSH des administrateurs) datent d'avant cet ajout.

- **Siège.** Une règle EMPLOYES → SRV_BUREAU (443) et une règle SUPPORT → SRV_SUPPORT (443), placées avant le refus par défaut.
- **VPN.** VPN_EMPLOYE → SRV_BUREAU et VPN_SUPPORT → SRV_SUPPORT dans l'onglet VPN : les droits suivent toujours l'identité.
- **Site 2.** Une phase 2 IPsec par serveur, limitée à l'adresse du serveur (/32) et à la seule zone qui en a besoin, et une règle à chaque extrémité : zone EMPLOYEE ou SUPPORT de FW_SITE2, puis onglet IPsec de FW_Siege.
- **Serveurs.** ufw n'ouvre le 443 qu'aux trois plages du profil (siège, VPN, site 2) et le SSH qu'aux administrateurs ; chaque serveur a son propre certificat et son propre compte d'administration (adminbureau, adminsupport).

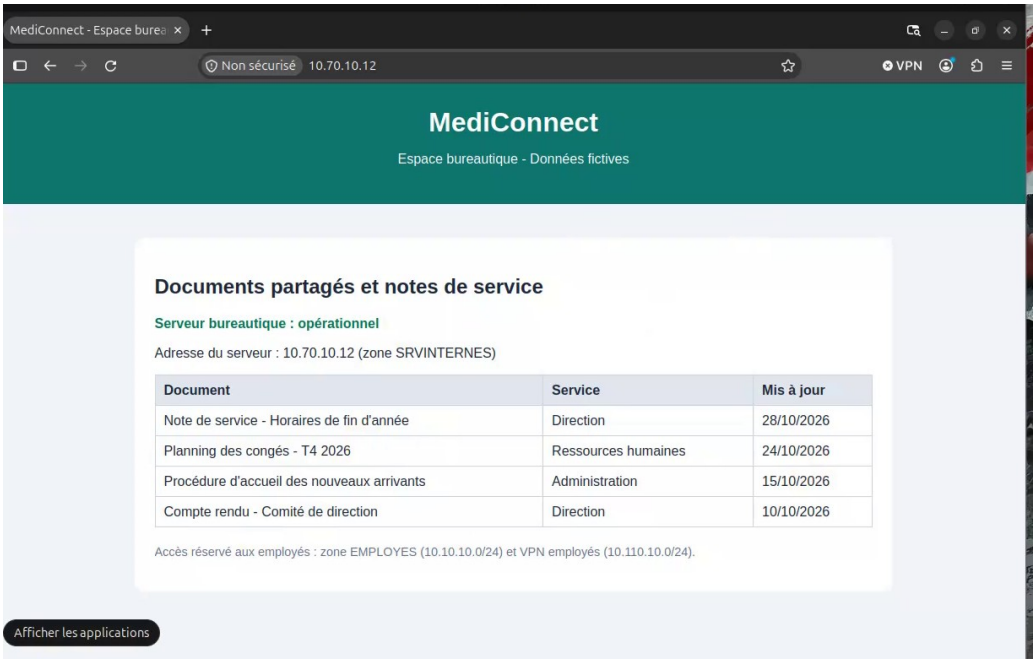


Figure 12 – Depuis PC_Employee, l'espace bureautique servi par SRV_BUREAU (10.70.10.12), données fictives.

Captures complémentaires en annexe : figures A19 à A25.

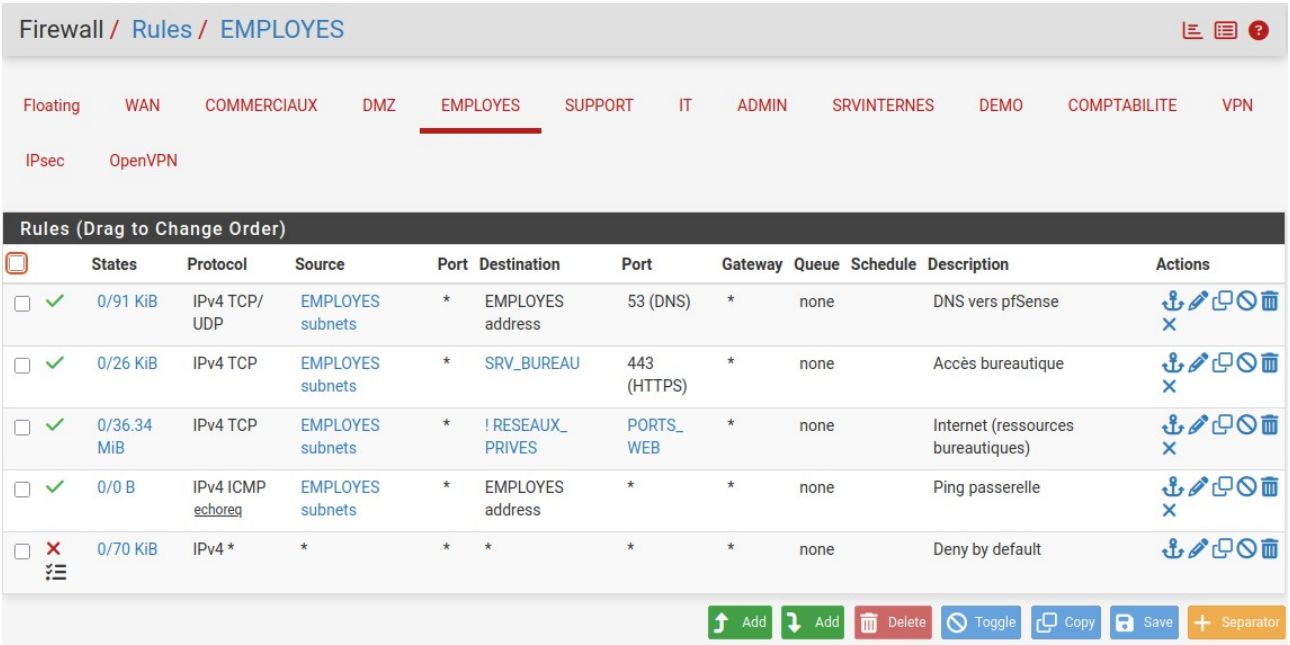


Figure 13 – Zone EMPLOYES : DNS, SRV_BUREAU en 443, web, ping de la passerelle, puis refus par défaut journalisé.

```
Status: active

     To                         Action      From
     --                         ------      ----
[ 1] 443/tcp                    ALLOW IN    10.10.10.0/24              # Employes
[ 2] 443/tcp                    ALLOW IN    10.110.10.0/24             # VPN employes
[ 3] 22/tcp                     ALLOW IN    10.99.99.0/24              # Admin SSH
[ 4] 22/tcp                     ALLOW IN    10.110.99.0/24             # Admin VPN SSH
[ 5] 443/tcp                    ALLOW IN    10.200.20.0/24             # Employes site 2

adminbureau@srv-bureau:~$
```

Figure 14 – ufw sur SRV_BUREAU : 443 pour les seuls employés (siège, VPN, site 2), SSH pour les seuls administrateurs ; tout le reste, dont les autres serveurs de SRVINTERNES, est refusé.

8. Règles basées sur l'identité

Les droits d'un utilisateur VPN dépendent de qui il est, pas du poste qu'il utilise : RADIUS lui attribue une IP dans la plage de son groupe, et pfSense filtre sur cette plage.

1. L'utilisateur présente son certificat et saisit identifiant et mot de passe.
2. FreeRADIUS valide le mot de passe et renvoie Framed-IP-Address (par exemple 10.110.40.10 pour compta01).
3. OpenVPN attribue cette IP au tunnel ; le réseau tunnel est un /16 pour contenir toutes les plages de groupe.
4. Les règles de l'interface VPN filtrent par alias de groupe (VPN_COMPTA, VPN_COMMERCIAUX…).
5. ufw sur chaque serveur vérifie à nouveau la plage source.

Groupe (alias)	Plage	Accès autorisés
VPN_COMMERCIAUX	10.110.30.0/24	CRM 443, DEMO 443
VPN_COMPTA	10.110.40.0/24	serveur comptable 443
VPN_IT	10.110.50.0/24	SSH vers le RADIUS
VPN_ADMIN	10.110.99.0/24	SSH (22) vers tous les serveurs, zone ADMIN, gestion de pfSense (22, 443), journalisé
VPN_EMPLOYE	10.110.10.0/24	SRV_BUREAU 443
VPN_SUPPORT	10.110.20.0/24	SRV_SUPPORT 443
Tous	10.110.0.0/16	DNS vers pfSense, Internet web (full tunnel)

Le même poste et le même VPN donnent des accès différents selon le compte : connecté en compta01, PC-TELETRAVAIL atteint le serveur comptable mais pas le CRM ; en commercial01, l'inverse ; en employe01, seulement l'espace bureautique ; en support01, seulement l'outil de support.

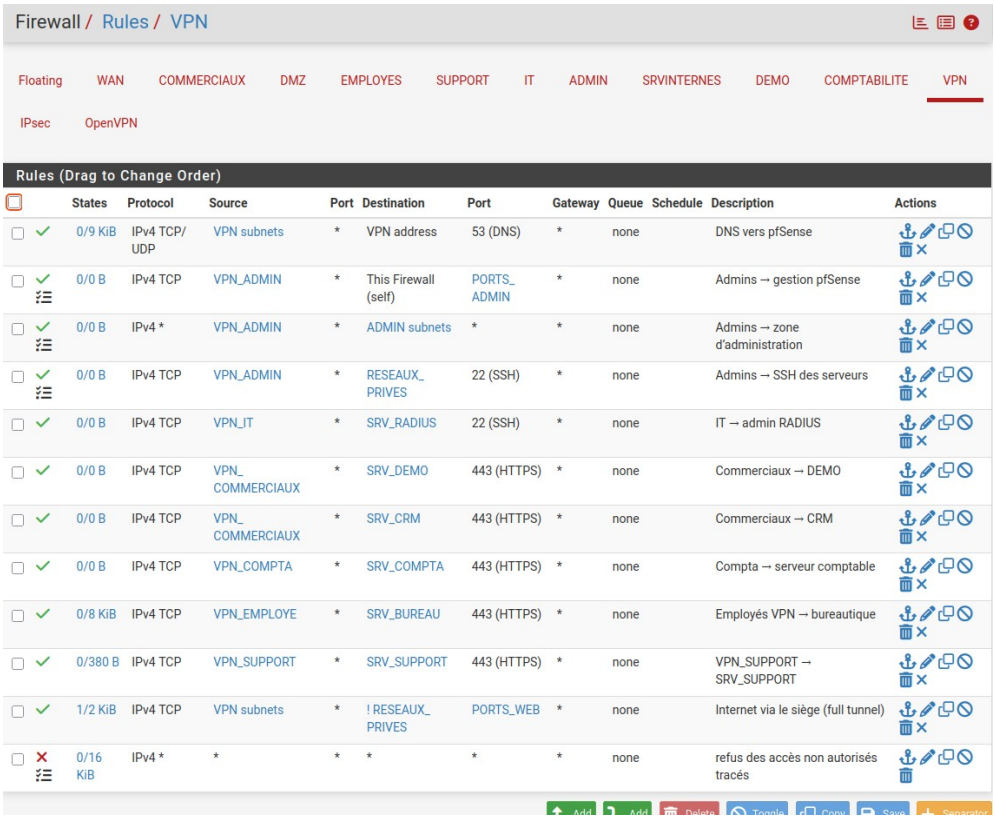


Figure 15 – Onglet VPN : une règle par groupe (dont VPN_EMPLOYE → SRV_BUREAU et VPN_SUPPORT → SRV_SUPPORT), puis blocage journalisé.

L'onglet OpenVPN reste volontairement vide. pfSense évalue cet onglet de groupe avant celui de l'interface assignée (VPN) : une règle large à cet endroit contournerait tout le filtrage par identité.



Figure 16 – Même poste en employe01 (10.110.10.10) : seul SRV_BUREAU est autorisé, avec le web. En VPN, la ligne « pfSense (admin web) » vise la passerelle locale du poste (192.168.228.2) : en full tunnel, ce paquet passe par pfSense et est refusé, comme toute adresse privée.



Figure 17 – Même poste en commercial01 (10.110.30.10) : CRM et DEMO autorisés, comptabilité refusée.

Captures complémentaires en annexe : figures A26 à A31.

9. Contrôle applicatif

Suricata analyse le contenu des paquets (couche 7) là où les règles pfSense ne voient qu'adresses et ports : il bloque automatiquement les attaquants sur le WAN et alerte sur la DMZ.

	WAN	DMZ
Mode	IPS (Legacy, Block Offenders)	IDS (alerte seule)
IP bloquée	la source (l'attaquant)	–
Règles ET Open	scan, exploit, web_server, sql, attack_response, dos	web_server, sql, exploit, attack_ response
Liste de confiance	PASS_LAB (passerelle, DNS, VPN ; sans les réseaux locaux)	–
Alertes	journal système, donc SRV_LOG	journal système, donc SRV_LOG

Pourquoi IDS seulement sur la DMZ : le trafic venu d'Internet est déjà inspecté et bloqué sur le WAN ; en blocage sur la DMZ, une règle de type attack_response, déclenchée par la réponse d'un serveur, bloquerait le serveur lui-même, puisque c'est lui la source de l'alerte : le portail patients deviendrait injoignable.

Prérequis appliqués : désactivation du déchargement matériel (checksum, TSO, LRO), sans laquelle Suricata voit des paquets incomplets, et 4 Go de RAM pour FW_Siege.

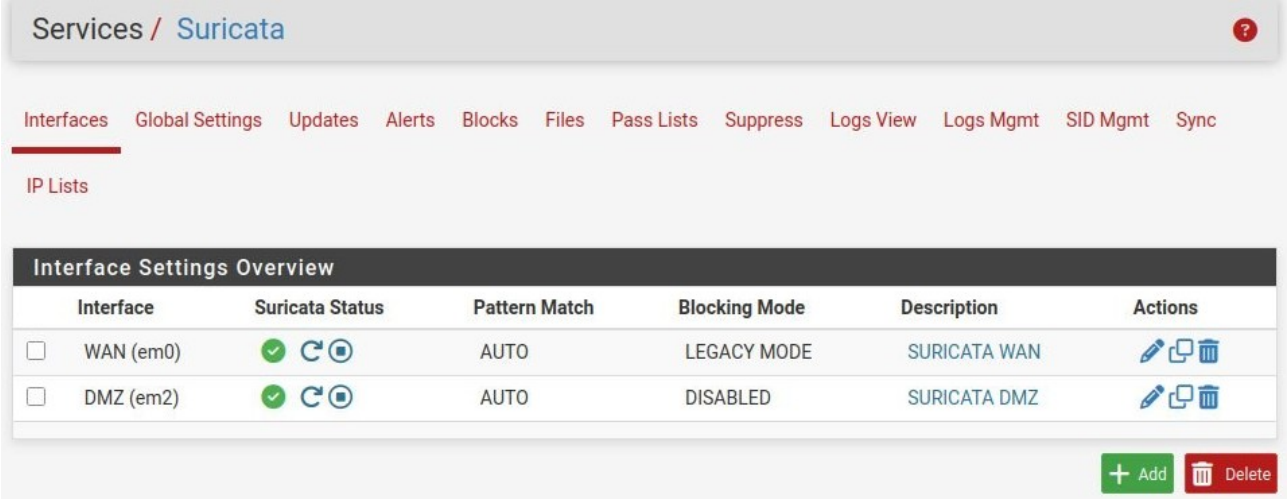


Figure 18 – Suricata : IPS en mode Legacy sur le WAN (blocage), IDS sur la DMZ (détection seule).

Test. Depuis Kali sur le WAN, nmap -sS -A vers 192.168.228.128 déclenche des alertes « ET SCAN » ; l'IP de Kali passe dans la liste Blocks et un second scan ne voit plus que des ports « filtered ».

Le contrôle applicatif passe aussi par le filtrage : seuls le web (80/443) et le DNS vers pfSense sortent des zones utilisateurs ; le ping vers Internet, SSH, FTP ou le DNS direct sont refusés et journalisés.

Captures complémentaires en annexe : figures A32 à A36.

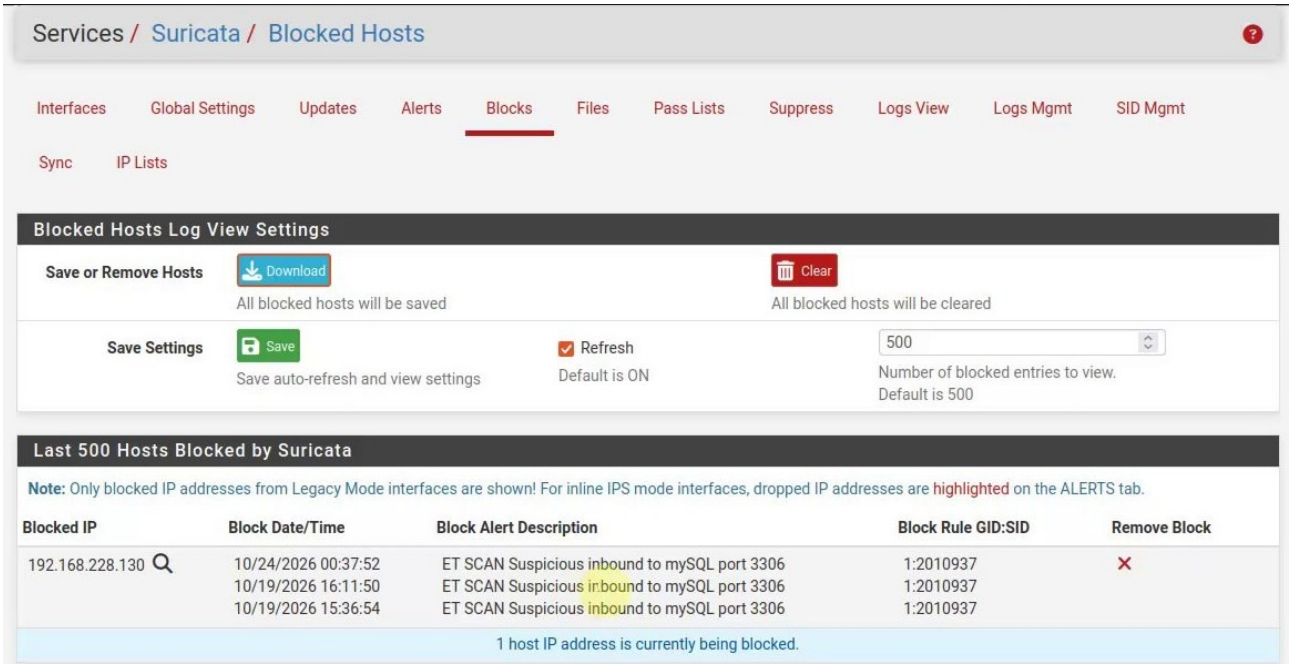


Figure 19 – Suricata bloque l'adresse de Kali (192.168.228.130) après une alerte « ET SCAN ».

10. Protection de la DMZ

La DMZ expose deux portails distincts sur la seule adresse publique, en HTTPS, et ne peut rien initier vers le réseau interne : un serveur web compromis ne sert pas de tremplin.

Publication (NAT WAN)	Serveur interne	Accès
443	SRV_WEB 10.60.10.10:443	portail patients, ouvert à tous
80	SRV_WEB 10.60.10.10:80	redirection 301 vers HTTPS
8443	SRV_MEDECINS 10.60.10.20:443	espace professionnel : certificat + mot de passe

- **HTTPS exclusif.** Le port 80 de SRV_WEB reste ouvert, mais uniquement pour renvoyer une redirection 301 vers HTTPS : aucune page n'est servie en clair ; SRV_MEDECINS (nginx) n'accepte que TLS 1.2 et 1.3.
- **Patients et médecins séparés.** Deux serveurs distincts : si le portail patients, le plus exposé, est compromis, l'espace médecins reste intact. Les deux serveurs partagent la DMZ, où pfSense ne voit pas leurs échanges : chacun refuse donc l'autre dans ufw, par une règle DENY placée en tête (figures A42 et 21).
- **Aucun accès direct aux serveurs internes.** Les règles DMZ bloquent tout trafic vers RESEAUX_PRIVES (journalisé) ; seuls le DNS vers pfSense et les mises à jour web sortent.
- **Inspection.** Suricata en IPS sur le WAN avant le NAT, en IDS sur la DMZ après.
- **Serveurs durcis.** ufw n'ouvre que 80/443 et le SSH depuis ADMIN et VPN_ADMIN.

En production, les deux portails auraient chacun un nom de domaine (patients.mediconnect.fr, pro.mediconnect.fr) derrière un reverse proxy et des certificats publics, plutôt qu'un port 8443 et des certificats auto-signés.

Captures complémentaires en annexe : figures A37 à A42.

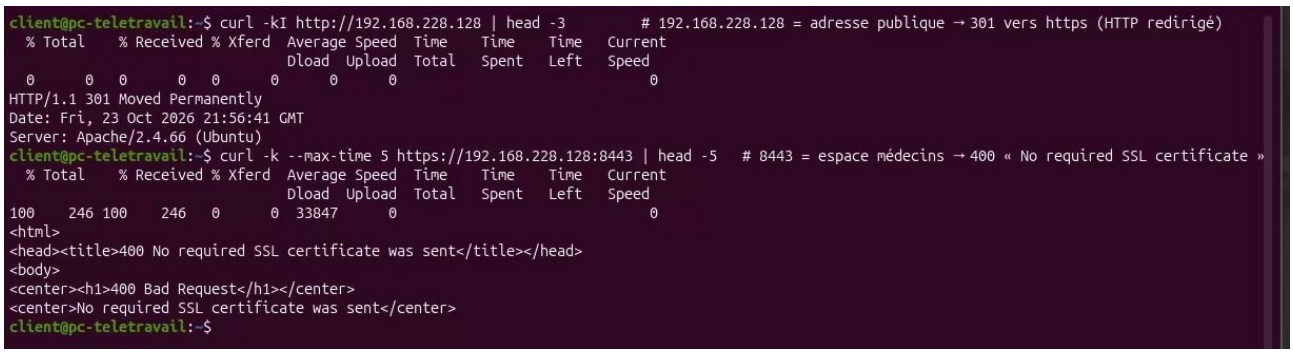


Figure 20 – HTTP redirigé vers HTTPS (301) ; espace médecins sans certificat : erreur 400.

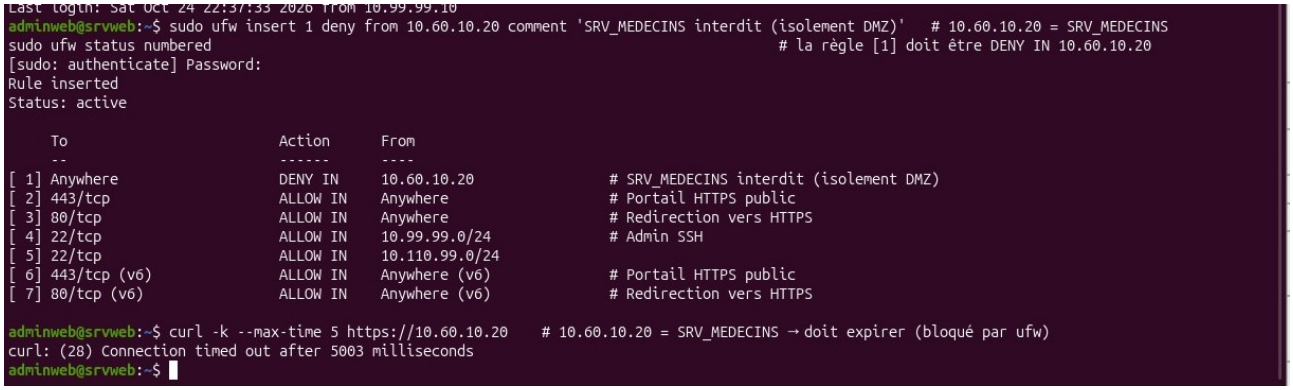


Figure 21 – Sur SRV_WEB, la règle [1] refuse SRV_MEDECINS (10.60.10.20), placée avant les règles 80/443 ouvertes à tous ; depuis SRV_WEB, curl vers SRV_MEDECINS expire : un portail compromis ne peut pas attaquer l'autre.

11. Sécurisation de l'administration

Les flux d'administration sont séparés des flux utilisateurs : seuls la zone ADMIN et le groupe VPN_ADMIN peuvent joindre les interfaces de gestion des pare-feu et le SSH des serveurs.

- **Zone dédiée.** ADMIN (10.99.99.0/24) est la seule zone à règle large ; seul VPN_ADMIN, avec MFA, peut y entrer, et chacune de ses connexions est journalisée.
- **Anti-lockout désactivé sur les deux pare-feu.** Cette règle automatique ouvrait l'interface web au LAN (l'actuelle zone COMMERCIAUX au siège, la zone COMMERCIAL au site 2) ; l'accès dépend désormais des seules règles. Vérifié : PC-ADMINISTRATEURS ouvre pfSense, PC_COMMERCIAL (10.30.30.100) ne l'ouvre plus.
- **Site 2 géré depuis le siège.** FW_SITE2 n'accepte son interface web (443) et son SSH (22) que depuis 10.99.99.0/24 via le tunnel.
- **À distance : MFA.** Un administrateur hors site passe par le VPN avec certificat + mot de passe ; le groupe VPN_ADMIN a les mêmes droits d'administration que la zone ADMIN : SSH (22) vers tous les serveurs et interfaces des pare-feu (22, 443), le tout journalisé.
- **Interface web durcie.** HTTPS seul, redirection HTTP supprimée, HSTS actif, autocomplétion désactivée, protection anti force brute (Login Protection), menu console protégé par mot de passe.
- **Serveurs.** SSH autorisé par ufw depuis ADMIN et VPN_ADMIN uniquement (plus IT et VPN_IT pour le seul RADIUS) ; un compte nommé par serveur (adminweb, admincrm…) et des clés SSH régénérées sur chaque clone.

Captures complémentaires en annexe : figures A43 à A47.

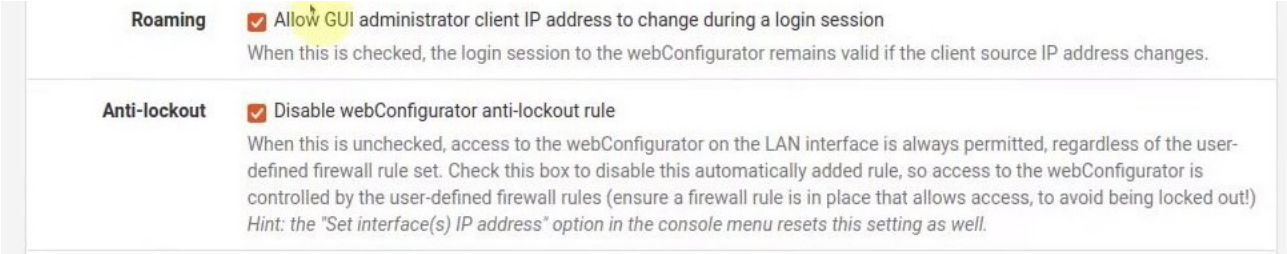


Figure 22 – Admin Access : interface en HTTPS, règle anti-lockout désactivée.



Figure 23 – Depuis PC-ADMINISTRATEURS, le script de test admin (annexe B) : SSH autorisé vers les neuf serveurs et pfSense ; en web, CRM, comptabilité, bureautique, support et DEMO restent fermés par ufw (moindre privilège). Seuls les portails publics de la DMZ, l'interface de pfSense et Internet répondent.

12. Stratégie de journalisation

Les journaux des deux pare-feu sont centralisés en temps réel sur SRV_LOG (10.99.99.30, zone ADMIN) : ils survivent à la rotation locale de pfSense et à la compromission d'un pare-feu, et se corrèlent au même endroit.

Événement (guide)	Source	Comment il est capturé
Refus de règles	pfSense (filterlog)	Block any journalisé sur chaque interface, blocage par défaut journalisé
Accès d'administration	pfSense	règles ADMIN et VPN_ADMIN journalisées, connexions à l'interface web, changements de configuration
Connexions VPN	pfSense (openvpn)	verbosité 3 : connexions, IP attribuée, échecs d'authentification
Authentifications	pfSense, nginx (SRV_MEDECINS)	AUTH_FAILED VPN ; certificat + identifiant médecin
Intrusions	Suricata	alertes envoyées au journal système, IP bloquées
Tunnel site à site	pfSense (IPsec)	journal IPsec des deux pare-feu
Refus sur les serveurs	ufw	/var/log/ufw.log (local)

Collecte. pfSense envoie tout son journal (Remote Syslog Contents : Everything) en UDP 514 depuis son adresse ADMIN ; FW_SITE2 l'envoie depuis son LAN, à travers le tunnel IPsec. rsyslog range les messages par équipement et par programme : /var/log/remote/10.99.99.1/ et /var/log/remote/10.200.10.1/.

Accès. ufw sur SRV_LOG n'accepte l'UDP 514 que des deux pare-feu et le SSH que de la zone ADMIN : seuls les administrateurs lisent les journaux, qui contiennent des comptes et des adresses.

Utilité constatée. Les journaux ont révélé des postes utilisant encore 8.8.8.8 comme DNS, un test SSH visé vers le mauvais serveur, et, grâce à ufw, un conflit d'adresse entre l'hôte VMware et pfSense.

Limite : l'UDP n'est ni chiffré ni acquitté ; en production on utiliserait syslog sur TLS, une rétention définie (par exemple 12 mois) et un outil de recherche (Graylog, Wazuh).

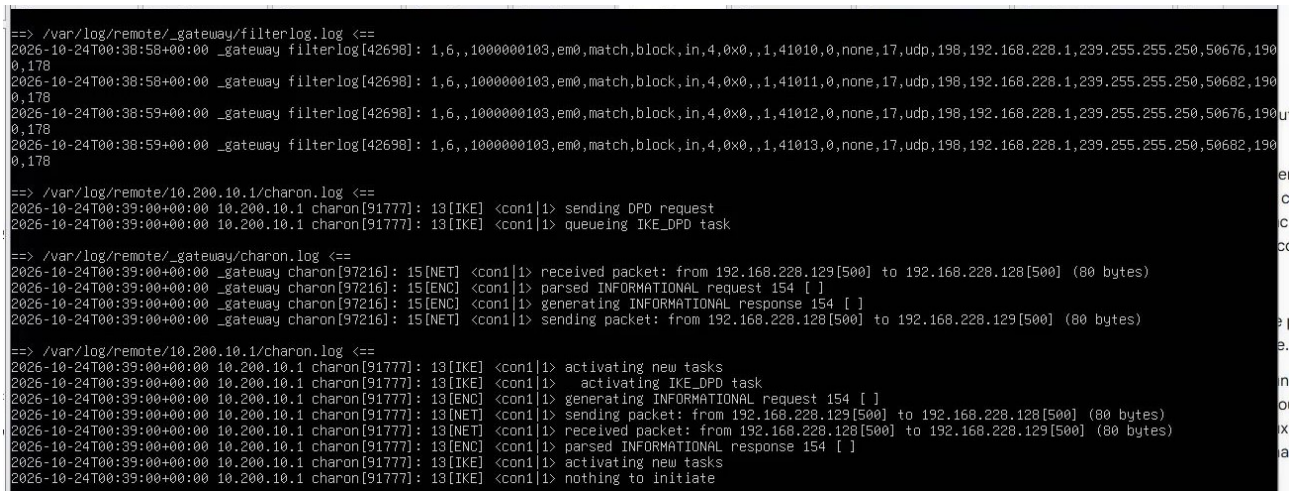


Figure 24 – SRV_LOG reçoit en direct les journaux des deux pare-feu (filterlog, IPsec).

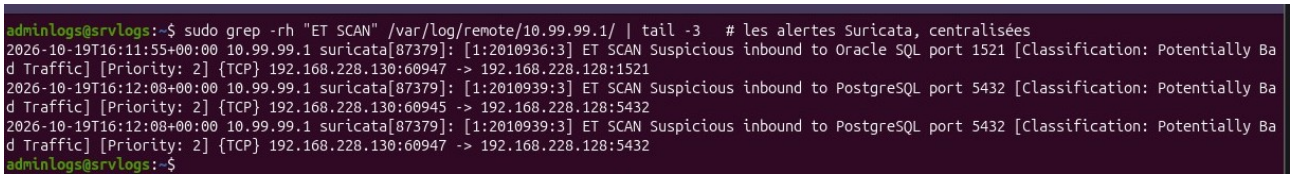


Figure 25 – Les alertes Suricata (« ET SCAN » déclenchées par Kali, 192.168.228.130) sont centralisées sur SRV_LOG, dans le dossier de FW_Siege (10.99.99.1).

Captures complémentaires en annexe : figure A48.

13. Tests réalisés

Chaque profil a été testé avec au moins un accès autorisé et un accès refusé ; tous les résultats sont conformes, et chaque refus apparaît dans le journal du pare-feu.

Profil (poste)	Test	Attendu	Obtenu
Patient (PC-TELETRAVAIL, Internet)	https://192.168.228.128	portail patients	conforme
Patient	http://192.168.228.128	redirection HTTPS	conforme
Médecin	https://…:8443 sans certificat	refus 400	conforme
Médecin	certificat + mot de passe	agenda affiché	conforme
Commercial (PC_COMMERCIAL)	CRM, DEMO	autorisé	conforme
Commercial	serveur comptable	refusé	conforme
Commercial	interface pfSense 10.30.30.1	refusé	conforme
Comptable (PC-COMPTA)	serveur comptable / CRM	autorisé / refusé	conforme
Employé (PC_Employee)	SRV_BUREAU / serveur comptable, SRV_SUPPORT, pfSense	autorisé / refusé	conforme
Support (PC-SUPPORT)	SRV_SUPPORT / SRV_BUREAU, CRM, comptabilité	autorisé / refusé	conforme

Profil (poste)	Test	Attendu	Obtenu
Commercial, comptable, informaticien	SRV_BUREAU, SRV_SUPPORT	refusé	conforme
Employé	ping google.com / navigation web	refusé / autorisé	conforme
Informaticien (PC-IT)	SSH RADIUS / SSH CRM	autorisé / refusé	conforme
Administrateur (PC-ADMINISTRATEURS)	SSH vers les 9 serveurs, pfSense, FW_SITE2 / HTTPS vers CRM, comptabilité, bureautique, support, DEMO	autorisé / refusé (ufw)	conforme
VPN compta01	IP attribuée	10.110.40.10	conforme
VPN compta01	serveur comptable / CRM / pfSense	autorisé / refusé / refusé	conforme
VPN commercial01	CRM, DEMO / comptabilité	autorisé / refusé	conforme
VPN avec certificat d'un autre compte	connexion	AUTH_FAILED	conforme
VPN employe01, support01	son serveur (BUREAU ou SUPPORT), web / l'autre serveur, CRM, comptabilité, DEMO	autorisé / refusé	conforme
VPN it01	SSH RADIUS / SSH CRM, comptabilité	autorisé / refusé	conforme
VPN admin01	SSH SRV_CRM, SRV_LOG, pfSense	autorisé	conforme
VPN it01, mauvais mot de passe	connexion	AUTH_FAILED, « Login incorrect » dans RADIUS	conforme
Site 2, commercial (10.200.10.10)	CRM, DEMO / comptabilité	autorisé / refusé	conforme
Site 2	interface FW_SITE2	refusé	conforme
Site 2, employé (10.200.20.10)	SRV_BUREAU (IPsec), web / CRM, DEMO, SRV_SUPPORT, FW_SITE2, PC commercial	autorisé / refusé	conforme
Site 2, support (10.200.30.10)	SRV_SUPPORT (IPsec), web / CRM, SRV_BUREAU, PC employé	autorisé / refusé	conforme
DMZ (SRV_WEB)	CRM	refusé	conforme
DEMO (SRV_DEMO)	CRM	refusé	conforme
Attaquant (Kali, Internet)	nmap -sS -A	alerte puis blocage	conforme
Journalisation	SRV_LOG	logs des deux pare-feu reçus	conforme
RADIUS	Diagnostics → Authentication	succès	conforme

Chaque poste a exécuté le même script de test (test_acces.sh), qui tente une connexion vers chaque serveur sur son port métier : une expiration prouve qu'un pare-feu jette le paquet. La figure 26 montre le résultat pour les commerciaux ; les autres profils sont en annexe (figures A52 à A58).

Le script, créé à l'identique sur chaque poste de test, est donné en annexe B, avec sa variante pour le poste d'administration, qui teste aussi le SSH.

Une expiration (✘) signifie qu'un pare-feu a jeté le paquet ; un service arrêté aurait répondu par un refus immédiat. Chaque refus est aussi visible dans le journal de pfSense.



Figure 26 – COMMERCIAUX : CRM et DEMO autorisés, le reste bloqué (dont SRV_BUREAU et SRV_SUPPORT).

14. Limites et difficultés

La maquette respecte les principes demandés, mais plusieurs choix sont des compromis de laboratoire qu'une mise en production corrigerait.

14.1 Limites de la solution

Limite	Conséquence	En production
Pas de VLAN 802.1Q : un VMnet et une carte par zone	même isolation, mais pas de trunk	VLAN tagués sur un commutateur
VMware limite une VM à 10 cartes réseau	CRM, Comptabilité, bureautique, support et RADIUS partagent la zone SRVINTERNES	une zone par application ; ufw compense ici
IPsec par clé pré-partagée	secret à protéger et à renouveler	certificats IKEv2
Certificats auto-signés, port 8443 pour les médecins	avertissement navigateur	autorité publique, un nom de domaine par portail
Mots de passe RADIUS en clair dans le fichier users	lisibles par un admin du serveur	base chiffrée ou annuaire (LDAP/AD)
Applications simulées par des pages statiques (CRM, comptabilité, bureautique, support)	pas de vraies données ni d'authentification applicative	applications réelles derrière les mêmes règles
Portail patients sans base de données interne	pas de flux DMZ → base à filtrer	flux DMZ → base sur un port précis
Syslog en UDP non chiffré, sans rétention ni outil d'analyse	pertes possibles	syslog TLS, SIEM (Graylog, Wazuh)
Suricata seulement au siège	site 2 non inspecté	IDS sur FW_SITE2
Pas de redondance des pare-feu	point unique de défaillance	cluster CARP
Au siège, l'identité est déduite du poste et de sa zone	un utilisateur assis sur le poste d'un autre profil en obtient les droits ; seul le VPN vérifie la personne	authentification réseau (802.1X ou portail captif avec RADIUS)
Contrôle applicatif fondé sur Suricata, la limitation des ports et le DNS imposé	le contenu du trafic web sortant n'est pas filtré	filtrage DNS ou proxy (pfBlockerNG, Squid)

14.2 Difficultés rencontrées

- **Conflit d'adresse VMware.** Les réseaux host-only connectaient le PC hôte avec l'adresse .1, identique à pfSense ; les réponses des serveurs partaient parfois vers l'hôte. Diagnostic par tcpdump et par l'adresse MAC 00:50:56:C0:00:04 dans ufw ; corrigé en retirant l'hôte et le DHCP VMware de tous les réseaux internes. L'hôte contournait aussi le pare-feu.
- **Règles « any → any ».** Placées en tête, elles rendaient la segmentation fictive (premier élément qui correspond gagne) ; remplacées par le modèle DNS, métier, Internet, blocage.
- **Chevauchement d'adressage.** Le réseau du site 2 et la zone Comptabilité utilisaient 10.40.40.0/24 ; le site 2 a été renuméroté en 10.200.x.0/24.

15. Conclusion

La maquette répond à chaque exigence du sujet, et chacune est démontrée par un test et une capture.

- **Segmentation.** Une zone par profil sur les deux sites, chacune limitée à son serveur métier (CRM, comptabilité, bureautique ou support), un refus par défaut journalisé sur chaque zone, et un pare-feu local (ufw) sur chaque serveur.
- **Accès distants.** Un tunnel IPsec chiffré entre les sites, un VPN à deux facteurs (certificat + mot de

passe RADIUS) pour les nomades, avec des droits qui suivent l'identité de l'utilisateur.

- **Services exposés.** Un portail patients servi uniquement en HTTPS (le port 80 ne renvoie qu'une redirection) et un espace médecins protégé par certificat et mot de passe, dans une DMZ qui ne peut rien initier vers l'interne ; une démonstration séparée de la production.
- **Surveillance.** Suricata détecte et bloque les attaques sur le WAN ; les journaux des deux pare-feu sont centralisés sur un serveur de la zone d'administration.
- **Administration.** Réservée à la zone ADMIN et aux administrateurs en VPN ; aucun poste utilisateur ne peut administrer un pare-feu.

Pour un passage en production, il faudrait ajouter de vrais VLAN, un annuaire d'entreprise, des certificats publics, la redondance des pare-feu et les ressources métier des employés et du support.

A. Captures complémentaires

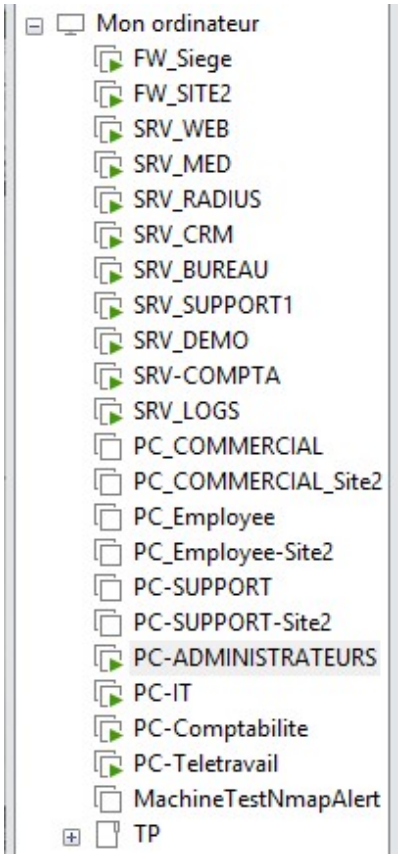


Figure A1 – *Architecture retenue.* Les machines virtuelles de la maquette sous VMware Workstation.

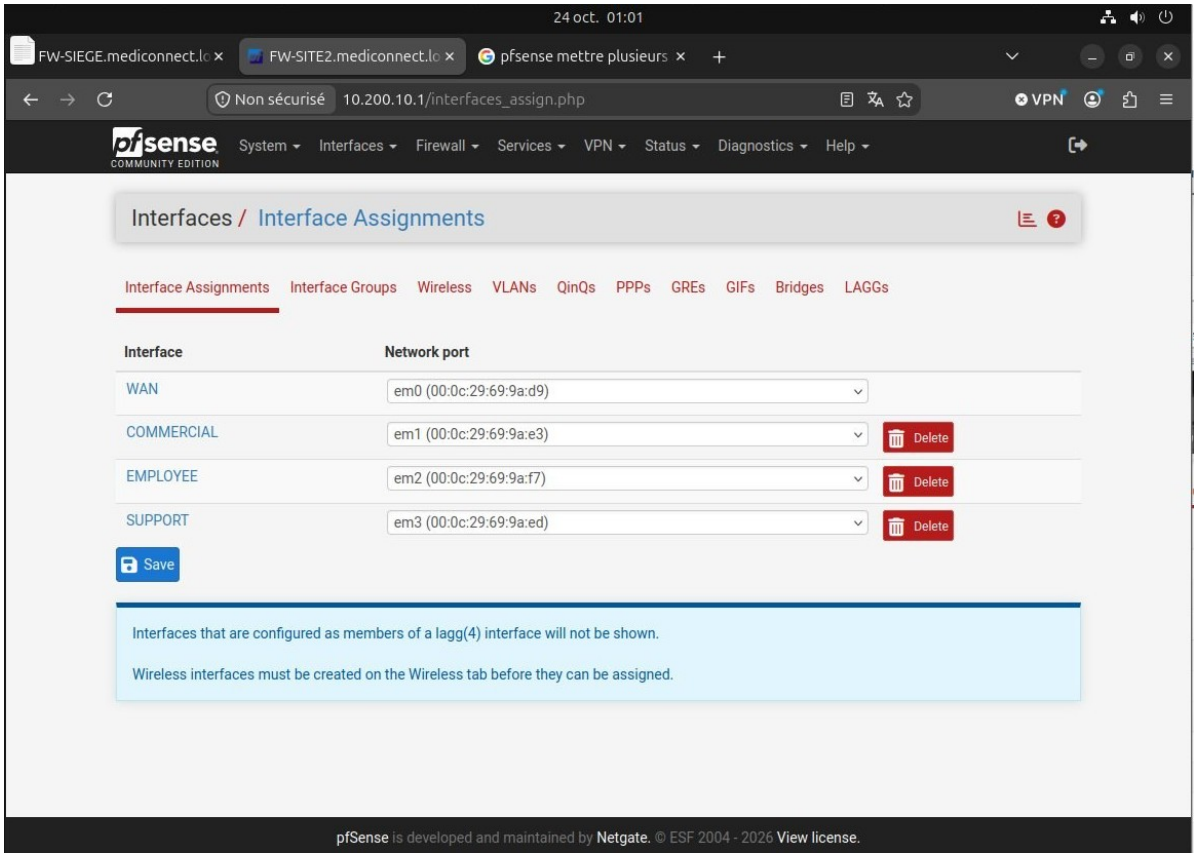


Figure A2 – *Architecture retenue.* FW_SITE2 : une zone par profil (commerciaux, employés, support).

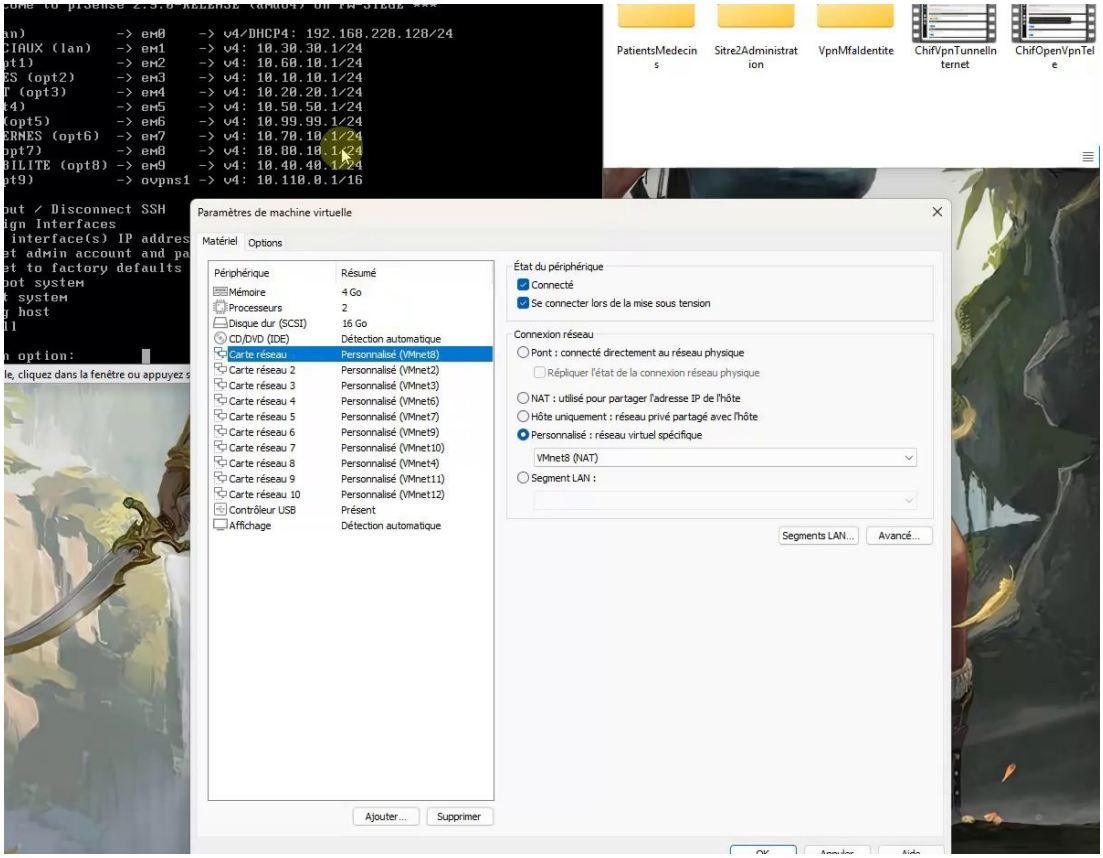


Figure A3 – *Architecture retenue.* Les 10 cartes réseau de FW_Siege, une par VMnet : le maximum de VMware, d'où le regroupement CRM, comptabilité et RADIUS dans SRVINTERNES.

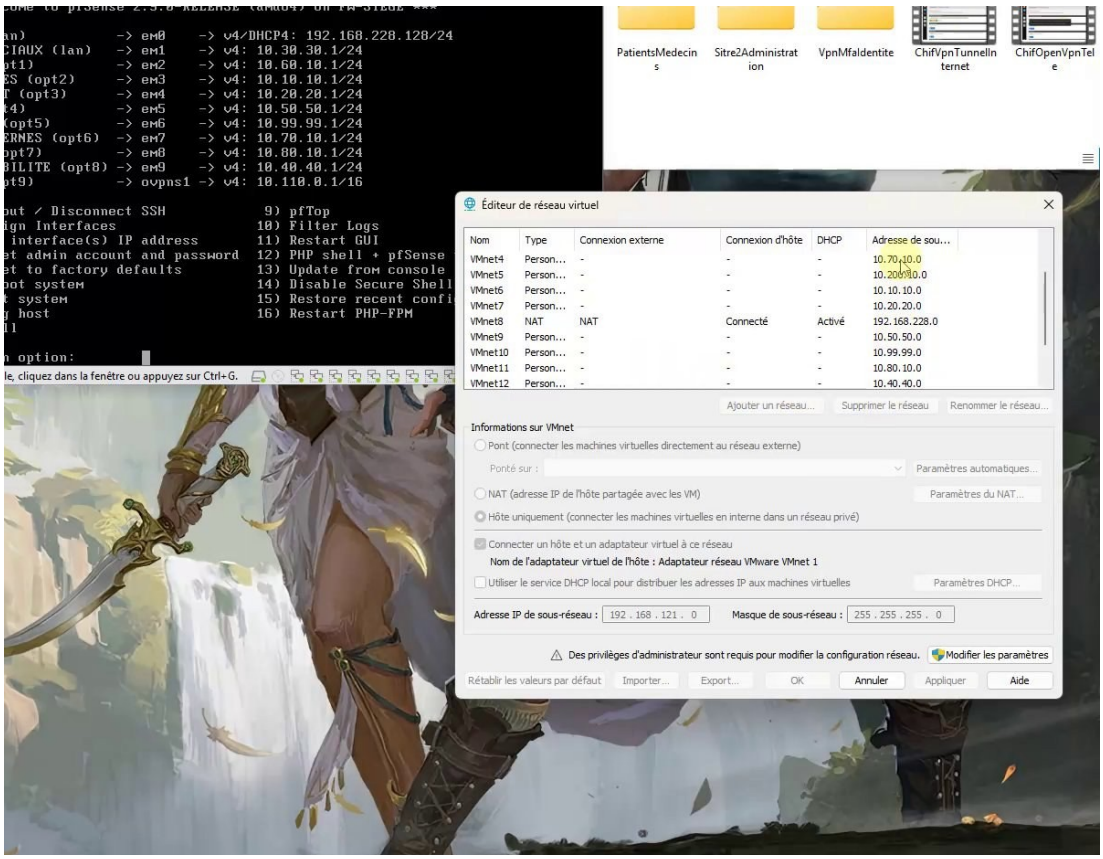


Figure A4 – *Architecture retenue.* Les VMnets en hôte uniquement, sans DHCP ni adaptateur hôte : la machine Windows n'a aucune adresse dans les zones et ne peut pas contourner le pare-feu.

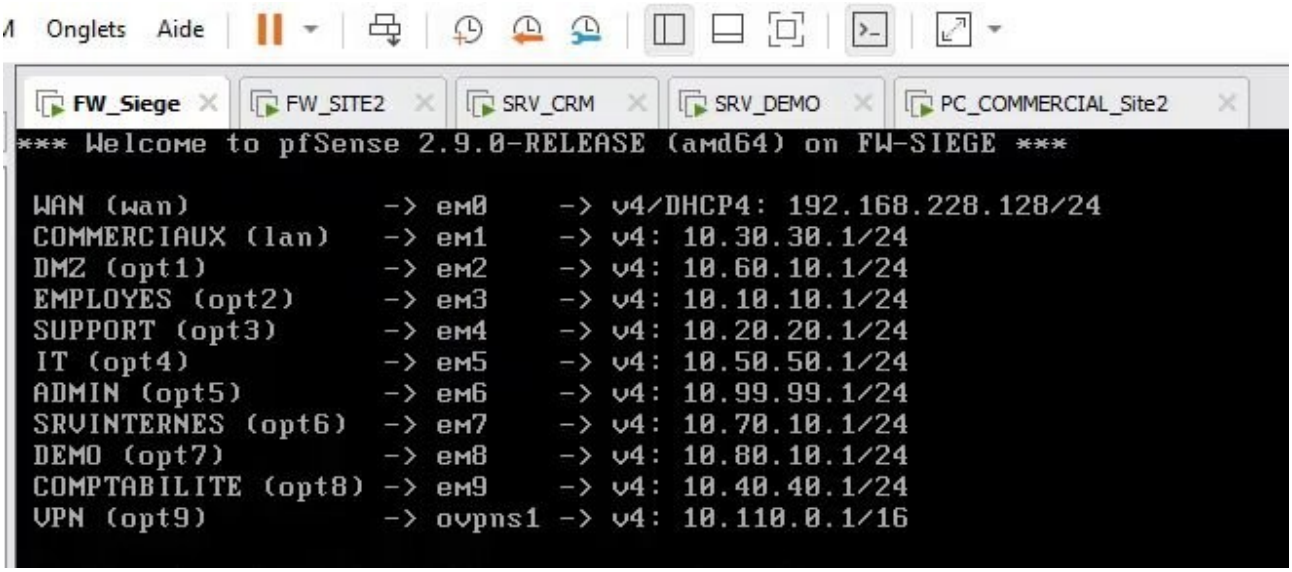


Figure A5 – *Plan d'adressage.* Console de FW_Siege : chaque interface, sa zone et sa passerelle en .1, conformes au plan d'adressage.

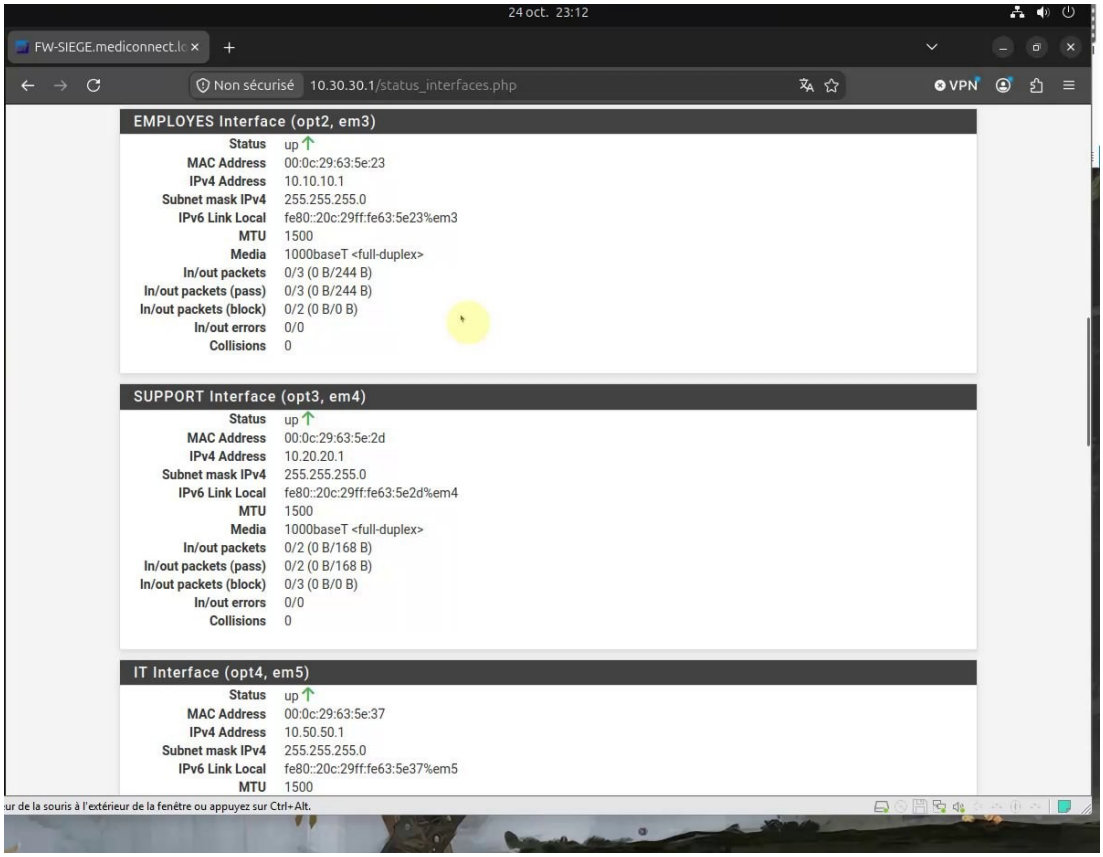


Figure A6 – *Plan d'adressage.* Status → Interfaces : toutes les zones sont actives (status up) avec leur adresse.

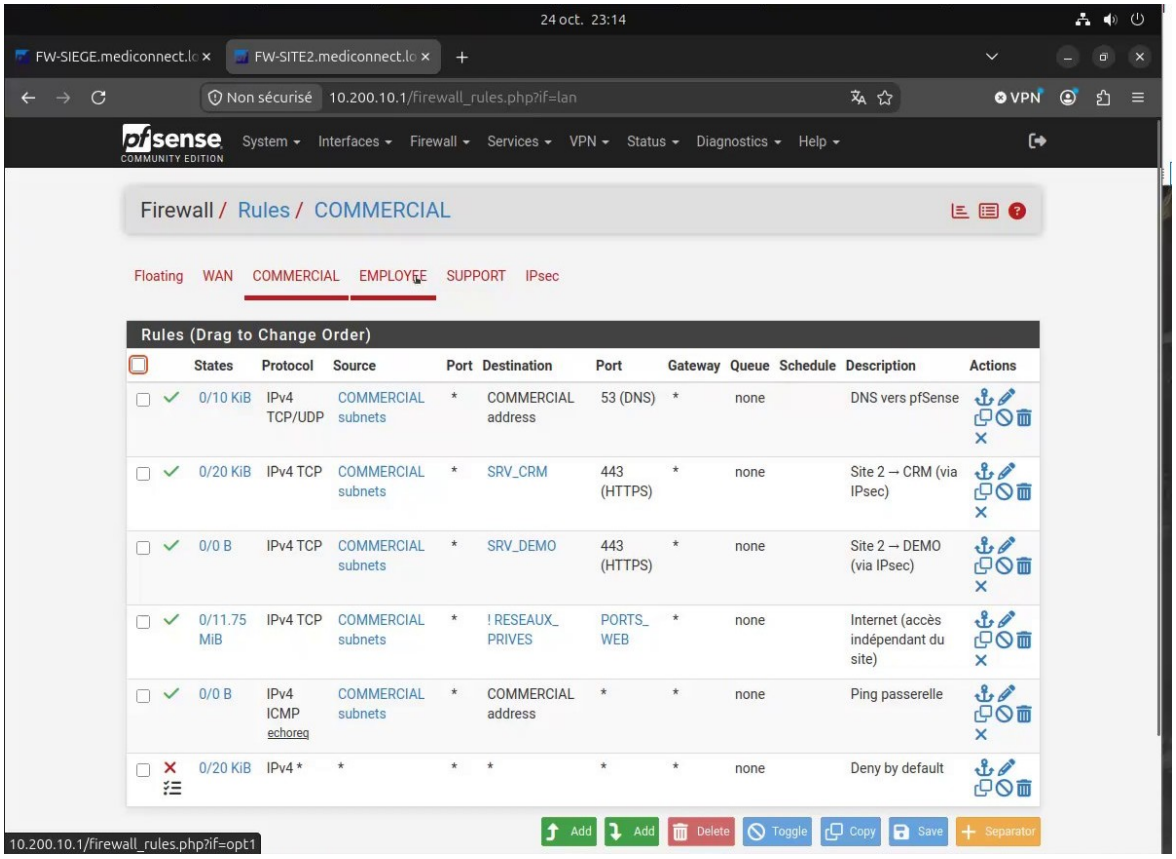


Figure A7 – *Plan d'adressage.* FW_SITE2, zone COMMERCIAL : DNS vers pfSense, CRM et DEMO du siège par le tunnel, web, ping de la passerelle, puis refus par défaut journalisé.

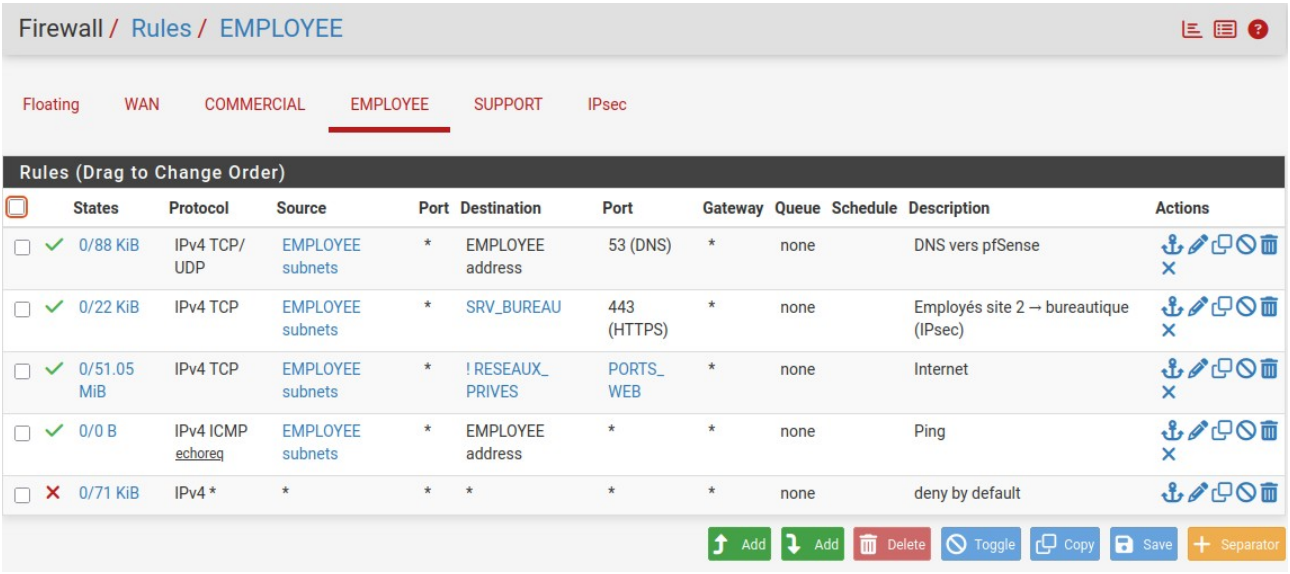


Figure A8 – *Plan d'adressage.* FW_SITE2, zone EMPLOYEE : DNS, SRV_BUREAU du siège en 443 par le tunnel, web, ping de la passerelle, puis refus par défaut ; aucun accès aux autres serveurs ni aux autres zones du site.

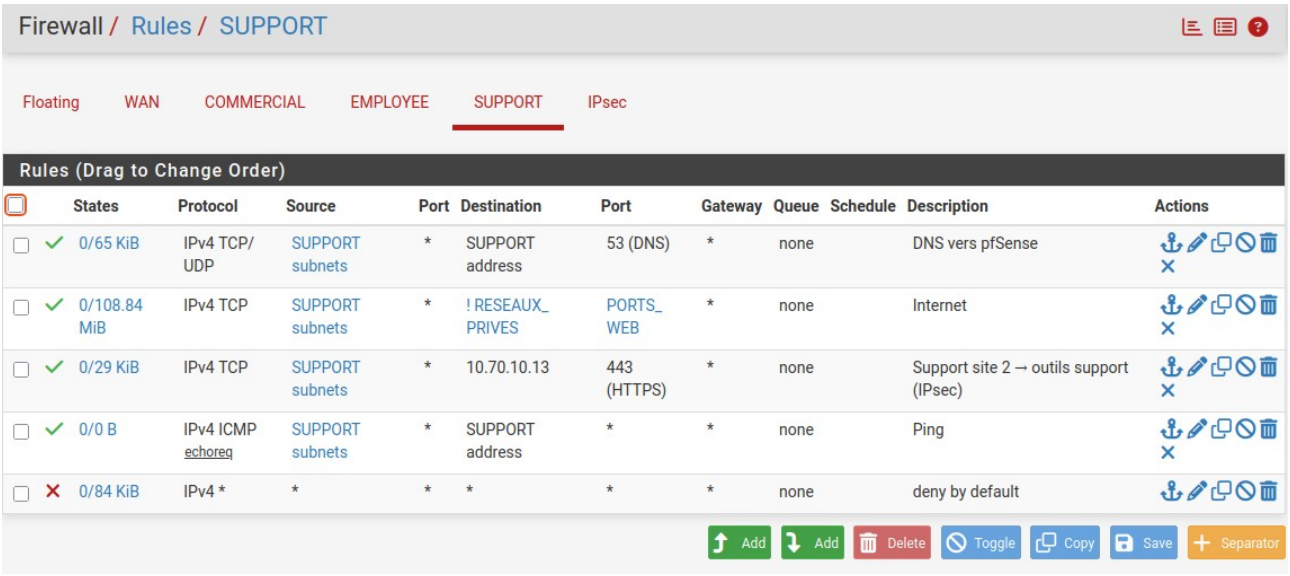


Figure A9 – *Plan d'adressage.* FW_SITE2, zone SUPPORT : même modèle, avec SRV_SUPPORT (10.70.10.13) en 443 par le tunnel.

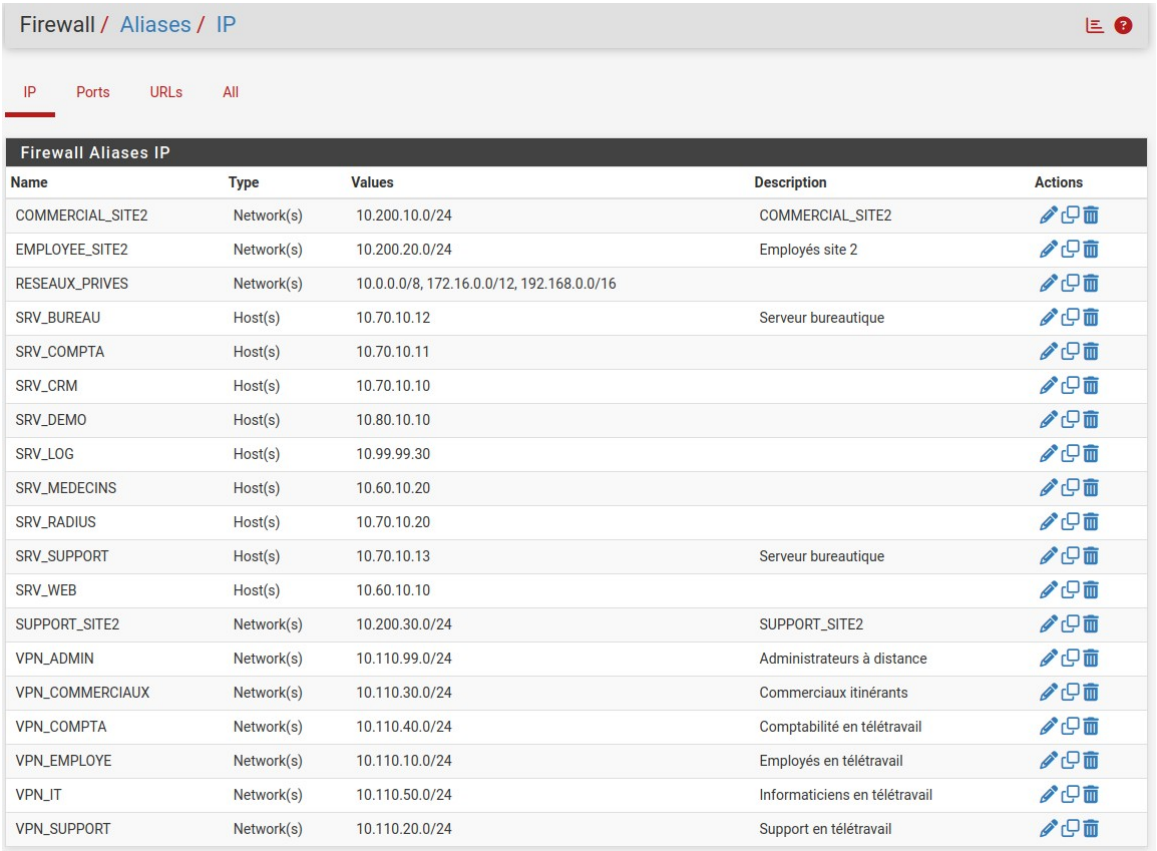


Figure A10 – *Plan d'adressage.* Les alias de FW_Siege : un par serveur (dont SRV_BUREAU et SRV_SUPPORT), un par zone du site 2, un par groupe VPN, et RESEAUX_PRIVES.

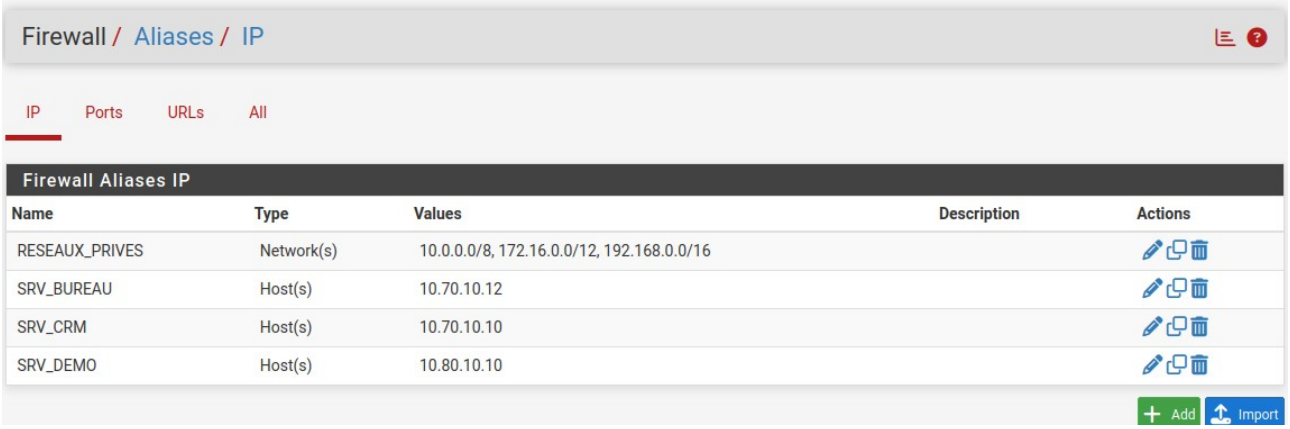


Figure A11 – *Plan d'adressage.* Les alias de FW_SITE2 : seulement les serveurs du siège joignables par le tunnel (CRM, DEMO, SRV_BUREAU) et RESEAUX_PRIVES ; SRV_SUPPORT y est visé par son adresse.

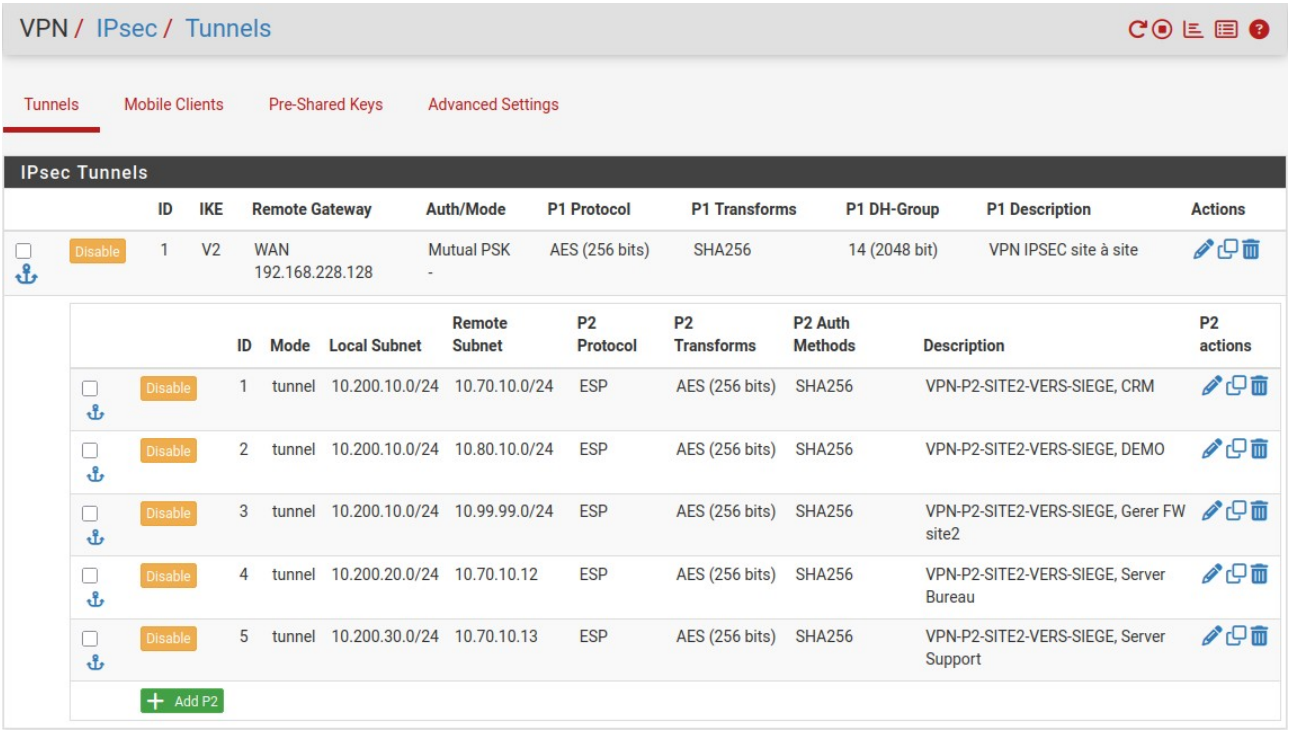


Figure A12 – *VPN utilisés.* IPsec côté site 2 : les cinq phases 2 symétriques.

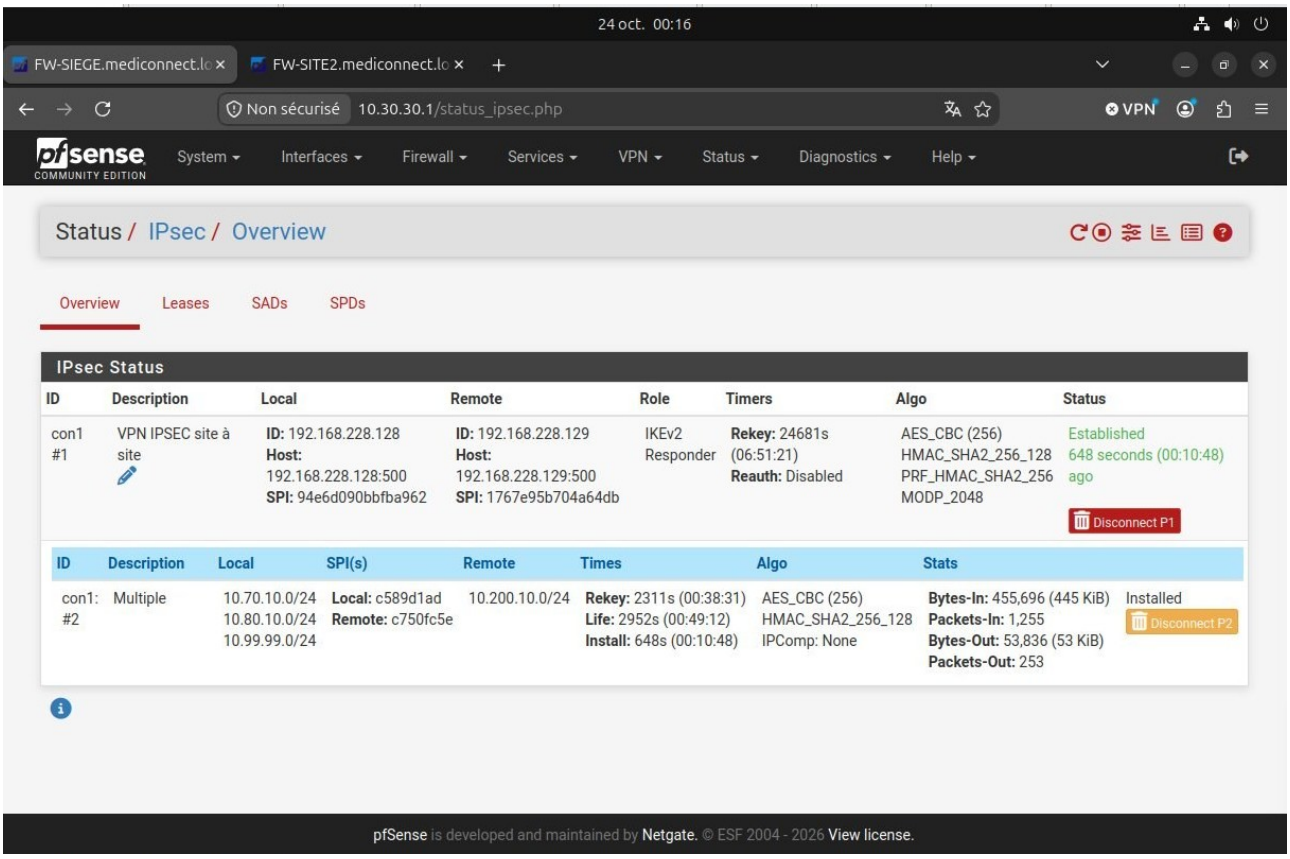


Figure A13 – *VPN utilisés.* Status → IPsec : tunnel établi, trafic échangé pendant les tests.

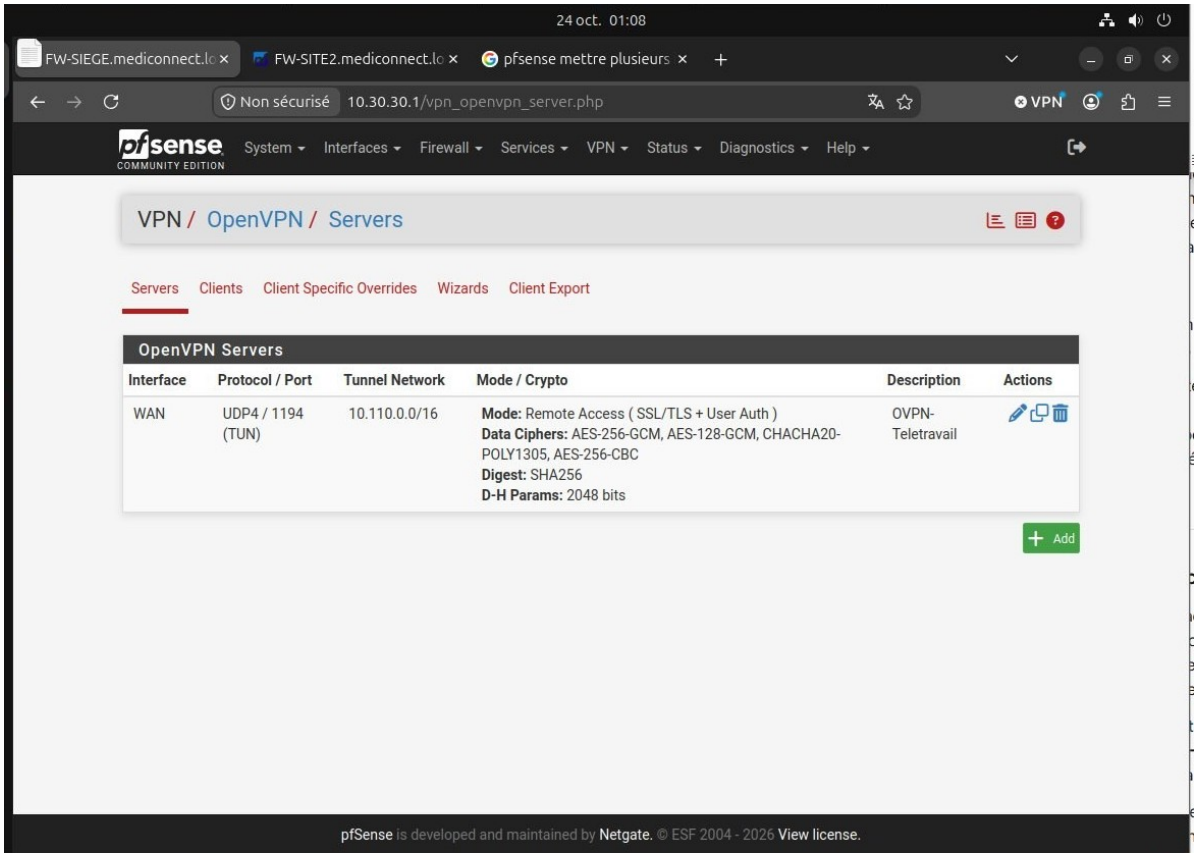


Figure A14 – *VPN utilisés.* Serveur OpenVPN : UDP 1194, SSL/TLS + User Auth, tunnel 10.110.0.0/16.

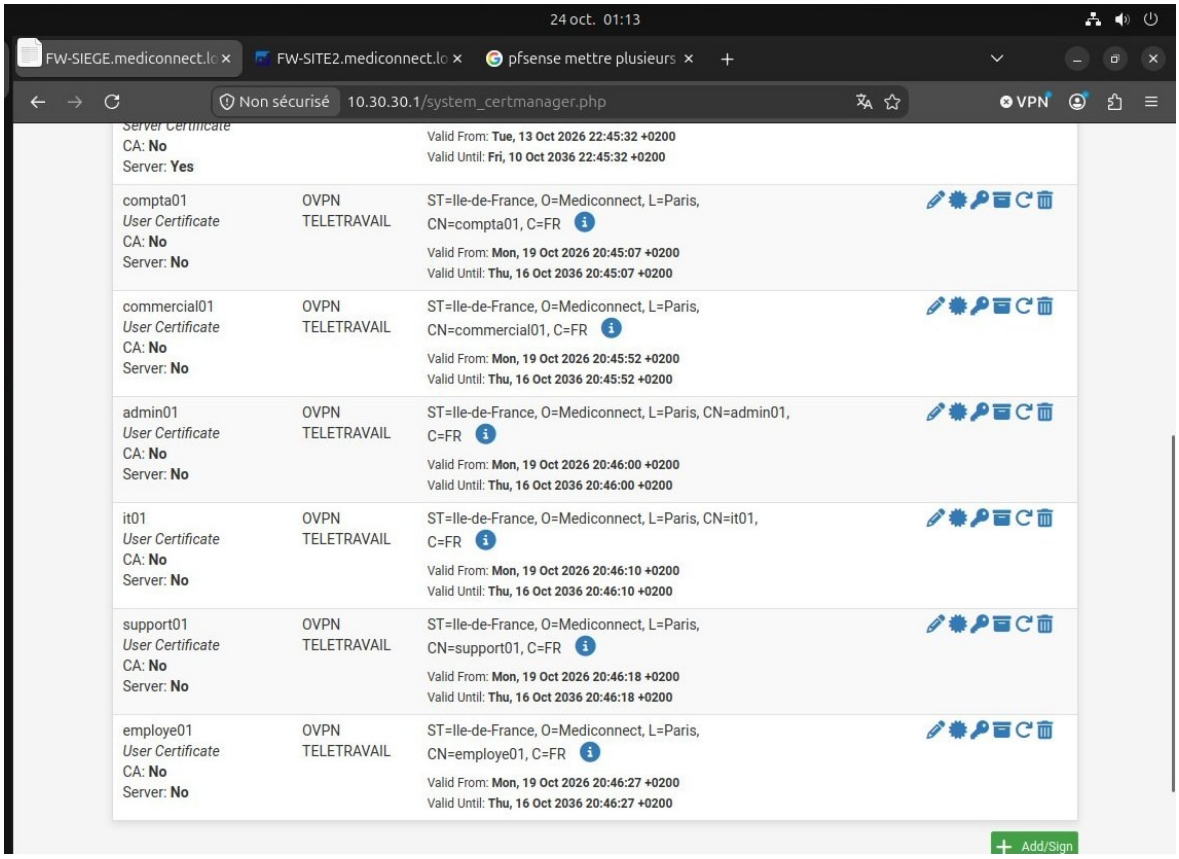


Figure A15 – *Mécanismes d'authentification.* Un certificat par utilisateur, signé par la CA « OVPN TELETRAVAIL ».

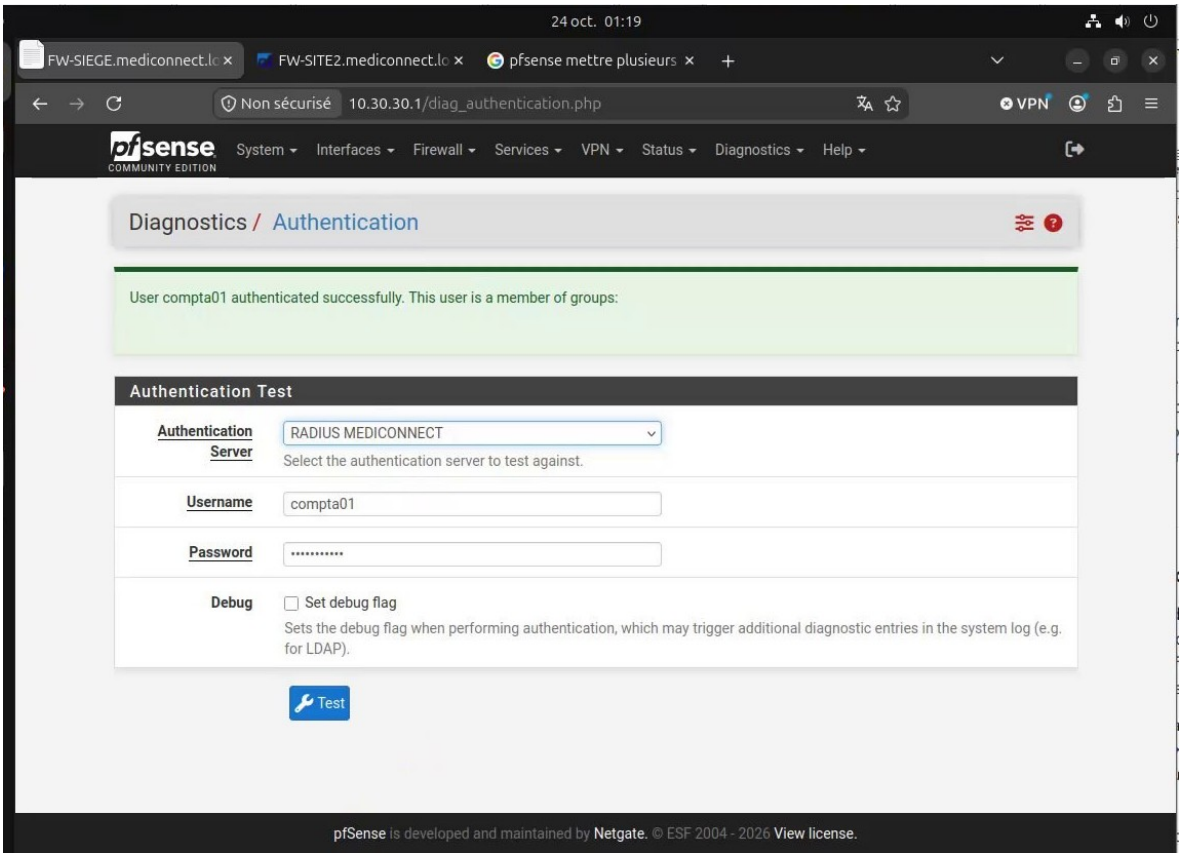


Figure A16 – *Mécanismes d'authentification.* pfSense interroge SRV_RADIUS : compta01 authentifié.



Figure A17 – *Mécanismes d'authentification.* Bon certificat (it01), mauvais mot de passe : AUTH_FAILED. Un certificat volé ne suffit pas.

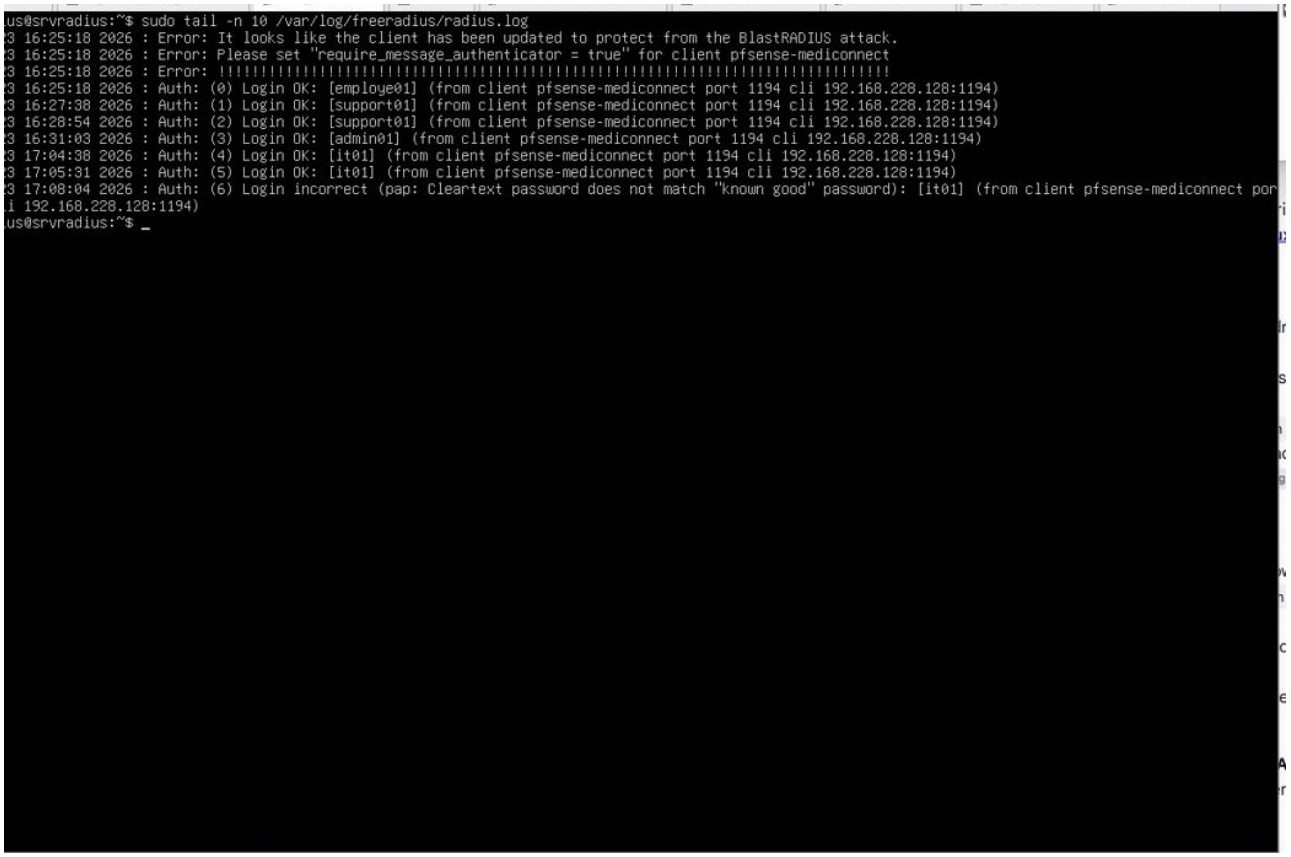


Figure A18 – *Mécanismes d'authentification.* Journal de SRV_RADIUS : connexions acceptées (Login OK) et refusées (Login incorrect).

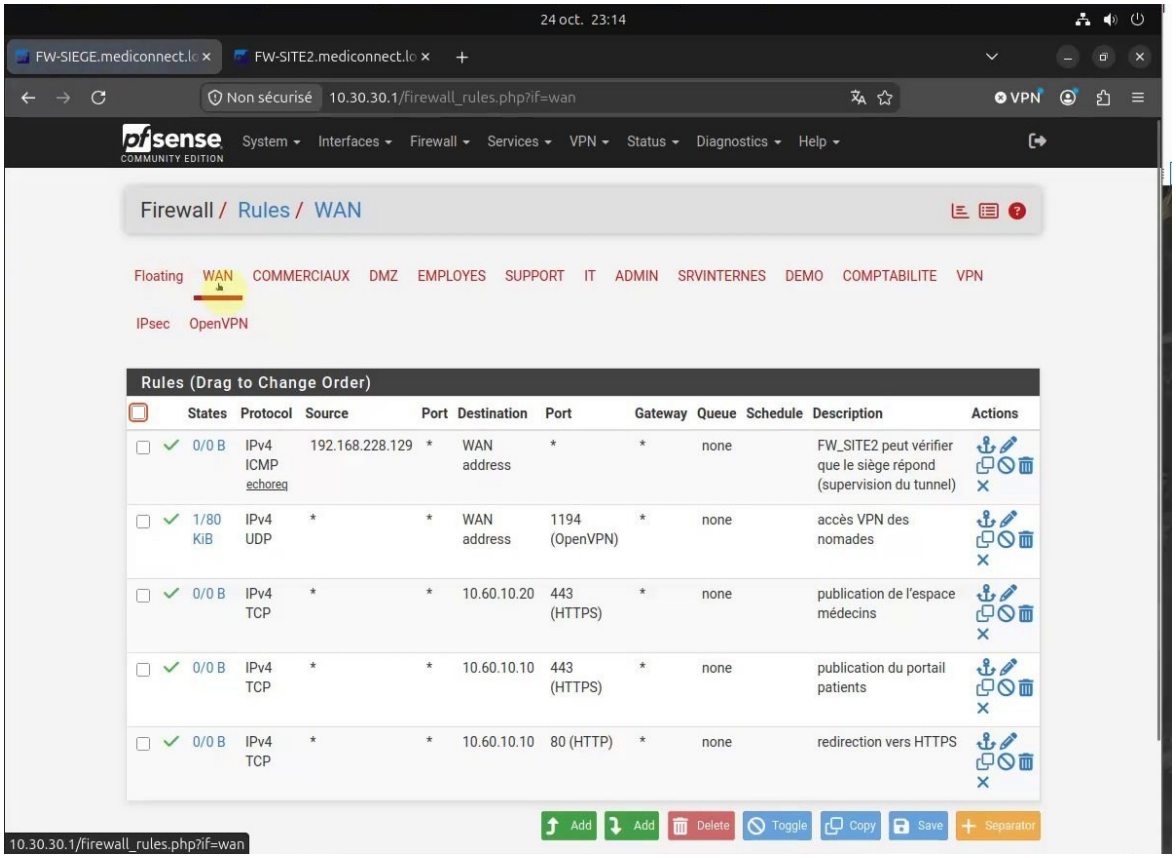


Figure A19 – *Politique de filtrage.* Règles du WAN : seuls l'OpenVPN (UDP 1194), le ping de supervision de FW_SITE2 et les trois services publiés sont acceptés.

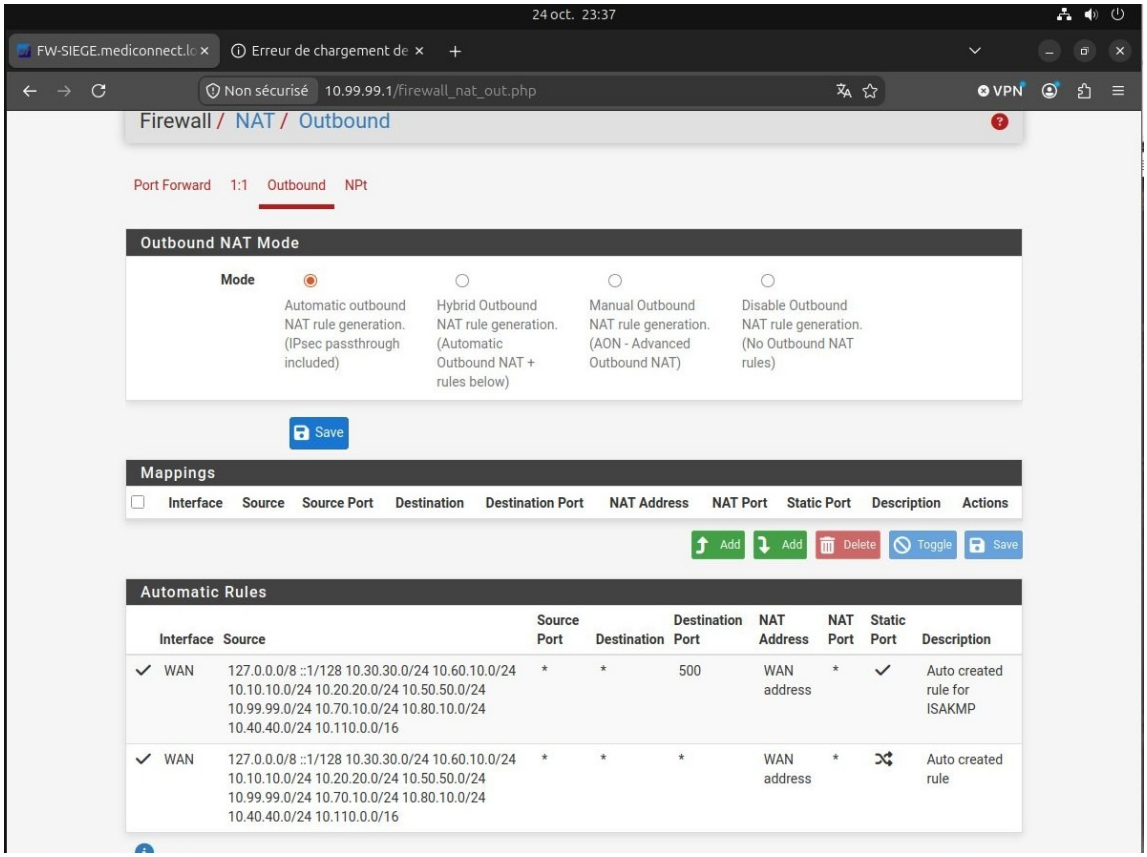


Figure A20 – *Politique de filtrage.* NAT sortant automatique : les zones internes et le VPN sortent derrière l'adresse WAN, seulement là où une règle l'autorise.

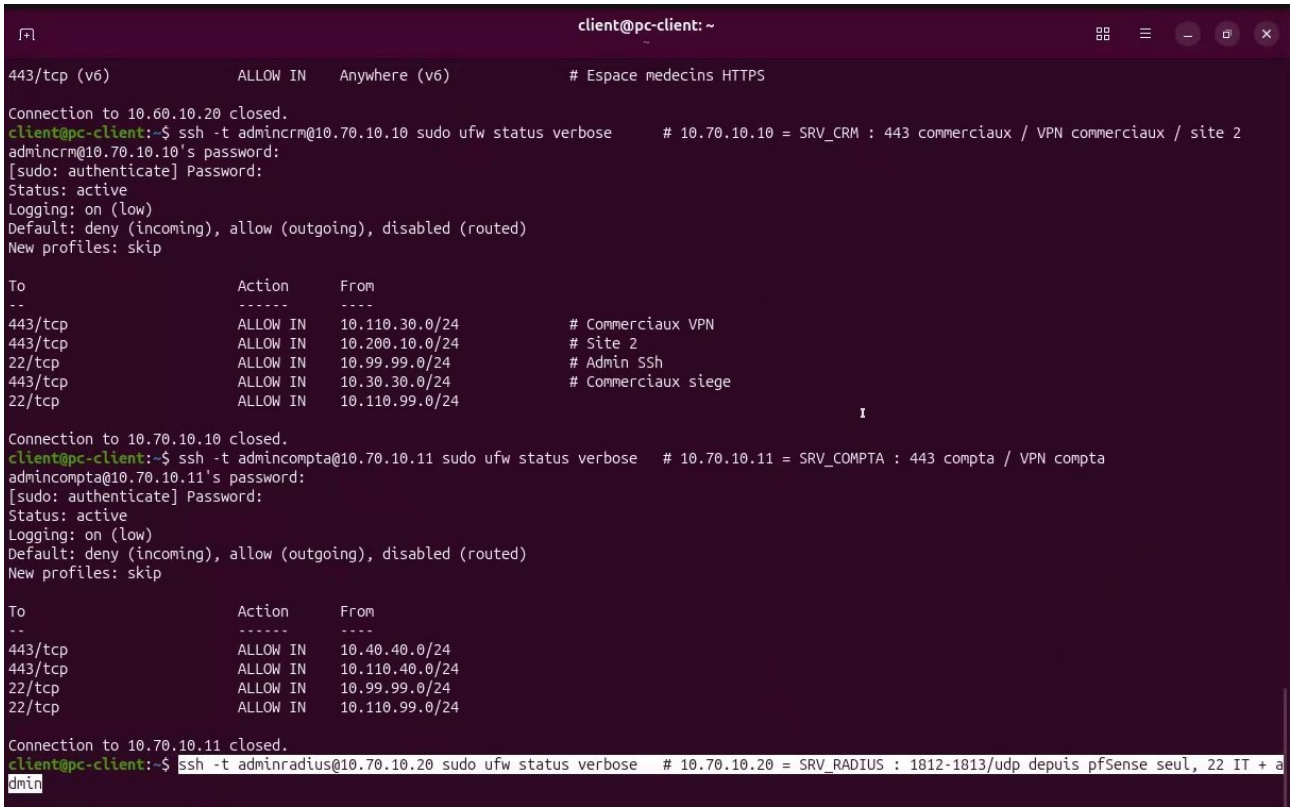


Figure A21 – *Politique de filtrage.* Depuis la zone ADMIN, `ufw status verbose` sur chaque serveur (ici SRV_CRM et SRV_COMPTA) : refus par défaut, le seul service métier depuis les seuls réseaux autorisés, et SSH réservé à la zone ADMIN et aux admins VPN (10.110.99.0/24).

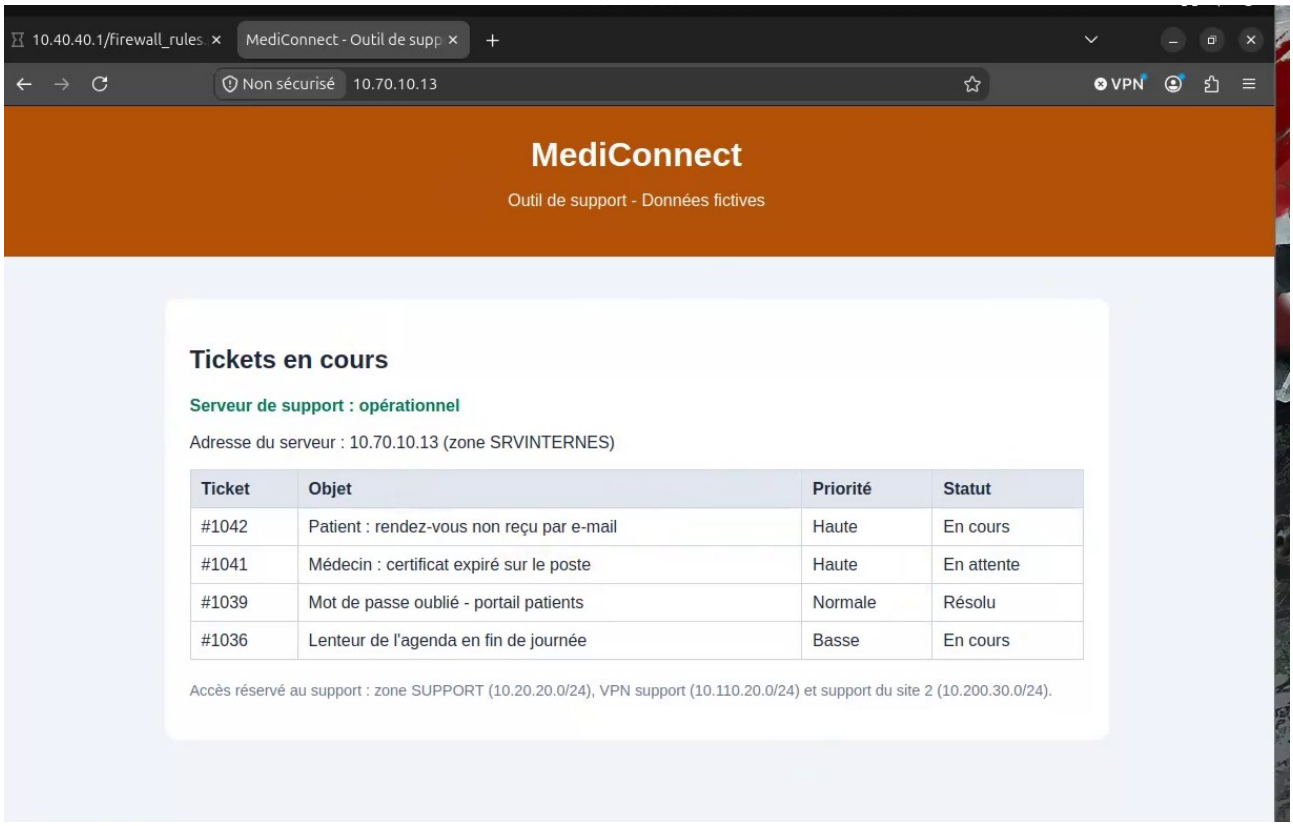


Figure A22 – *Politique de filtrage.* Depuis PC-SUPPORT, l'outil de support servi par SRV_SUPPORT (10.70.10.13), données fictives.

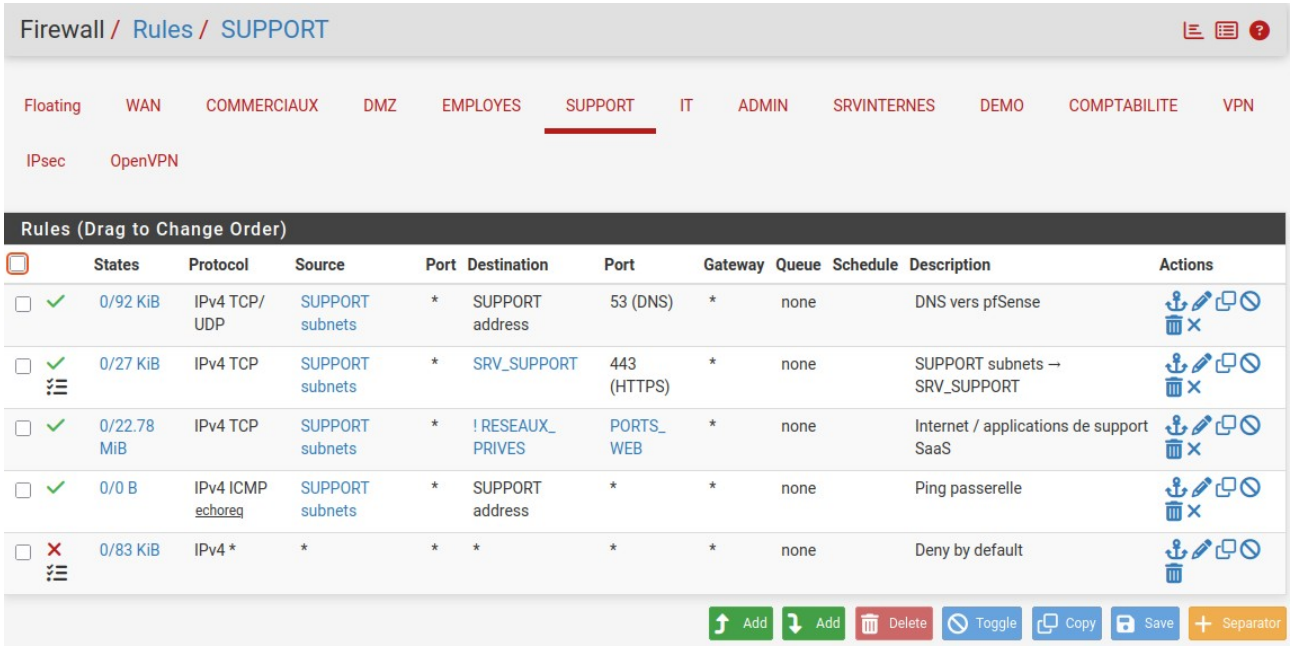


Figure A23 – *Politique de filtrage.* Zone SUPPORT : DNS, SRV_SUPPORT en 443, web, ping de la passerelle, puis refus par défaut journalisé.

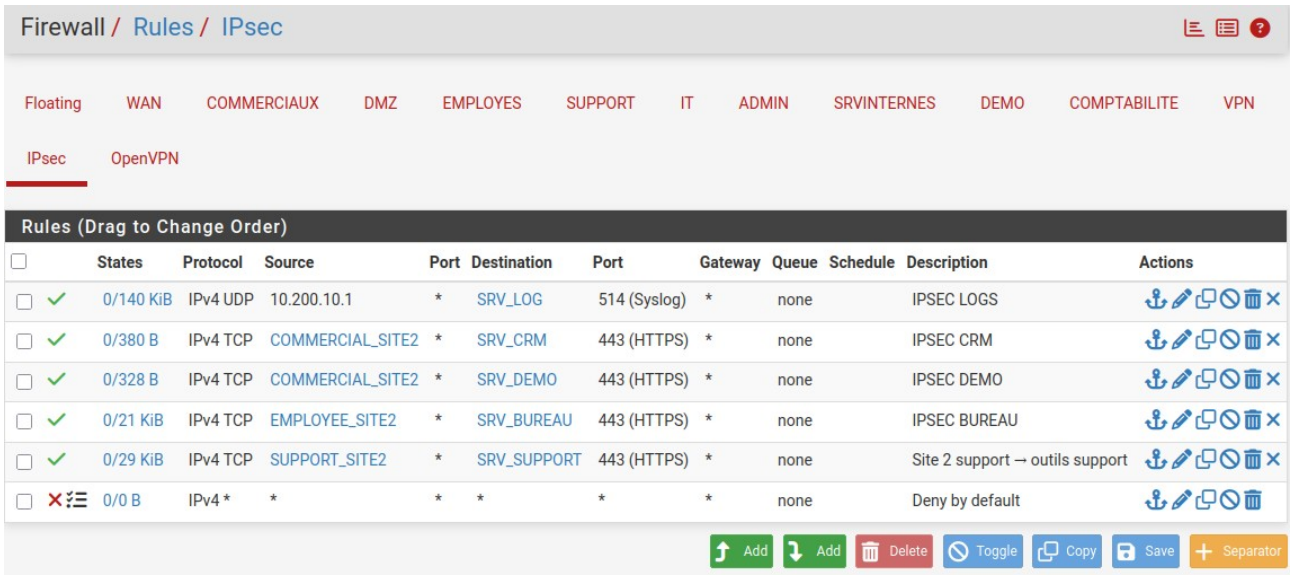


Figure A24 – *Politique de filtrage.* Onglet IPsec de FW_Siege : chaque zone du site 2 vers son seul serveur (CRM et DEMO, SRV_BUREAU, SRV_SUPPORT), le syslog de FW_SITE2, puis refus par défaut.

```
adminsupport@srv-support:~$ sudo ufw status numbered    # 443 : support (siège, VPN, site 2) ; 22 : admins uniquement
[sudo: authenticate] Password:
Status: active

     To                         Action      From
     --                         ------      ----
[ 1] 443/tcp                    ALLOW IN    10.20.20.0/24              # Support
[ 2] 443/tcp                    ALLOW IN    10.110.20.0/24             # VPN support
[ 3] 443/tcp                    ALLOW IN    10.200.30.0/24             # Support site 2
[ 4] 22/tcp                     ALLOW IN    10.99.99.0/24              # Admin SSH
[ 5] 22/tcp                     ALLOW IN    10.110.99.0/24             # Admin VPN SSH

adminsupport@srv-support:~$
```

Figure A25 – *Politique de filtrage.* ufw sur SRV_SUPPORT : 443 pour le seul support (siège, VPN, site 2), SSH pour les seuls administrateurs.

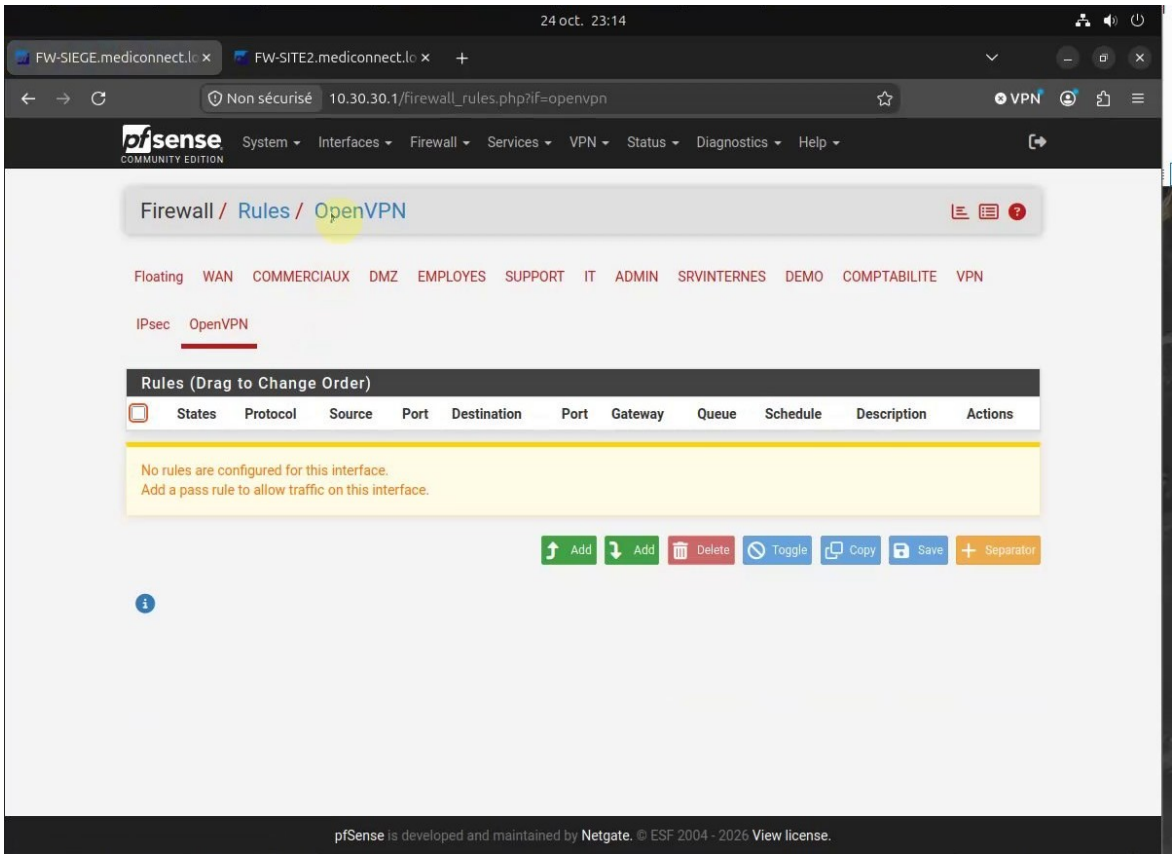


Figure A26 – *Règles basées sur l'identité.* L'onglet OpenVPN, sans aucune règle : seul l'onglet VPN décide.

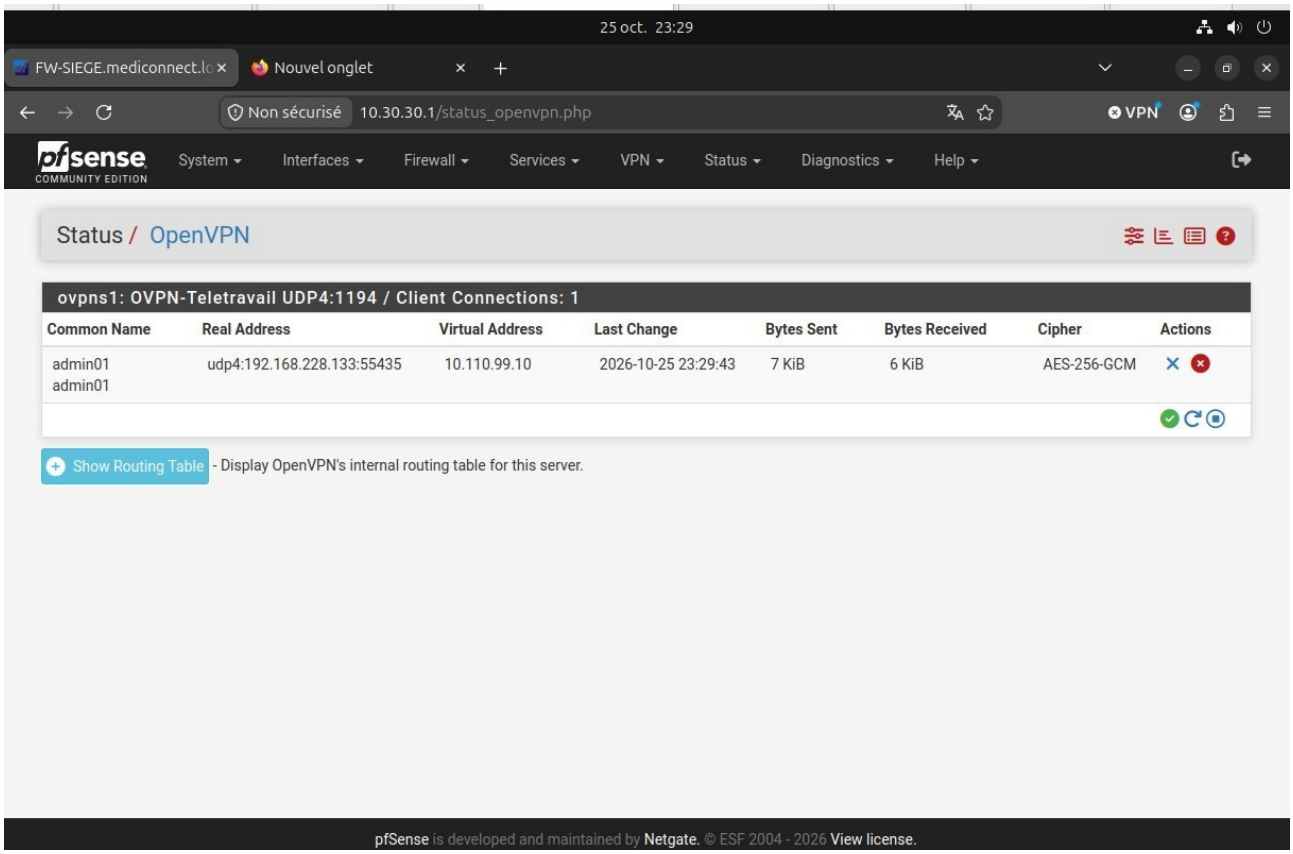


Figure A27 – *Règles basées sur l'identité.* Status → OpenVPN : admin01 est connecté depuis 192.168.228.133 (Internet) et a reçu 10.110.99.10, l'adresse du groupe Administrateurs ; le tunnel est chiffré en AES-256-GCM. Le pare-feu sait donc qui se cache derrière chaque adresse VPN.



Figure A28 – *Règles basées sur l'identité.* employe01 (10.110.10.10) : le web répond (HTTP/2 200), le CRM, la comptabilité et la DEMO sont refusés.

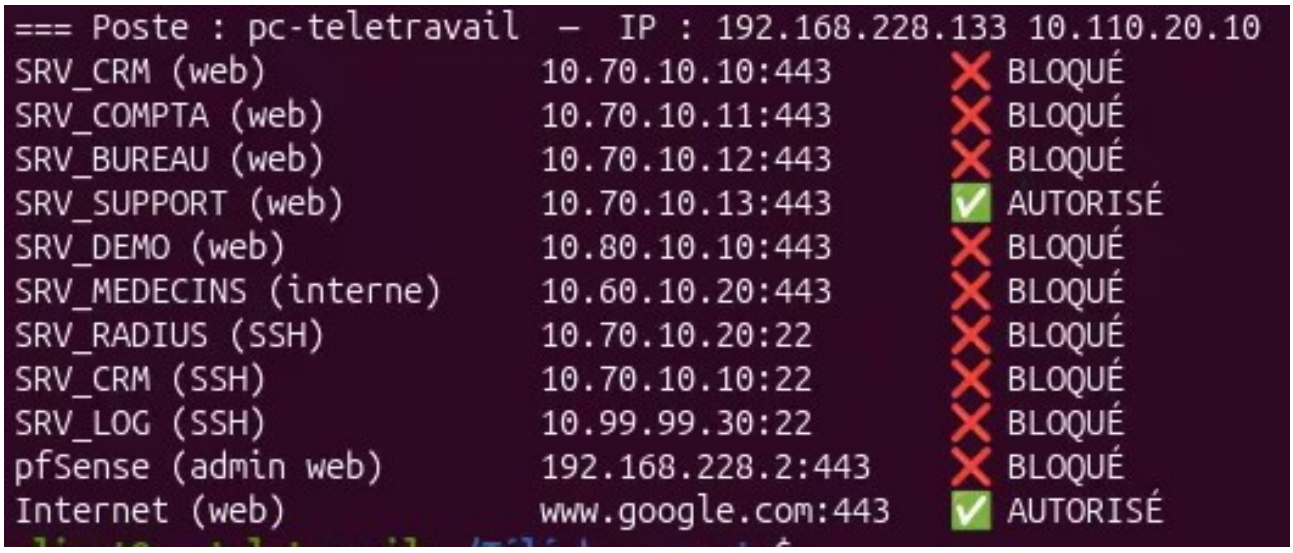


Figure A29 – *Règles basées sur l'identité.* Même poste en support01 (10.110.20.10) : seul SRV_SUPPORT est autorisé, avec le web (même remarque pour la ligne « pfSense »).

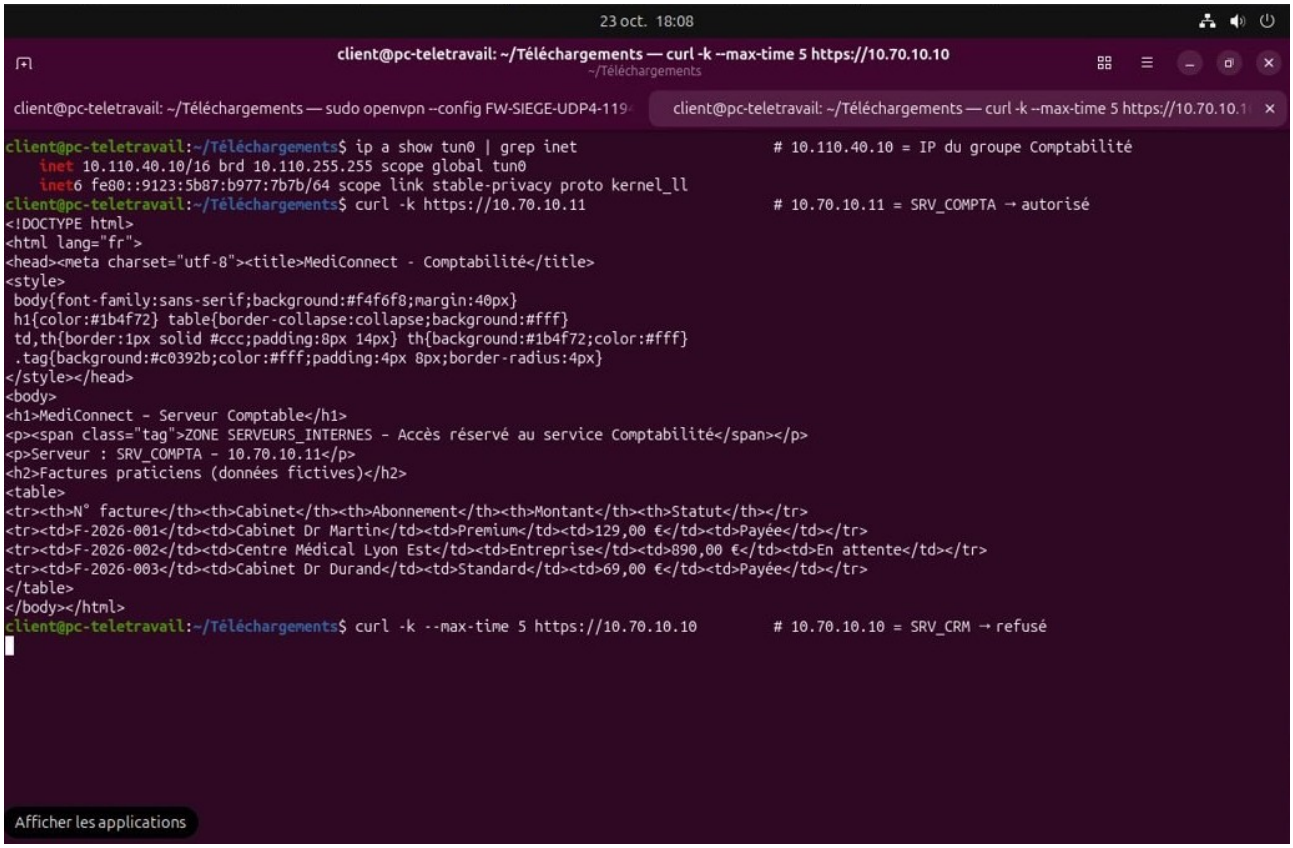


Figure A30 – *Règles basées sur l'identité.* compta01 en VPN (10.110.40.10) : comptabilité autorisée, CRM refusé.

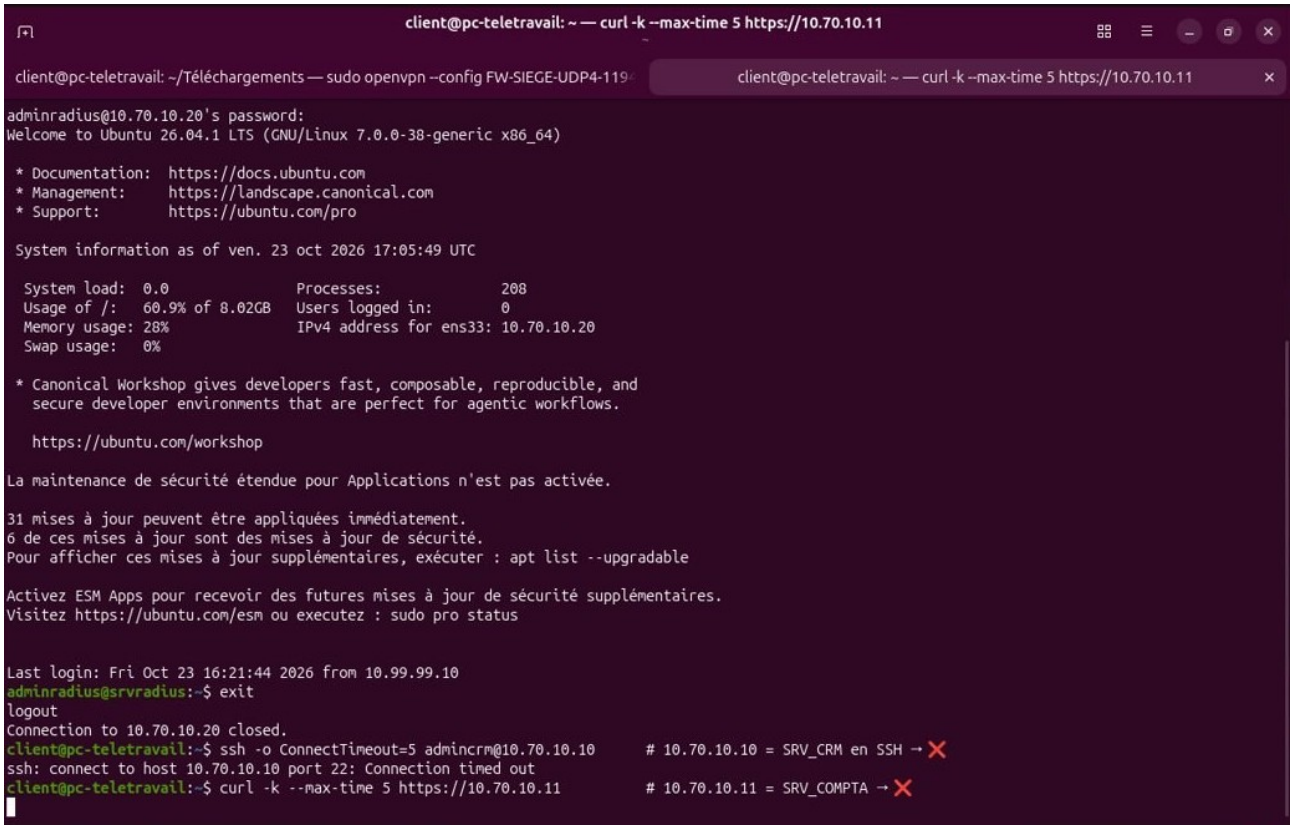


Figure A31 – *Règles basées sur l'identité.* it01 (10.110.50.10) : SSH vers SRV_RADIUS accepté, SSH vers SRV_CRM et HTTPS vers SRV_COMPTA refusés.

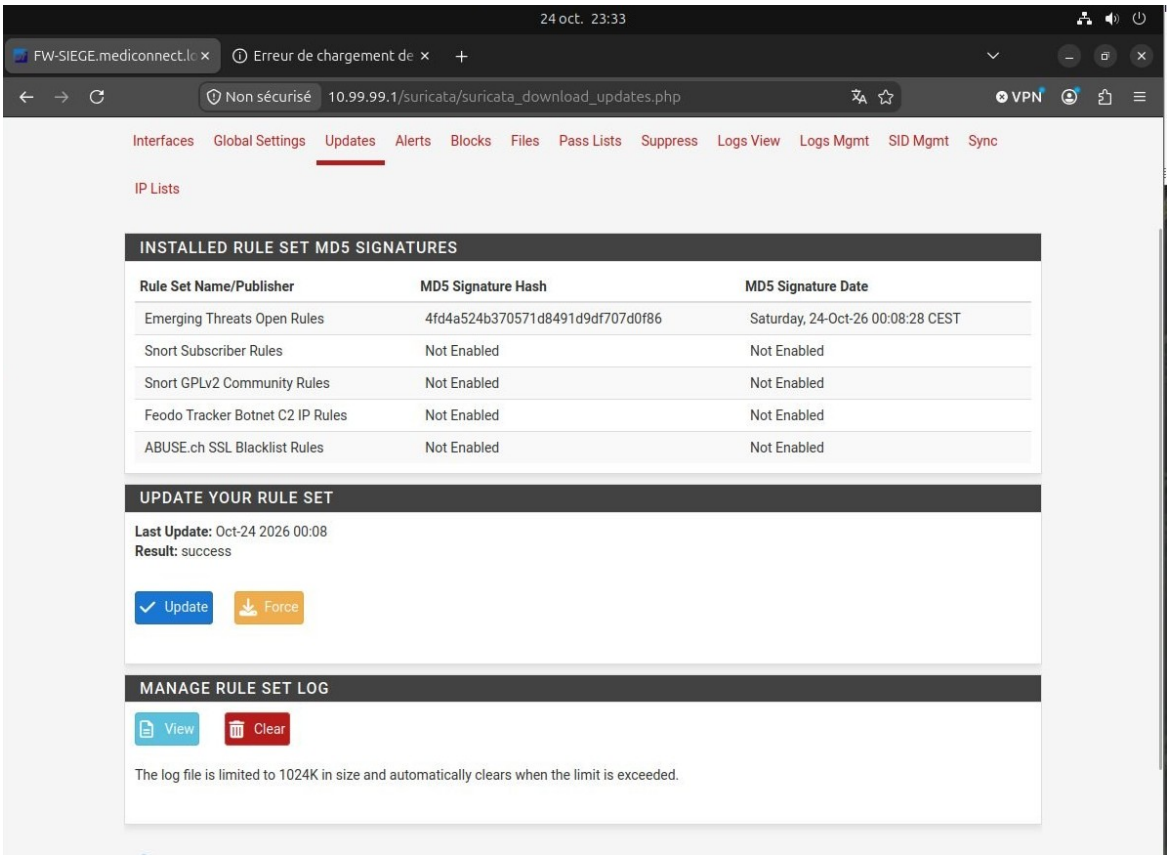


Figure A32 – *Contrôle applicatif.* Signatures Emerging Threats Open installées et mises à jour avec succès.

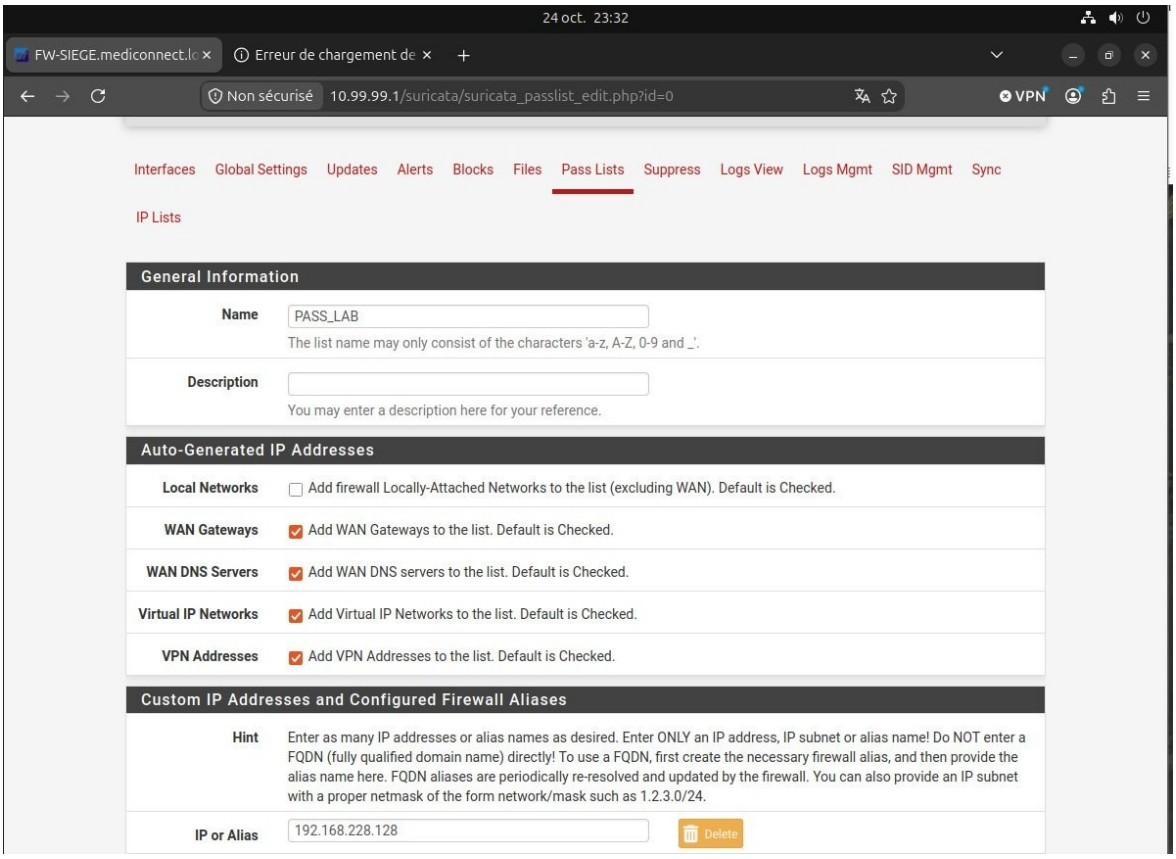


Figure A33 – *Contrôle applicatif.* Pass list PASS_LAB : les passerelles, DNS et adresses VPN ne peuvent pas être bloqués par erreur.

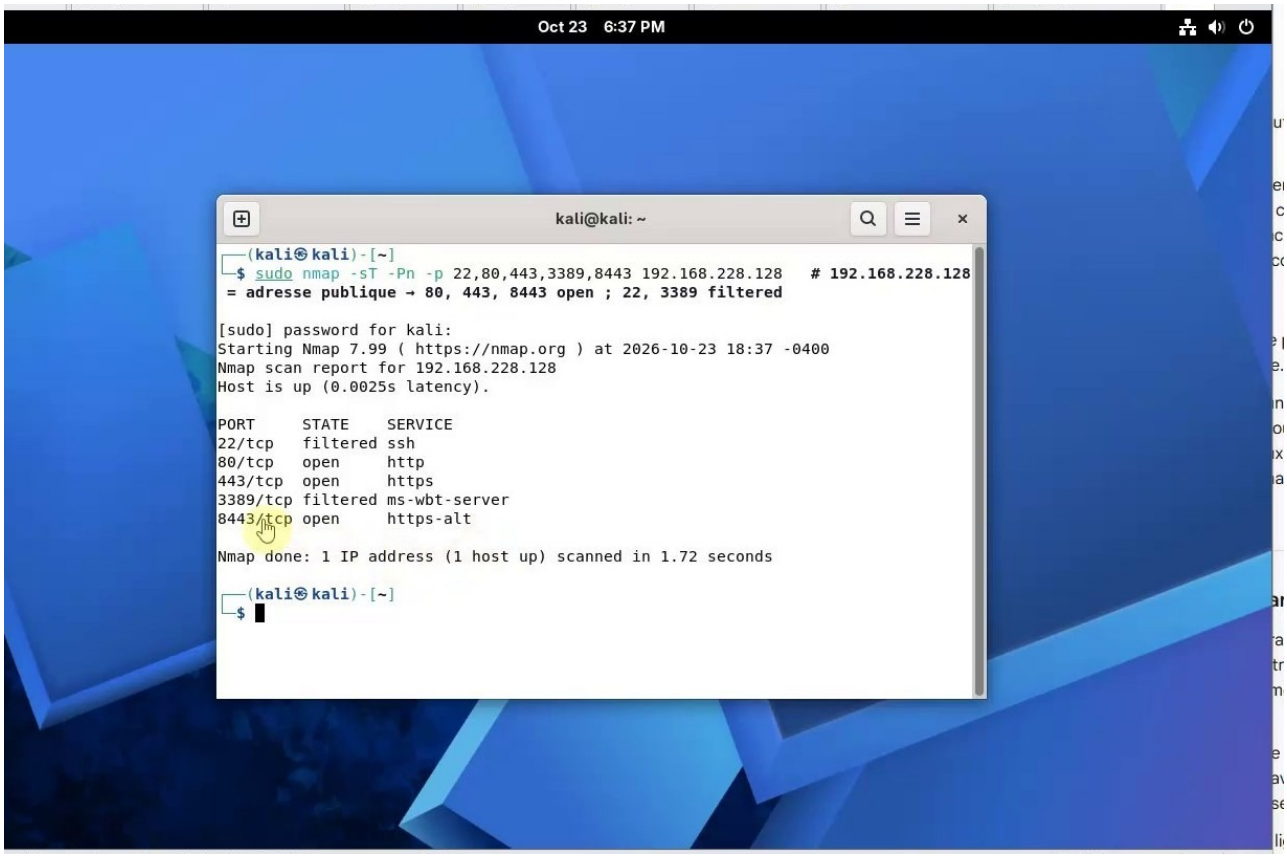


Figure A34 – *Contrôle applicatif.* Depuis Kali : seuls 80, 443 et 8443 sont ouverts ; 22 et 3389 sont filtrés.

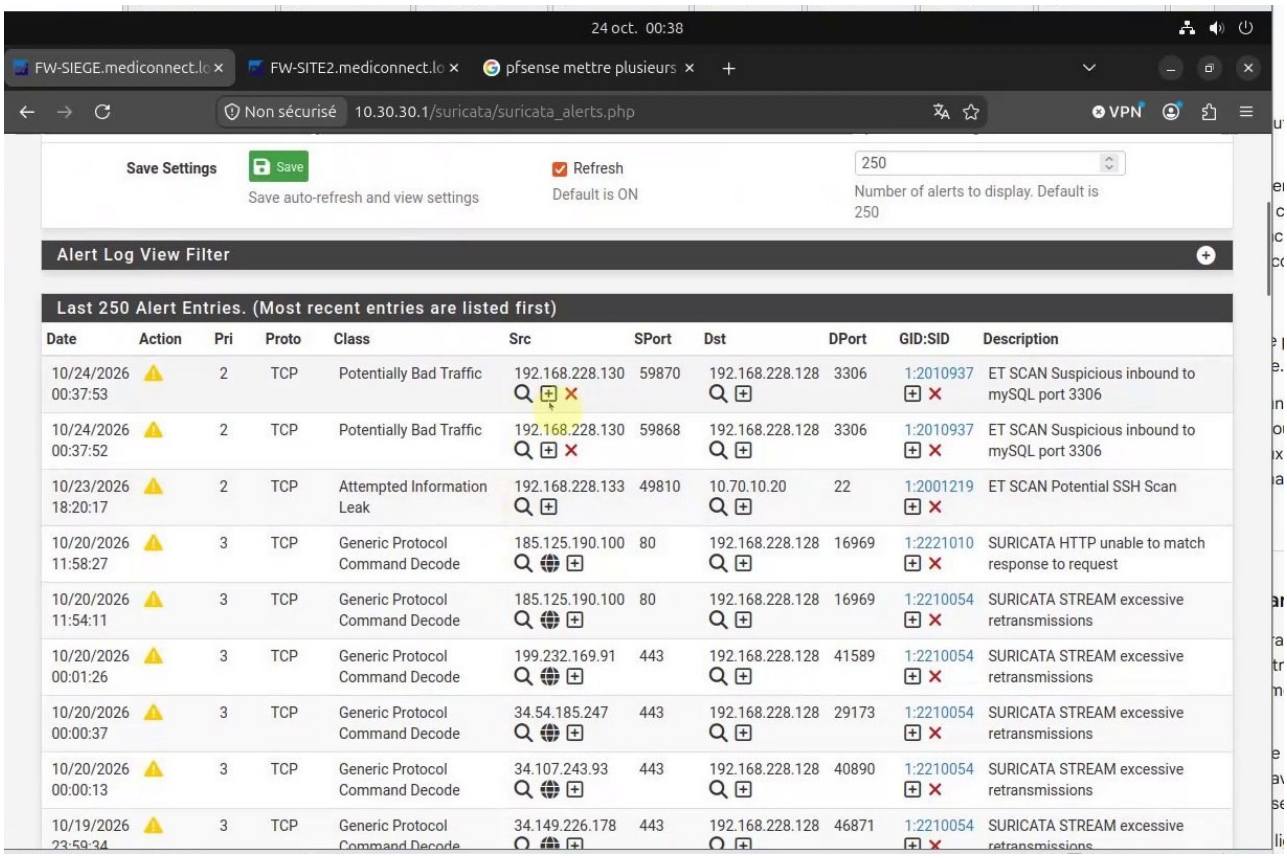


Figure A35 – *Contrôle applicatif.* Alertes Suricata pendant le scan : signatures « ET SCAN » déclenchées par 192.168.228.130 (Kali).

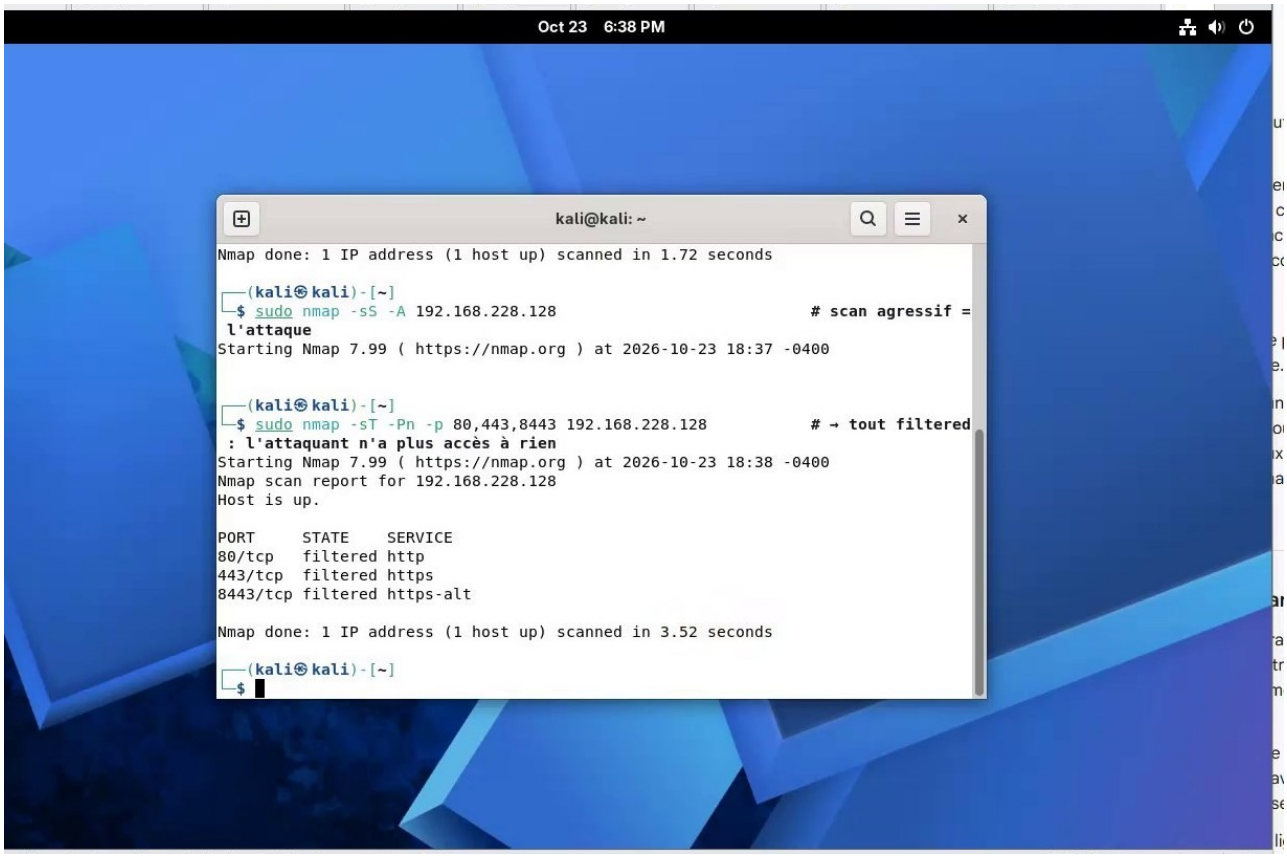


Figure A36 – *Contrôle applicatif.* Après le blocage, même les services publiés sont filtrés pour l'attaquant.

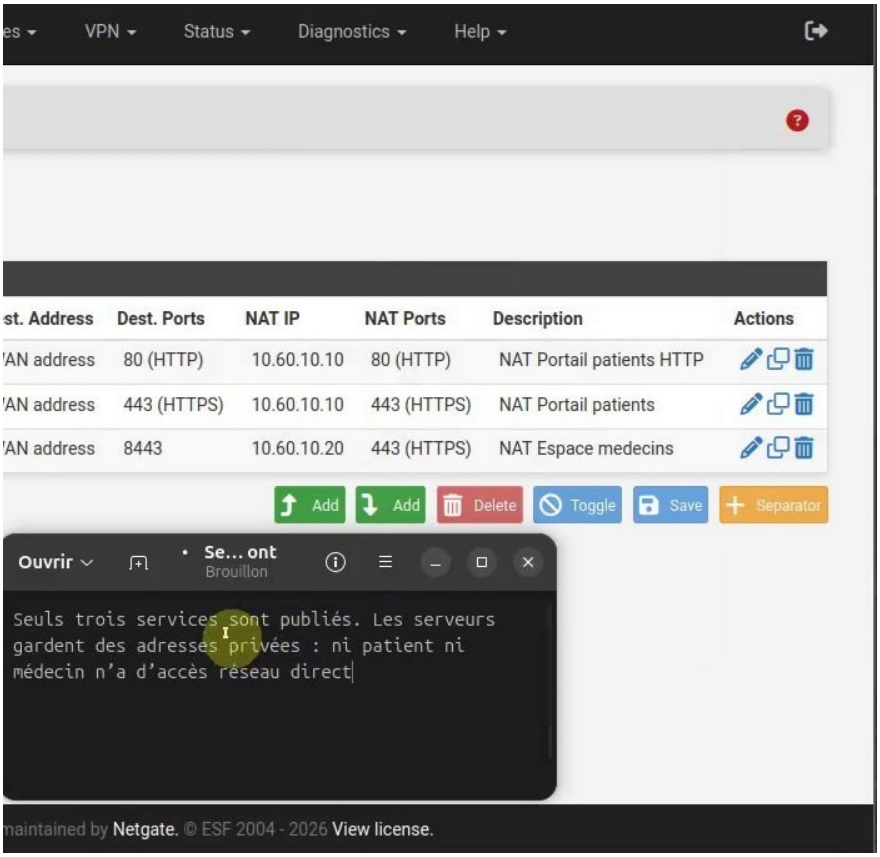


Figure A37 – *Protection de la DMZ.* NAT Port Forward : 443 et 80 vers SRV_WEB, 8443 vers SRV_MEDECINS.

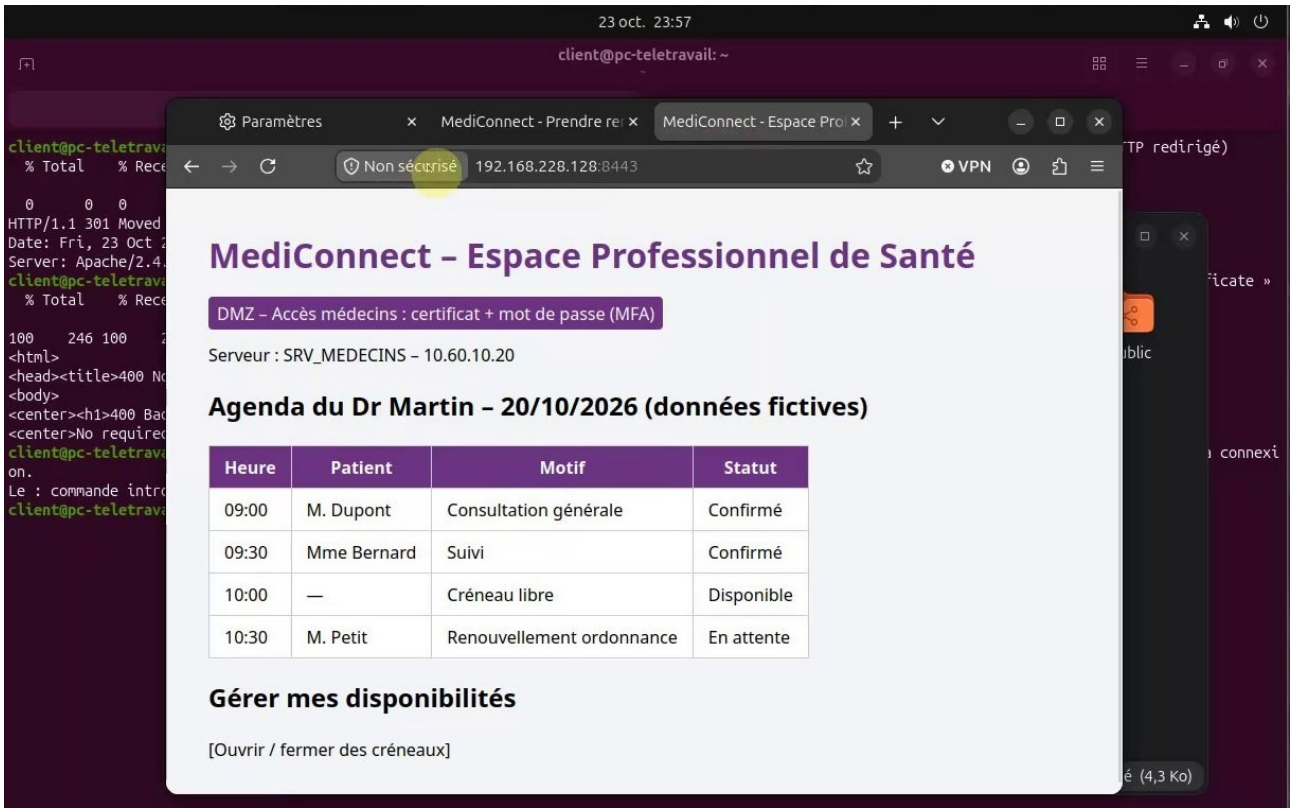


Figure A38 – *Protection de la DMZ.* Avec certificat et mot de passe, le Dr Martin accède à son agenda.

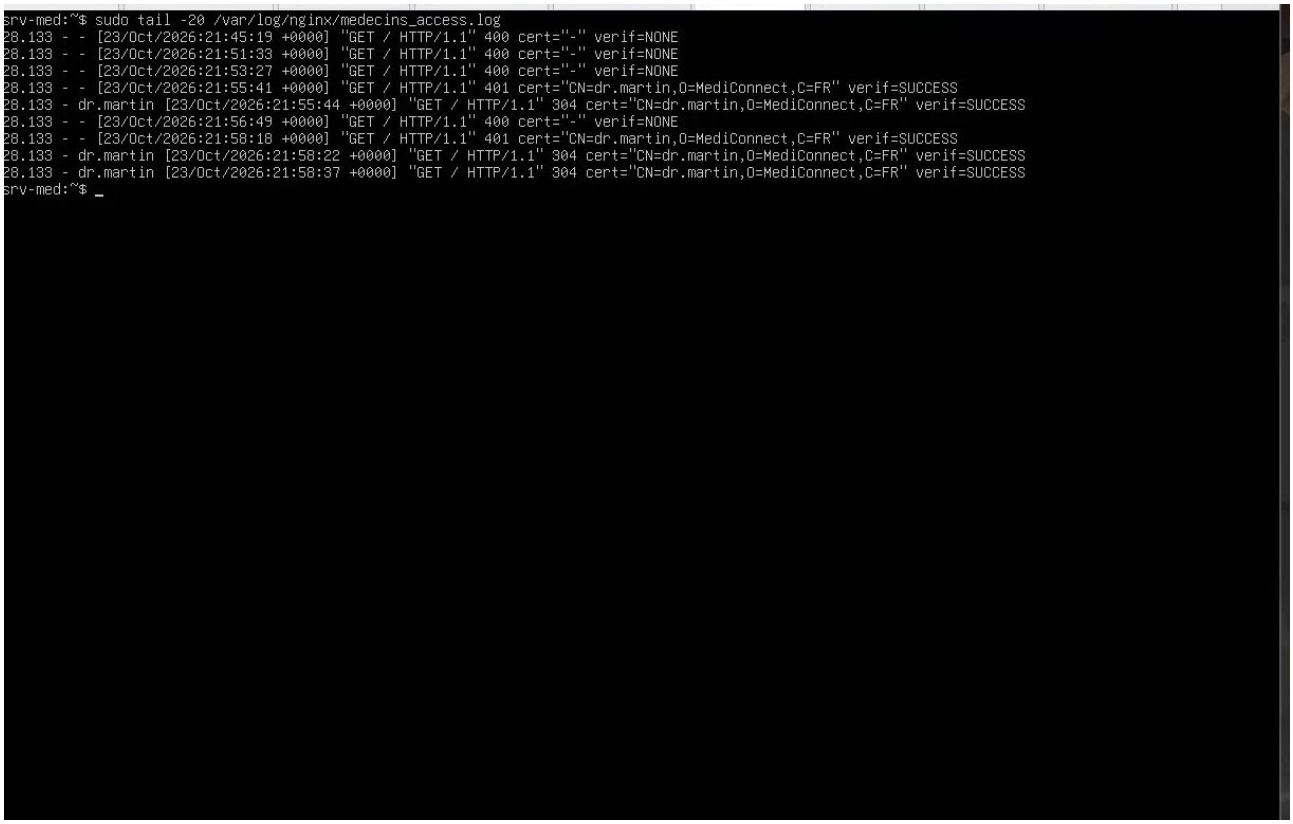


Figure A39 – *Protection de la DMZ.* Journal de SRV_MEDECINS : utilisateur dr.martin et certificat vérifié (verif=SUCCESS).

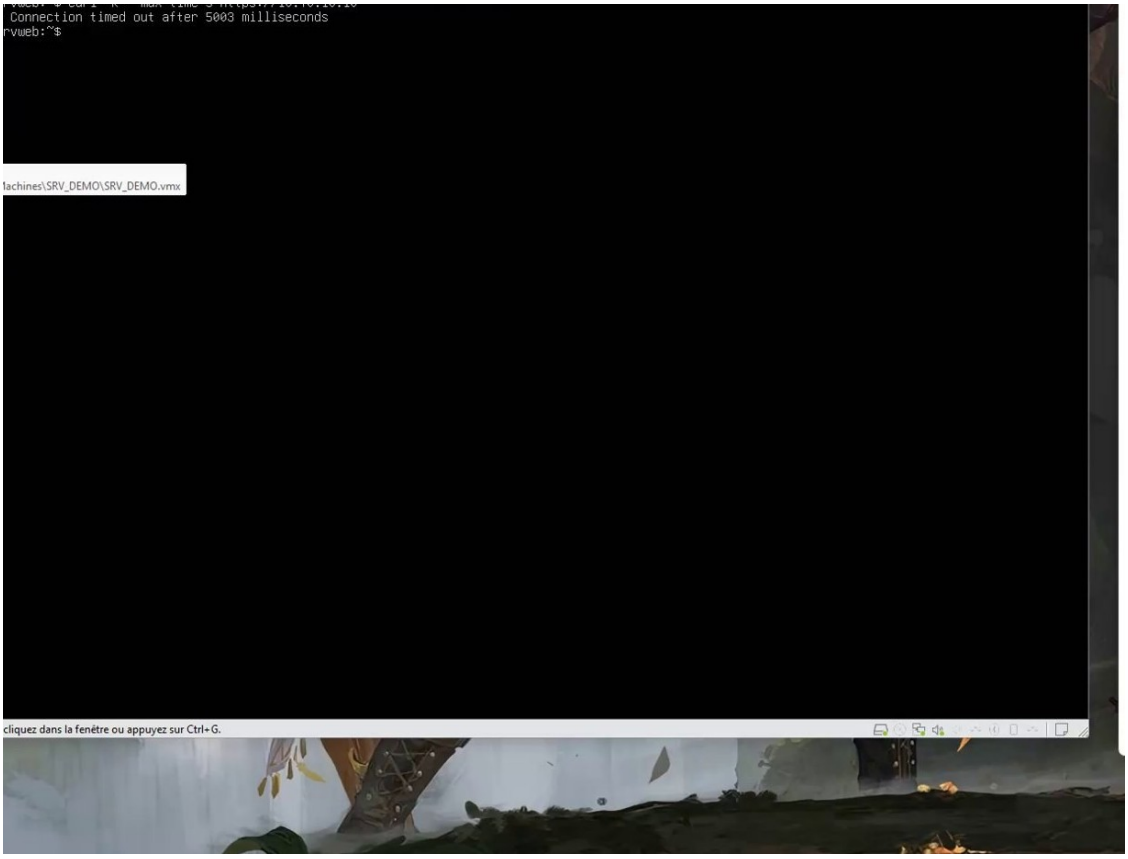


Figure A40 – *Protection de la DMZ.* SRV_WEB (DMZ) ne joint pas SRV_CRM.

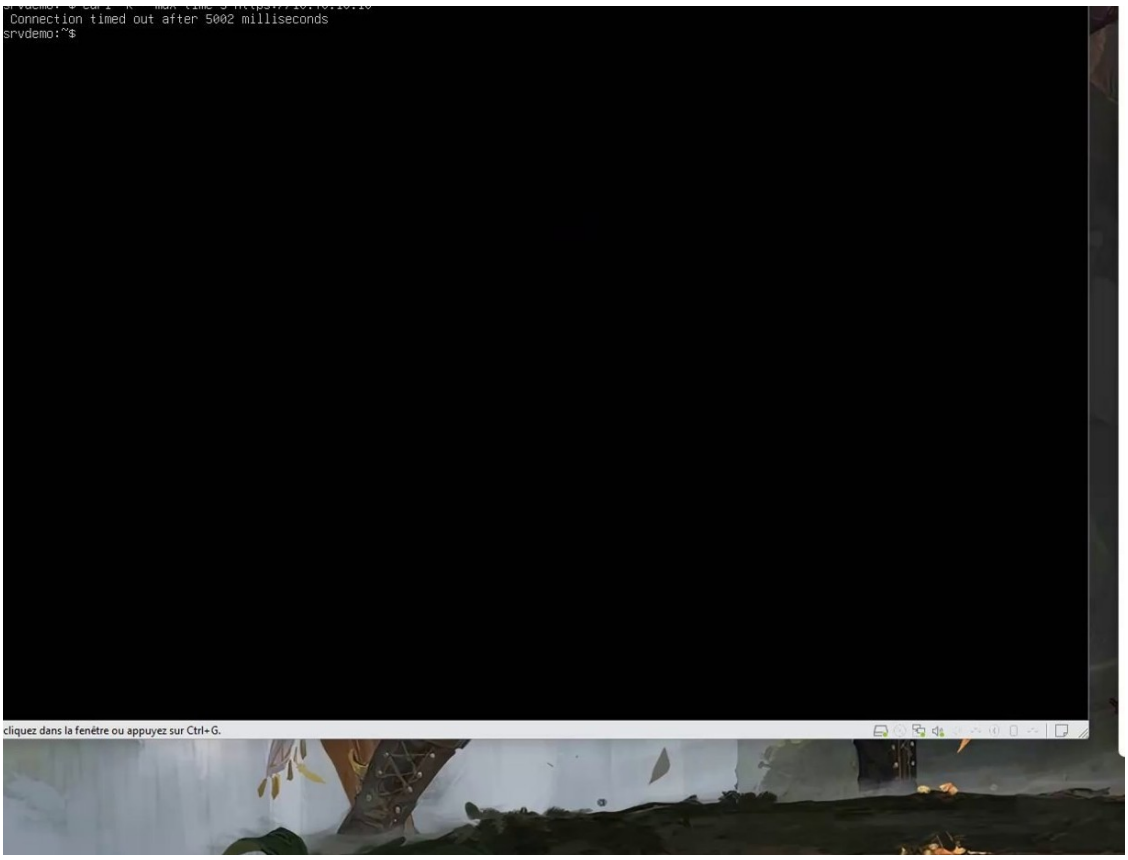


Figure A41 – *Protection de la DMZ.* SRV_DEMO ne joint pas la production.

```
  Memory usage: 31%              IPv4 address for ens33: 10.60.10.20
  Swap usage:   0%

 * Canonical Workshop gives developers fast, composable, reproducible, and
   secure developer environments that are perfect for agentic workflows.

   https://ubuntu.com/workshop

La maintenance de sécurité étendue pour Applications n'est pas activée.

46 mises à jour peuvent être appliquées immédiatement.
7 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Activez ESM Apps pour recevoir des futures mises à jour de sécurité supplémentaires.
Visitez https://ubuntu.com/esm ou executez : sudo pro status


Last login: Sat Oct 24 22:37:45 2026 from 10.99.99.10
adminmed@srv-med:~$ sudo ufw insert 1 deny from 10.60.10.10 comment 'SRV_WEB interdit (isolement DMZ)'   # 10.60.10.10 = SRV_WEB
sudo ufw status numbered                                                                                  # la règle [1] doit être DENY IN 10.60.10.10
[sudo: authenticate] Password:
Rule inserted
Status: active

     To                         Action      From
     --                         ------      ----
[ 1] Anywhere                   DENY IN     10.60.10.10                # SRV_WEB interdit (isolement DMZ)
[ 2] 443/tcp                    ALLOW IN    Anywhere                   # Espace medecins HTTPS
[ 3] 22/tcp                     ALLOW IN    10.99.99.0/24              # Admin SSH
[ 4] 22/tcp                     ALLOW IN    10.110.99.0/24
[ 5] 443/tcp (v6)               ALLOW IN    Anywhere (v6)              # Espace medecins HTTPS

adminmed@srv-med:~$ curl -k --max-time 5 https://10.60.10.10    # 10.60.10.10 = SRV_WEB → doit expirer
sudo dmesg | grep "UFW BLOCK" | grep 10.60.10.10 | tail -2   # la preuve : le paquet de SRV_WEB est refusé
curl: (28) Connection timed out after 5002 milliseconds
adminmed@srv-med:~$
```

Figure A42 – *Protection de la DMZ.* Sur SRV_MEDECINS, la règle [1] refuse tout trafic venant de SRV_WEB (10.60.10.10) ; depuis SRV_MEDECINS, curl vers SRV_WEB expire, car SRV_WEB refuse à son tour SRV_MEDECINS.

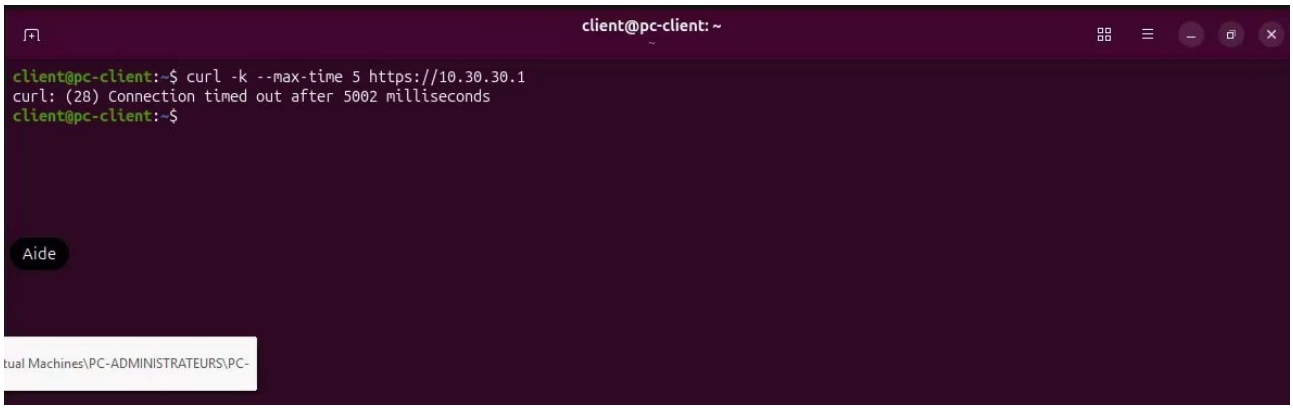


Figure A43 – *Sécurisation de l'administration.* Depuis le poste commercial, `curl https://10.30.30.1` expire : l'interface du pare-feu n'est plus accessible depuis le réseau local.

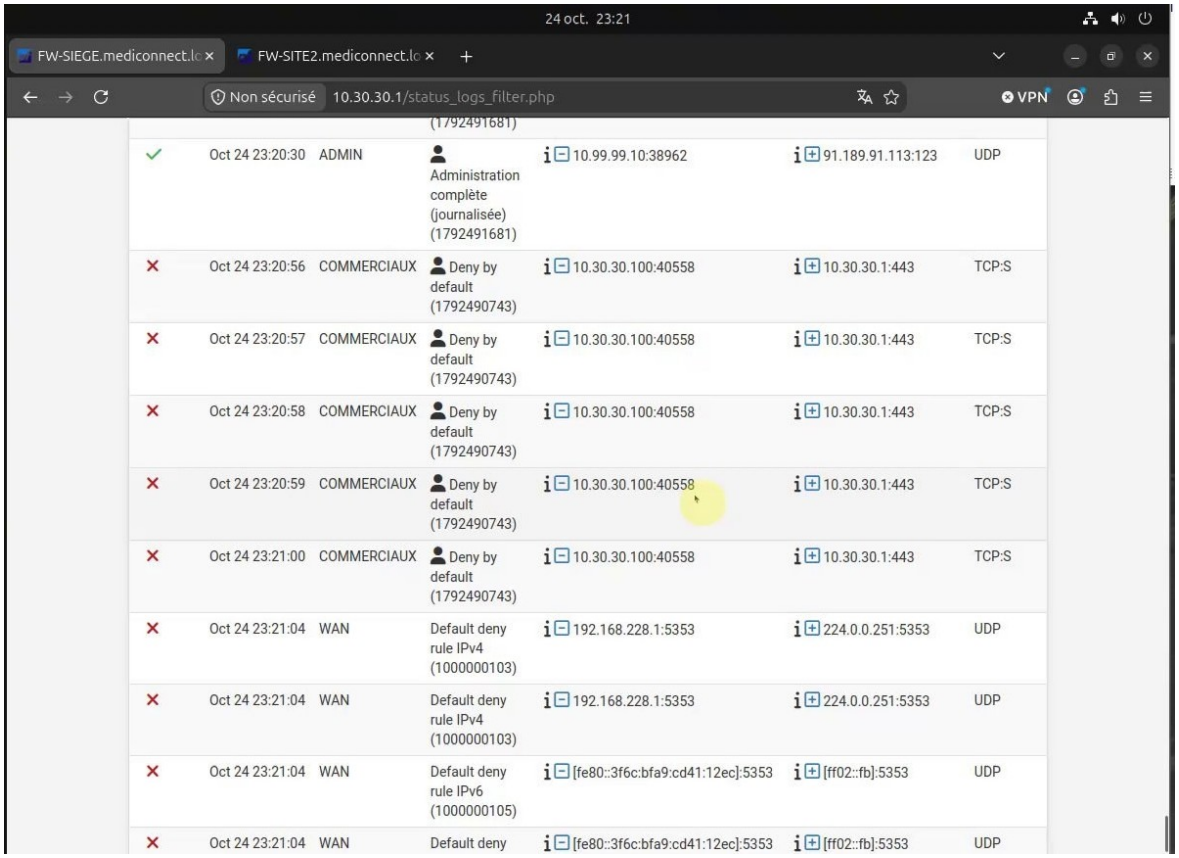


Figure A44 – *Sécurisation de l'administration.* Le poste commercial (10.30.30.100) tente d'ouvrir l'interface du pare-feu (10.30.30.1:443) : chaque tentative est refusée et journalisée.

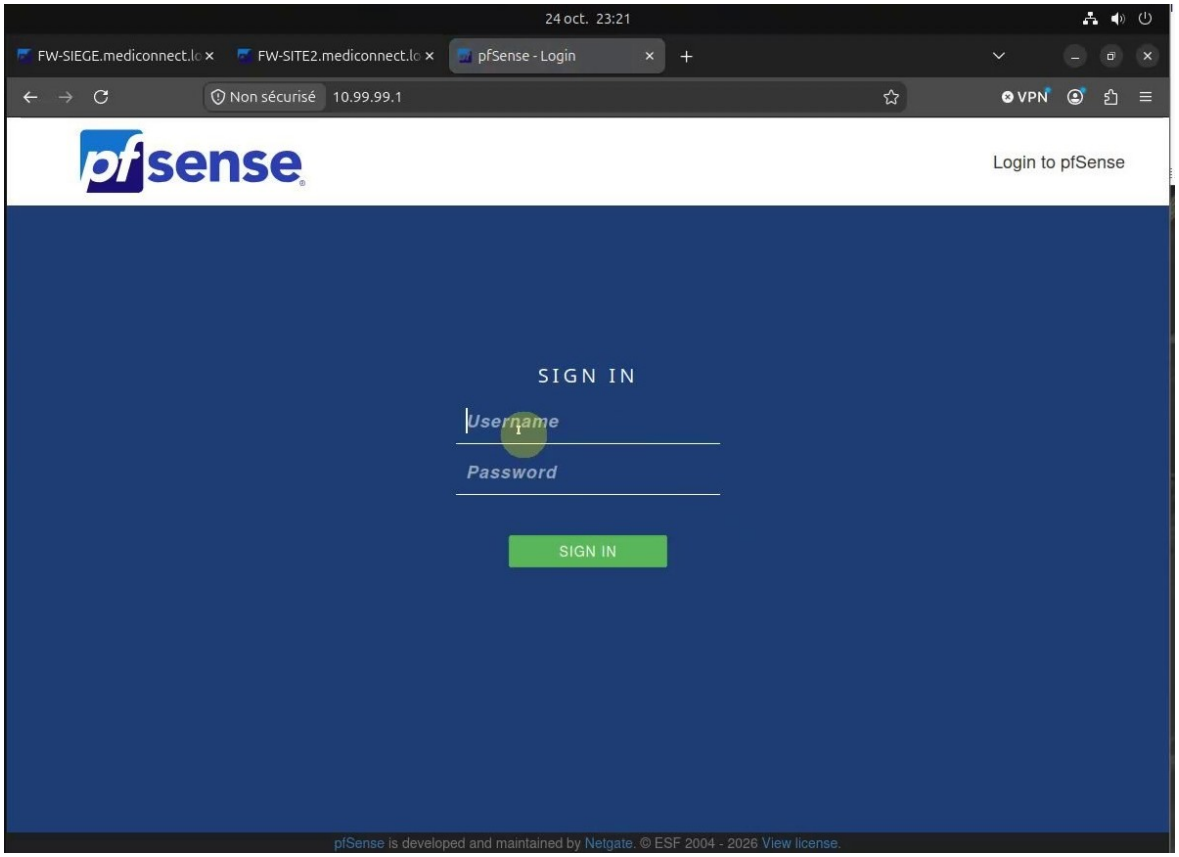


Figure A45 – *Sécurisation de l'administration.* Depuis PC-ADMINISTRATEURS, https://10.99.99.1 affiche la page de connexion de pfSense.

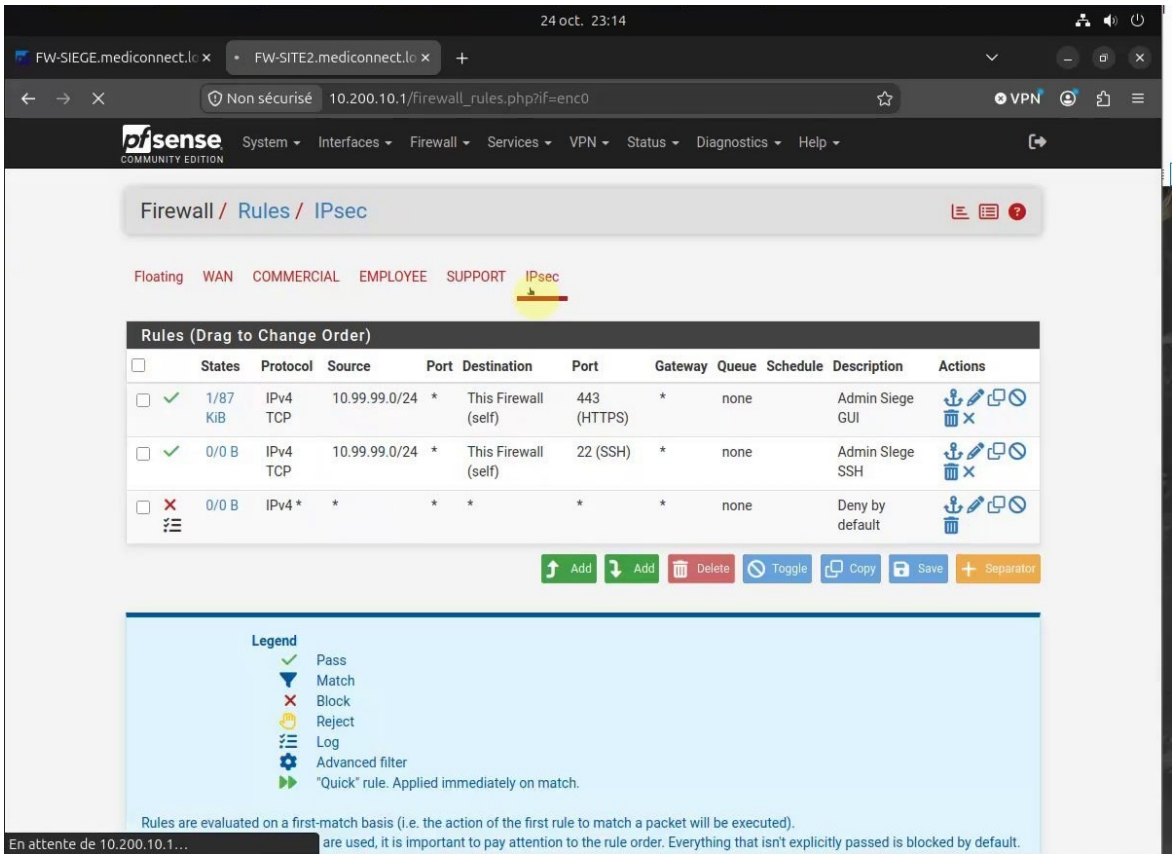


Figure A46 – *Sécurisation de l'administration.* FW_SITE2 ouvert depuis PC-ADMINISTRATEURS à travers le tunnel (10.200.10.1) : son onglet IPsec n'accepte l'administration (443, 22) que depuis 10.99.99.0/24.

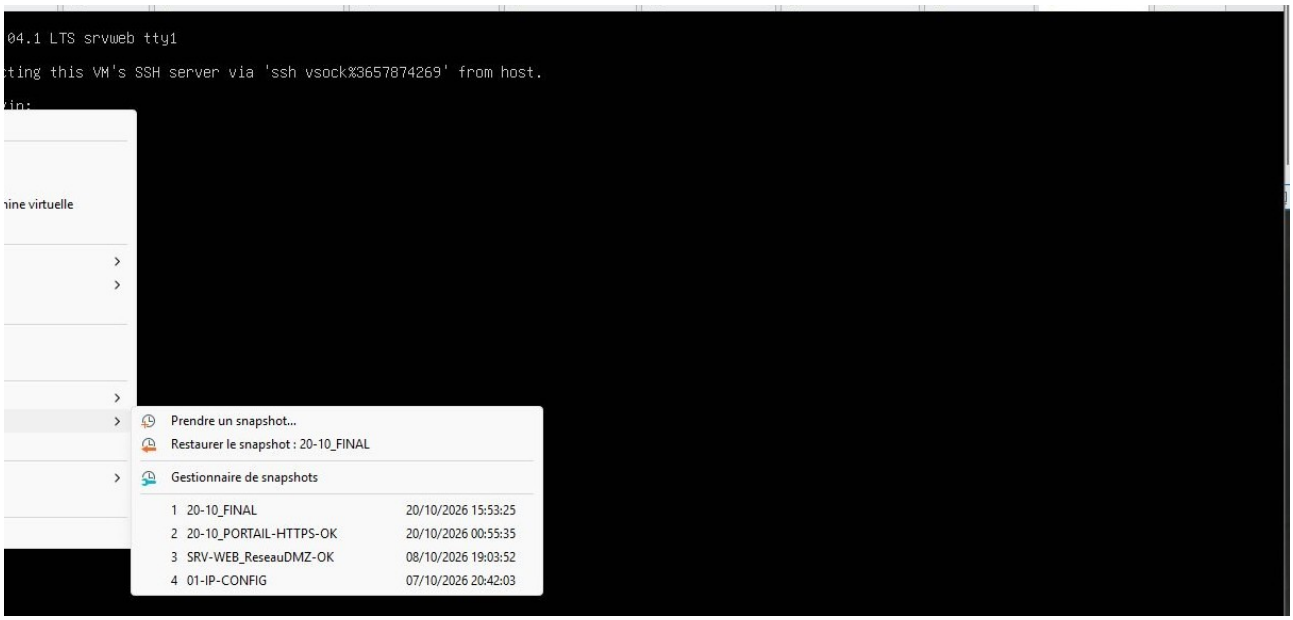


Figure A47 – *Sécurisation de l'administration.* Points de restauration VMware à chaque étape validée, jusqu'à l'état final « 20-10_FINAL ».

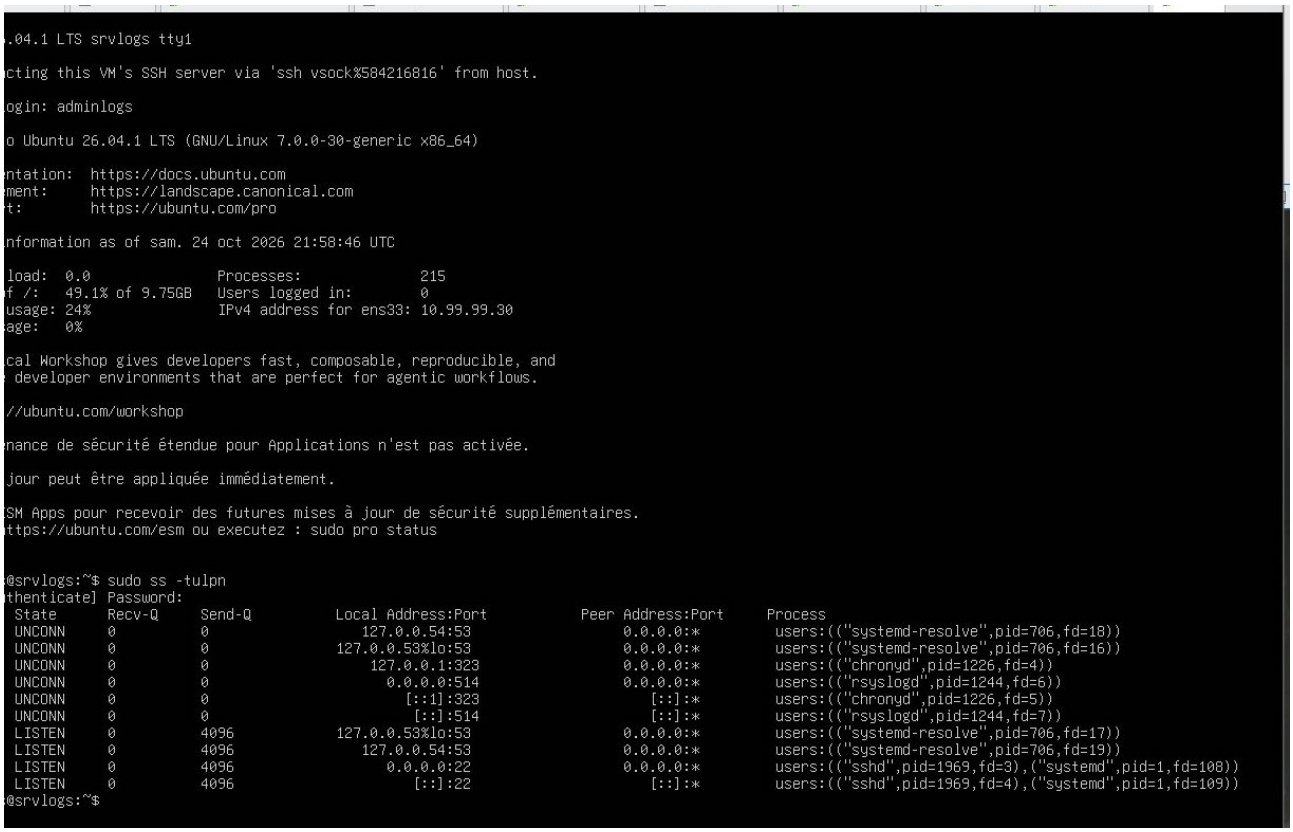


Figure A48 – *Stratégie de journalisation.* SRV_LOG n'écoute que sur 514/udp (réception des journaux) et 22/tcp (administration) ; les autres services sont locaux.

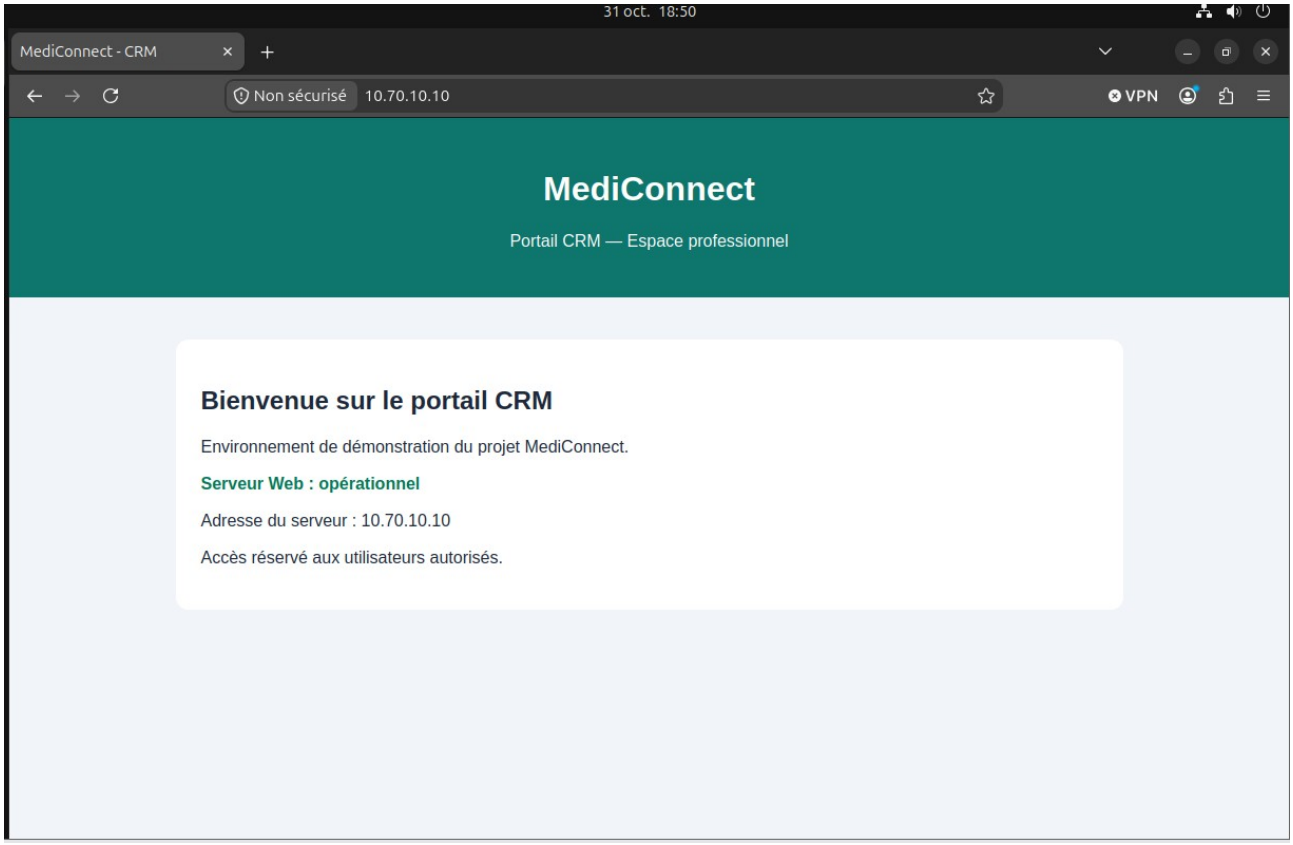


Figure A49 – *Tests réalisés.* Depuis le poste commercial, le portail CRM (10.70.10.10).

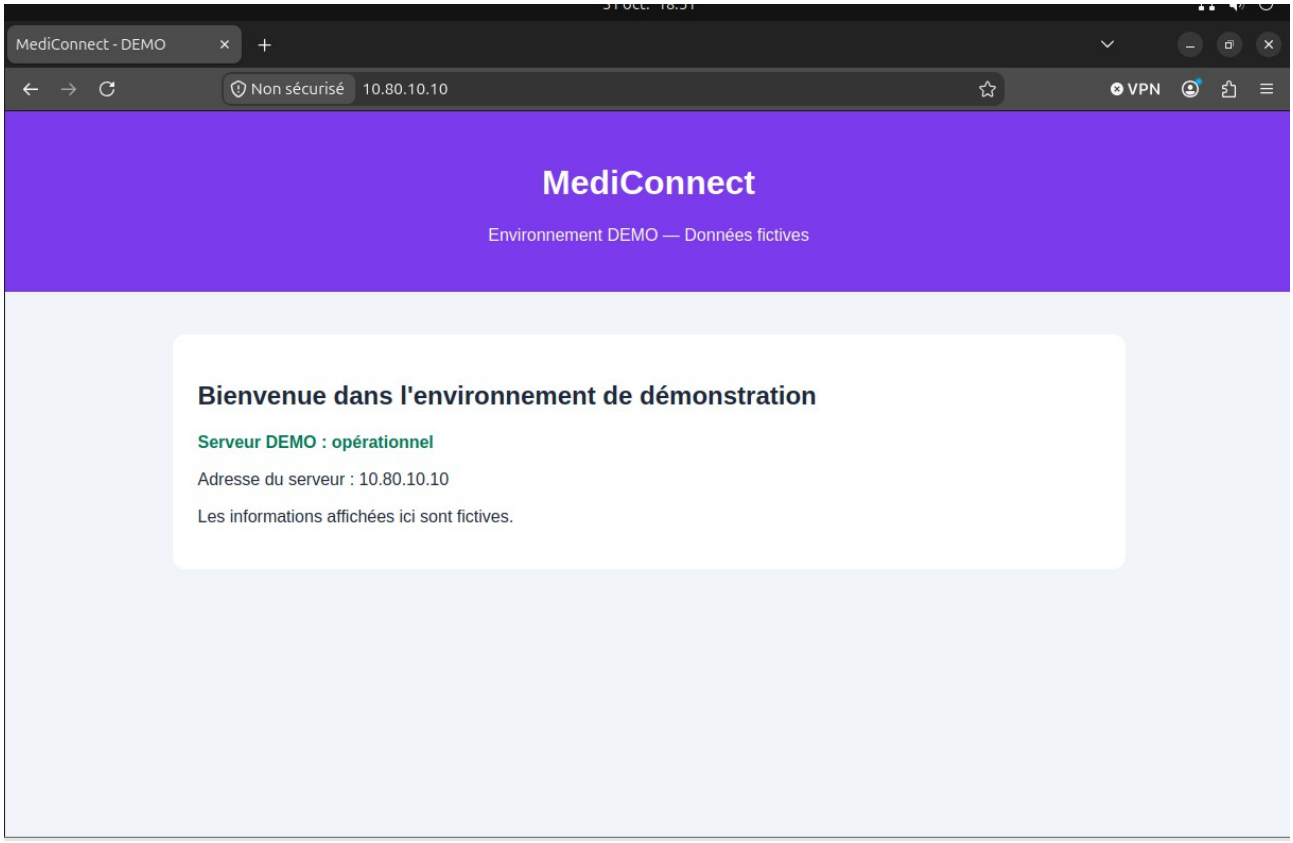


Figure A50 – *Tests réalisés.* Depuis le poste commercial, l'environnement de démonstration (10.80.10.10), séparé de la production.

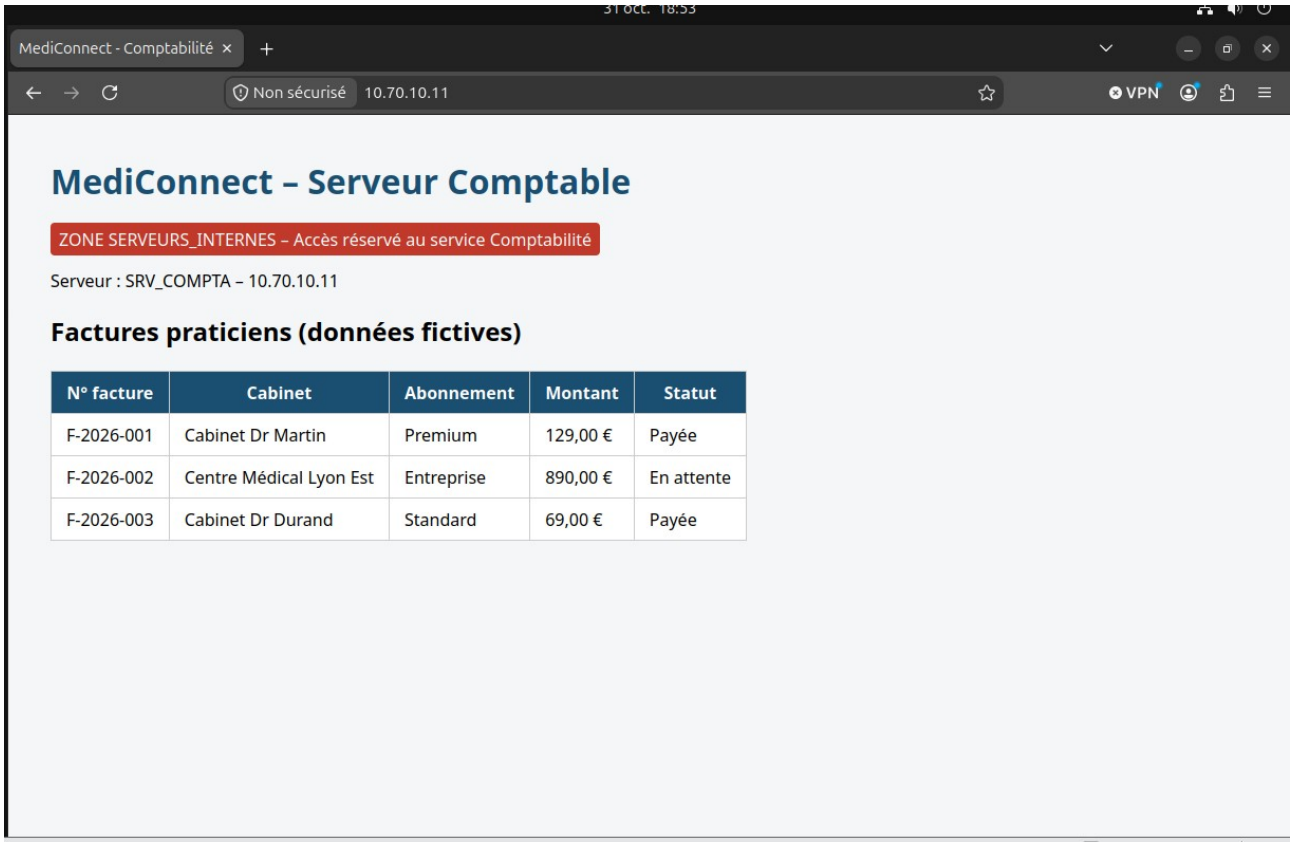


Figure A51 – *Tests réalisés.* Depuis le poste comptable, le serveur comptable (10.70.10.11), réservé à ce service.

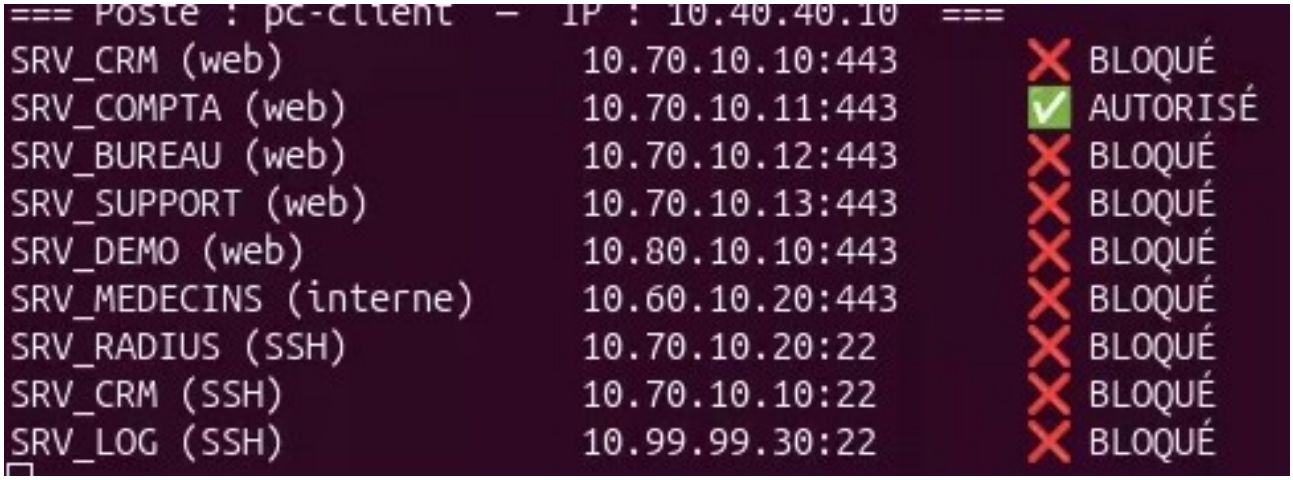


Figure A52 – *Tests réalisés.* COMPTABILITE : seul le serveur comptable est autorisé ; SRV_BUREAU et SRV_SUPPORT sont bloqués.



Figure A53 – *Tests réalisés.* EMPLOYES : SRV_BUREAU et le web autorisés, tout le reste bloqué.

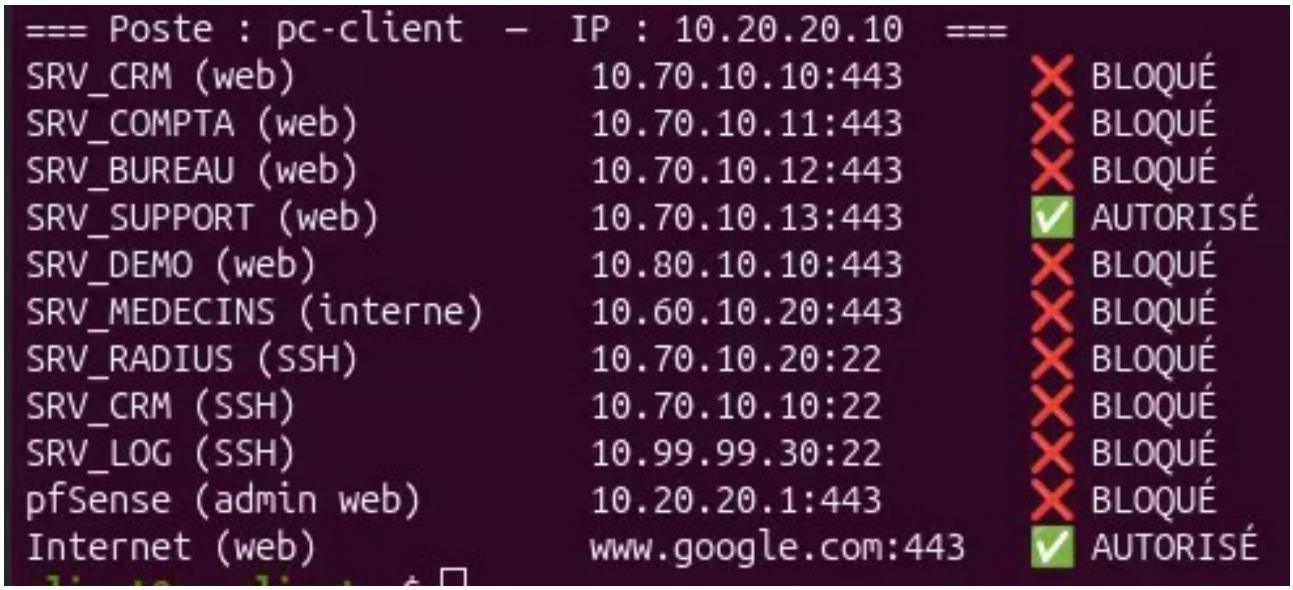


Figure A54 – *Tests réalisés.* SUPPORT : SRV_SUPPORT et le web autorisés, tout le reste bloqué.



Figure A55 – *Tests réalisés.* IT : SSH vers SRV_RADIUS et web uniquement ; SRV_BUREAU et SRV_SUPPORT bloqués.



Figure A56 – *Tests réalisés.* Site 2, commerciaux : CRM et DEMO via IPsec ; comptabilité, SRV_BUREAU, SRV_SUPPORT et FW_SITE2 refusés.



Figure A57 – *Tests réalisés.* Site 2, employés : SRV_BUREAU via IPsec et le web ; tout le reste refusé.

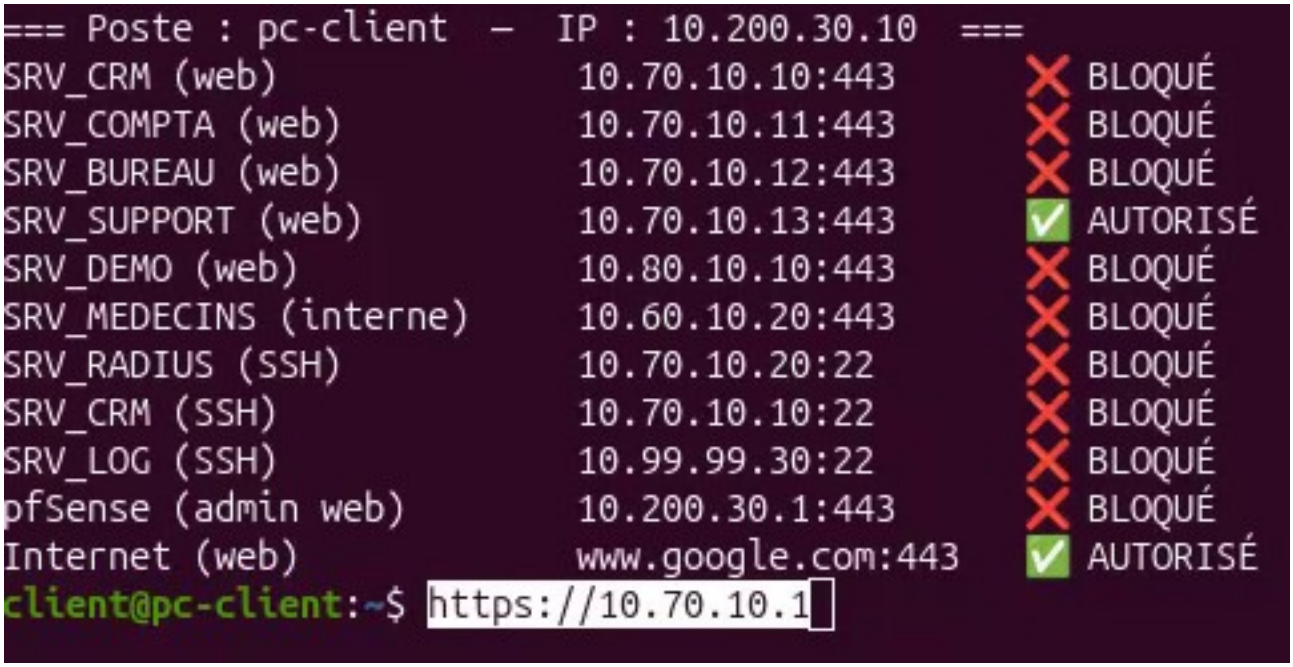


Figure A58 – *Tests réalisés.* Site 2, support : SRV_SUPPORT via IPsec et le web ; tout le reste refusé.

B. Script de test des accès

Script `test_acces.sh`, créé à l'identique sur chaque poste de test (section 13).

```
cat > ~/test_acces.sh << 'EOF'
#!/bin/bash
# Teste chaque serveur sur son port métier : connexion établie = AUTORISÉ, pas de réponse = BLOQUÉ
teste() {   # $1 = IP, $2 = port, $3 = nom affiché
  if timeout 3 bash -c "</dev/tcp/$1/$2" 2>/dev/null; then
    printf "%-26s %-20s ✔ AUTORISÉ\n" "$3" "$1:$2"
  else
    printf "%-26s %-20s ✘ BLOQUÉ\n"   "$3" "$1:$2"
  fi
}
echo "=== Poste : $(hostname)  –  IP : $(hostname -I) ==="
teste 10.70.10.10 443 "SRV_CRM (web)"            # 10.70.10.10 = SRV_CRM
teste 10.70.10.11 443 "SRV_COMPTA (web)"         # 10.70.10.11 = SRV_COMPTA
teste 10.70.10.12 443 "SRV_BUREAU (web)"         # 10.70.10.12 = SRV_BUREAU (employés)
teste 10.70.10.13 443 "SRV_SUPPORT (web)"        # 10.70.10.13 = SRV_SUPPORT (support)
teste 10.80.10.10 443 "SRV_DEMO (web)"           # 10.80.10.10 = SRV_DEMO
teste 10.60.10.20 443 "SRV_MEDECINS (interne)"   # 10.60.10.20 = SRV_MEDECINS (DMZ)
teste 10.70.10.20 22  "SRV_RADIUS (SSH)"         # 10.70.10.20 = SRV_RADIUS
teste 10.70.10.10 22  "SRV_CRM (SSH)"            # 10.70.10.10 = SRV_CRM, administration
teste 10.99.99.30 22  "SRV_LOG (SSH)"            # 10.99.99.30 = SRV_LOG (zone ADMIN)
teste $(ip route | awk '/default/{print $3; exit}') 443 "pfSense (admin web)"   # passerelle = pfSense
teste www.google.com 443 "Internet (web)"
EOF
chmod +x ~/test_acces.sh        # rend le script exécutable
```

Variante du poste d'administration (web et SSH)

```
cat > ~/test_acces.sh << 'EOF'
#!/bin/bash
# Teste chaque serveur en web (HTTPS) et en SSH : connexion établie = AUTORISÉ, pas de réponse = BLOQUÉ
teste() {   # $1 = IP, $2 = port, $3 = nom affiché
  if timeout 3 bash -c "</dev/tcp/$1/$2" 2>/dev/null; then
    printf "%-24s %-20s ✔ AUTORISÉ\n" "$3" "$1:$2"
  else
    printf "%-24s %-20s ✘ BLOQUÉ\n"   "$3" "$1:$2"
  fi
}
GW=$(ip route | awk '/default/{print $3; exit}')   # passerelle = pfSense
echo "=== Poste : $(hostname)  –  IP : $(hostname -I) ==="
echo "--- Accès web (HTTPS 443) ---"
teste 10.70.10.10 443 "SRV_CRM"
teste 10.70.10.11 443 "SRV_COMPTA"
teste 10.70.10.12 443 "SRV_BUREAU"
teste 10.70.10.13 443 "SRV_SUPPORT"
teste 10.80.10.10 443 "SRV_DEMO"
teste 10.60.10.10 443 "SRV_WEB (DMZ)"
teste 10.60.10.20 443 "SRV_MEDECINS (DMZ)"
teste $GW 443 "pfSense (admin web)"
teste www.google.com 443 "Internet"
echo "--- Administration (SSH 22) ---"
teste 10.70.10.10 22 "SRV_CRM"
teste 10.70.10.11 22 "SRV_COMPTA"
teste 10.70.10.12 22 "SRV_BUREAU"
teste 10.70.10.13 22 "SRV_SUPPORT"
teste 10.70.10.20 22 "SRV_RADIUS"
teste 10.80.10.10 22 "SRV_DEMO"
teste 10.60.10.10 22 "SRV_WEB (DMZ)"
teste 10.60.10.20 22 "SRV_MEDECINS (DMZ)"
teste 10.99.99.30 22 "SRV_LOG"
teste $GW 22 "pfSense (SSH)"
EOF
chmod +x ~/test_acces.sh
```